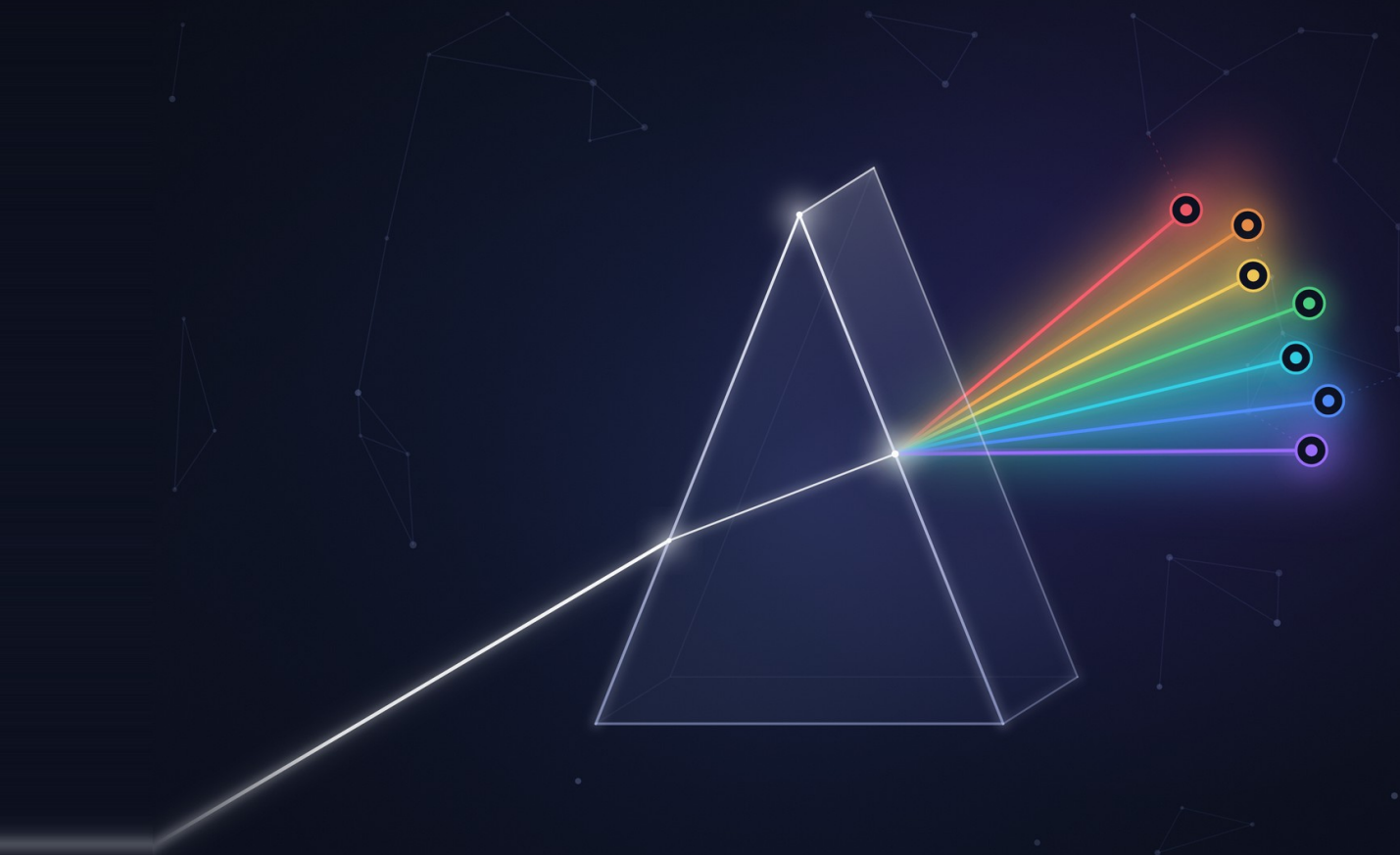




# MASTERING IDENTUS

did:prism

A Developer Handbook for  
Decentralized Identity

JON BAUER & ROBERTO CARVAJAL

# **Mastering Identus: A Developer Handbook**

Jon Bauer, Roberto Carvajal

2024-04-05

# Table of contents

|                                           |               |
|-------------------------------------------|---------------|
| <b>Welcome</b>                            | <b>1</b>      |
| <b>Copyright</b>                          | <b>2</b>      |
| <b>License</b>                            | <b>3</b>      |
| Book Content: . . . . .                   | 3             |
| Applications: . . . . .                   | 3             |
| <b>Dedication</b>                         | <b>4</b>      |
| <b>Preface</b>                            | <b>5</b>      |
| <br><b>Section I</b>                      | <br><b>6</b>  |
| <b>Introduction</b>                       | <b>7</b>      |
| <b>SSI Basics</b>                         | <b>8</b>      |
| What SSI Means in This Book . . . . .     | 8             |
| The SSI Interaction . . . . .             | 8             |
| DIDs and DID Documents . . . . .          | 9             |
| Verifiable Credentials . . . . .          | 10            |
| Verifiable Presentations . . . . .        | 11            |
| The Roles in the Trust Triangle . . . . . | 11            |
| Trust Registries and Governance . . . . . | 12            |
| Exchange Protocols . . . . .              | 12            |
| How This Maps to Identus . . . . .        | 12            |
| Developer Takeaways . . . . .             | 13            |
| <br><b>DIDs and DID Documents</b>         | <br><b>14</b> |
| Overview . . . . .                        | 14            |
| DID Syntax and DID Methods . . . . .      | 14            |
| DID Subjects and Controllers . . . . .    | 15            |
| DID Document Structure . . . . .          | 15            |
| Example PRISM DID Document . . . . .      | 16            |
| DID Lifecycle . . . . .                   | 18            |
| Resolvers . . . . .                       | 19            |
| Controllers . . . . .                     | 20            |
| Verification Flow . . . . .               | 20            |
| Privacy Checks . . . . .                  | 21            |

## Table of contents

|                                            |               |
|--------------------------------------------|---------------|
| <b>Identus Concepts</b>                    | <b>23</b>     |
| PRISM Node . . . . .                       | 24            |
| Cloud Agent . . . . .                      | 24            |
| Building Blocks . . . . .                  | 25            |
| Apollo - Cryptography . . . . .            | 25            |
| Castor - DID . . . . .                     | 25            |
| Pollux - Verifiable Credential . . . . .   | 26            |
| Mercury - DIDComm . . . . .                | 26            |
| Edge Agent . . . . .                       | 27            |
| Mediator . . . . .                         | 27            |
| Verifiable Data Registry (VDR) . . . . .   | 28            |
| <br><b>Section II - Getting Started</b>    | <br><b>30</b> |
| <b>Installation - Local Environment</b>    | <b>31</b>     |
| Overview . . . . .                         | 31            |
| Version Selection . . . . .                | 31            |
| Prerequisites . . . . .                    | 32            |
| Clone the Cloud Agent Repository . . . . . | 32            |
| Configure Local Agent Instances . . . . .  | 32            |
| Start the Issuer Cloud Agent . . . . .     | 34            |
| Start the Verifier Cloud Agent . . . . .   | 35            |
| Stop Local Instances . . . . .             | 36            |
| Local SSI Model . . . . .                  | 36            |
| <br><b>Agent REST API</b>                  | <br><b>37</b> |
| The Cloud Agent API . . . . .              | 37            |
| OpenAPI Specification . . . . .            | 39            |
| APISIX Gateway . . . . .                   | 40            |
| Swagger UI . . . . .                       | 40            |
| Postman . . . . .                          | 42            |
| Tutorials . . . . .                        | 42            |
| <br><b>Mediator</b>                        | <br><b>43</b> |
| Overview . . . . .                         | 43            |
| Protocol surface . . . . .                 | 43            |
| Version selection . . . . .                | 45            |
| Prerequisites . . . . .                    | 45            |
| Clone the mediator repository . . . . .    | 45            |
| Local configuration files . . . . .        | 45            |
| Start the mediator . . . . .               | 48            |
| Check the running mediator . . . . .       | 49            |
| Configuration notes . . . . .              | 50            |
| Stop the mediator . . . . .                | 50            |

|                                                                |           |
|----------------------------------------------------------------|-----------|
| <b>Section III - Building</b>                                  | <b>51</b> |
| <b>Example Project</b>                                         | <b>52</b> |
| Overview - Airline Ticket Wallet . . . . .                     | 52        |
| <b>Wallets</b>                                                 | <b>53</b> |
| Overview . . . . .                                             | 53        |
| Wallet Responsibilities . . . . .                              | 53        |
| Edge Agent Wallets . . . . .                                   | 54        |
| Pluto Storage . . . . .                                        | 55        |
| Cloud Agent Wallets . . . . .                                  | 55        |
| Multi-Tenant Wallets . . . . .                                 | 55        |
| Cloud Agent Key Material . . . . .                             | 56        |
| Choosing Edge or Cloud Custody . . . . .                       | 56        |
| Airline Ticket Flow . . . . .                                  | 57        |
| Implementation Notes . . . . .                                 | 58        |
| <b>DIDComm</b>                                                 | <b>59</b> |
| Overview . . . . .                                             | 59        |
| Key Characteristics . . . . .                                  | 59        |
| Message Structure . . . . .                                    | 60        |
| Protocols . . . . .                                            | 61        |
| Example interaction . . . . .                                  | 62        |
| Benefits . . . . .                                             | 62        |
| DIDComm in Identus . . . . .                                   | 63        |
| <b>Connections</b>                                             | <b>64</b> |
| Overview . . . . .                                             | 64        |
| Connections in Self-Sovereign Identity . . . . .               | 64        |
| PeerDIDs . . . . .                                             | 65        |
| Out of Band invites . . . . .                                  | 67        |
| Connecting two peers . . . . .                                 | 69        |
| Connectionless Credential Presentations and Issuance . . . . . | 75        |
| <b>Verifiable Credentials</b>                                  | <b>76</b> |
| Overview . . . . .                                             | 76        |
| Formats . . . . .                                              | 76        |
| JWT Verifiable Credentials . . . . .                           | 77        |
| SD-JWT Verifiable Credentials . . . . .                        | 77        |
| AnonCreds . . . . .                                            | 77        |
| OID4VCI . . . . .                                              | 78        |
| W3C VC 2.0 context . . . . .                                   | 78        |
| Schemas . . . . .                                              | 78        |
| Schema specifications . . . . .                                | 78        |
| Example schema . . . . .                                       | 79        |
| Creating schemas in Identus . . . . .                          | 79        |
| Versioning . . . . .                                           | 80        |

## Table of contents

|                                                  |                |
|--------------------------------------------------|----------------|
| Issuing . . . . .                                | 80             |
| Prerequisites . . . . .                          | 80             |
| Credential states . . . . .                      | 81             |
| Issuer flow . . . . .                            | 83             |
| Holder flow . . . . .                            | 84             |
| Connectionless issuance . . . . .                | 85             |
| OpenID4VCI issuance . . . . .                    | 86             |
| Presenting and verification . . . . .            | 86             |
| Revoking . . . . .                               | 87             |
| Revocation mechanism . . . . .                   | 87             |
| Revoking a credential . . . . .                  | 88             |
| Checking revocation status . . . . .             | 88             |
| <b>Verification</b>                              | <b>90</b>      |
| Presenting proof . . . . .                       | 90             |
| Verification and acceptance . . . . .            | 92             |
| Direct credential verification . . . . .         | 92             |
| Verification policies . . . . .                  | 93             |
| Selective disclosure . . . . .                   | 93             |
| <br><b>Section IV - Deploy</b>                   | <br><b>96</b>  |
| <b>Installation - Production Environment</b>     | <b>97</b>      |
| Scope . . . . .                                  | 97             |
| Version Selection . . . . .                      | 97             |
| Deployment Model . . . . .                       | 98             |
| Hardware and Data Requirements . . . . .         | 101            |
| Prepare the Base Identus Configuration . . . . . | 101            |
| Create the Preprod Environment File . . . . .    | 103            |
| Production-Style Compose Example . . . . .       | 105            |
| Production Configuration and Security . . . . .  | 110            |
| Docker and PostgreSQL Hardening . . . . .        | 111            |
| SSL and Reverse Proxy . . . . .                  | 112            |
| Key Management with HashiCorp Vault . . . . .    | 113            |
| Multi-Tenant Operation . . . . .                 | 113            |
| Keycloak External IAM . . . . .                  | 115            |
| Cardano Wallet Operations . . . . .              | 118            |
| Cardano DB Sync Operations . . . . .             | 121            |
| Preprod and Mainnet Network Selection . . . . .  | 122            |
| Copy Cardano Network Configuration . . . . .     | 123            |
| Start Preprod . . . . .                          | 124            |
| Production Checks . . . . .                      | 125            |
| <br><b>Maintenance</b>                           | <br><b>126</b> |
| Restarting and Cleanup . . . . .                 | 126            |

## Table of contents

|                                                             |                |
|-------------------------------------------------------------|----------------|
| Observability . . . . .                                     | 127            |
| Health and Service Checks . . . . .                         | 127            |
| Managing Nodes and Memory . . . . .                         | 127            |
| Performance Testing . . . . .                               | 128            |
| Analytics with BlockTrust Analytics . . . . .               | 128            |
| Upgrading Agents . . . . .                                  | 128            |
| Version Selection and Compatibility . . . . .               | 128            |
| Upgrade Procedure and Compatibility Notes . . . . .         | 128            |
| Minimizing Downtime . . . . .                               | 129            |
| HashiCorp Vault and Key Management . . . . .                | 129            |
| Key Management . . . . .                                    | 129            |
| Backups and Restore . . . . .                               | 129            |
| Key and Credential Rotation . . . . .                       | 130            |
| <br><b>Section V - Addendum</b>                             | <br><b>133</b> |
| <br><b>Trust Registries</b>                                 | <br><b>134</b> |
| What a Trust Registry is . . . . .                          | 134            |
| Where a Trust Registry sits in the architecture . . . . .   | 135            |
| The ToIP Trust Registry Query Protocol (TRQP) 2.0 . . . . . | 137            |
| Trust Registries and Identus today . . . . .                | 138            |
| <br><b>Continuing on Your Journey</b>                       | <br><b>139</b> |
| <br><b>Appendices</b>                                       | <br><b>140</b> |
| <br><b>Errata</b>                                           | <br><b>141</b> |
| <br><b>Glossary</b>                                         | <br><b>142</b> |

# Welcome

Welcome to the book!

# Copyright

IdentusBook.com

Copyright ©2024 Jon Bauer and Roberto Carvajal

All rights reserved

Please see our License for more information about fair use.

# License

## Book Content:

The content of the book (text, printed code, and images) are licensed under Creative Commons Attribution-NonCommercial-ShareAlike 4.0

The intent here is to allow anyone to use or excerpt from the book as long as they credit the source. In general we are very open to having our work shared non-commercially. We are copyrighting this book to protect the ability to version and revise the work officially, and to keep open the door for a print version if the opportunity arises and/or makes sense.

If you'd like to commercially reproduce contents from this book, please contact us.

## Applications:

The example code that accompanies this book is licensed under a MIT License

This allows anyone to freely take, modify, or redistribute the code as long as they also assign the MIT license to it.

# Dedication

We dedicate this book to the many contributors, at Input/Output, Hyperledger, LF Decentralized Trust, and community at large who have made this software what it is today.

Your work is appreciated, thank you!

# Preface

Identity underpins countless fields and products, and privacy should be a human right. Protecting that privacy for the people who use identity-enabled products is hard work, but it is work worth doing.

What drew us to digital identity was a possibility: genuine privacy for transactions between people. In *Code: And Other Laws of Cyberspace* (1999), Lawrence Lessig warned that technologies born in freedom, the Internet among them, come under steady pressure from governments to be controlled and regulated. Left unchecked, freedom curdles into control and privacy into surveillance.

Centralized systems carry an innate capacity for control, and absolute power corrupts absolutely. Decentralized technologies like blockchains and Self-Sovereign Identity reject the premise that all information must pass before a single set of eyes. Encryption, cryptography, and decentralized architecture prove we can have provable identity, commerce, and trust without surrendering privacy.

Identus is one expression of that ethos. With it, you can build applications that get real work done without feeding the surveillance machine. Maybe the goal is private conversations, agreements, and shopping. Maybe it is simply knowing that the people you deal with online are who they claim to be. Self-Sovereign Identity hands back the freedom and privacy we deserve in order to create and connect. It is, quite simply, the right thing to do.

We wrote this book to show fellow developers how to wield this powerful toolset, and we hope it moves you to build something great for all of us. We can't wait to see what you make.

Jon Bauer & Roberto Carvajal

## **Section I**

# Introduction

This is a developer-centric book about creating and launching Self-Sovereign applications with Idenus. We aim to show the reader how to configure, build and deploy a complex idea from scratch.

This is not a book about Self-Sovereign Identity. There are already great resources available on that topic. If you're new to the idea of SSI or Idenus, we recommend the excellent resources listed below as a pre-requisite to this text.

- Self-Sovereign Identity by Alex Preukschat, Drummond Reed, et al. This is the definitive book on SSI and it's ecosystem of topics.
- Idenus Documentation

It should be noted that Idenus is still new and at the time of writing this book, there are very few best practices, in fact, very little practices at all. A handful of adventurous developers have been building on the platform and sharing their experiences, and we hope to share our own learnings in hopes of magnifying that knowledge and helping developers skip the common pitfalls and bring their ideas to market.

We hope this text will be accessible to anyone who is curious about building decentralized digital identity applications.

We hope that newcomers will be able to use this text to skip common pitfalls and misunderstandings, and bring their ideas to market faster.

We're glad you could join us :)

# SSI Basics

## What SSI Means in This Book

Self-Sovereign Identity (SSI) describes identity systems built around user-held credentials and verifiable proofs, rather than a single identity provider that stores the user's account profile. A person, organization, device, or software agent can receive a credential from an issuer, store it in a wallet or agent, and present proof to a verifier. The verifier checks the proof and applies its own policy without a custom account integration with every issuer.

SSI does not make holder-provided claims trustworthy by itself. A verifier checks who issued the credential, what the credential says, whether the proof is valid, whether the credential is still in good standing, and whether the issuer is acceptable for that transaction. SSI changes custody and exchange of identity data; governance, law, contracts, and reputation still shape trust decisions.

This chapter uses standard terms from the W3C Decentralized Identifiers (DIDs) v1.0 Recommendation and the W3C Verifiable Credentials Data Model v2.0 Recommendation. DID Core defines DIDs as identifiers for verifiable, decentralized digital identity that can be decoupled from centralized registries, identity providers, and certificate authorities. The VC Data Model defines credentials, presentations, issuers, holders, subjects, and verifiers. The Identus Quick Start Guide describes Identus as core libraries for SSI interactions between issuers, holders, and verifiers.

## The SSI Interaction

A typical exchange has four steps.

1. An issuer makes claims about a subject and packages those claims as a credential.
2. A holder receives the credential and stores it in a wallet or agent.
3. A verifier asks the holder for proof that satisfies a specific request.
4. The holder returns a presentation, and the verifier checks cryptography, status, and business policy.

Example: a university issues a degree credential to Alice. Alice receives the credential in her wallet and acts as holder. The degree describes Alice, making Alice the subject. An employer acts as verifier and requests proof that Alice has a computer science degree from an accredited university. Alice's wallet creates a presentation from the credential. The employer's software checks that the university signed the credential, that Alice can prove control of the holder keys required by the credential format, that the issuer has not suspended

or revoked the credential, and that the university is accepted under the employer's hiring policy.

Policy evaluation is validation. Cryptographic verification can show that an issuer's key secured the credential and that no one modified the credential after issuance. It cannot show that the issuer is acceptable for a particular decision. A diploma from an unknown training provider can pass cryptographic verification and still fail an employer's policy. The W3C VC specification describes validation as the verifier's business-rule check for whether a credential is proper for a particular use.

## The SSI interaction

A university degree, held by Alice and presented to an employer

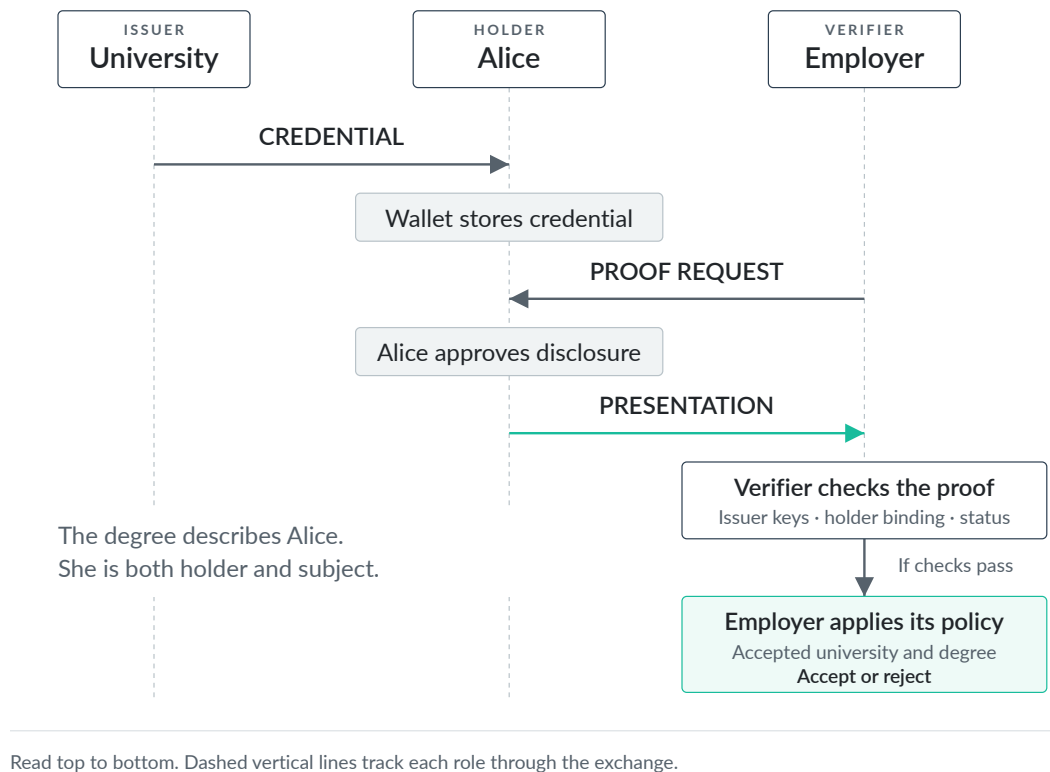


Figure 1: The issuer supplies the credential; the holder supplies the presentation. The employer decides whether to accept it after technical checks.

## DIDs and DID Documents

A Decentralized Identifier (DID) is a URI. It has a `did:` scheme, a DID method, and a method-specific identifier. In `did:prism:4a9bce8d72e4c30017c42f2b`, the method is `prism`; the last segment is the identifier data defined by that method.

The DID method tells software how to create, resolve, update, and deactivate that class of DID. DID Core does not require one storage technology. A DID method can use a distributed ledger, a database, a peer-to-peer network, or another verifiable data registry, as long as the method defines the required operations.

A DID resolves to a DID Document. DID Documents express public verification material, verification relationships, and services. A DID Document can tell software which public keys can be used for authentication, assertion, key agreement, capability invocation, or capability delegation. It can list service endpoints for communication protocols such as DIDComm. It should not contain secrets, private keys, or a personal profile.

The DID subject and DID controller may be the same entity, but they do not have to be. The subject is the person, organization, device, data model, or other thing identified by the DID. The controller is the entity that can change the DID Document according to the DID method. A company DID might identify the company as subject, and the company might delegate key operations to a Cloud Agent it controls.

DIDs can create correlation risk. DID Core warns that globally unambiguous identifiers can link activity across contexts. Pairwise DIDs reduce that risk by giving each relationship its own pseudonymous DID. Apply the same privacy review to DID Documents: reused keys, unusual service endpoints, or descriptive properties can still link activity across relationships.

## **Verifiable Credentials**

A credential is a set of claims made by an issuer. A Verifiable Credential (VC) is a credential with a securing mechanism that lets software detect tampering and check authorship. The VC can be about a person, organization, device, account, shipment, software artifact, or any other subject.

The issuer decides what to claim and signs or otherwise secures the credential. The holder stores the credential. The subject is the entity the claims describe. The holder and subject often match, but not always. A parent can hold a credential about a child. A company officer can hold a credential about the company. A device fleet manager can hold credentials about devices.

The data model is separate from the credential format. W3C VC 2.0 defines the model. Implementations can secure and transport credentials through different formats and protocols. Identus chapters later in the book use JWT-VC, SD-JWT-VC, and AnonCreds in implementation flows, so the right choice depends on the credential formats supported by the agents and wallets in that flow.

Credential status is part of production verification. W3C VC 2.0 defines `credentialStatus` for discovering status information such as suspension or revocation. The details depend on the status method. A verifier that accepts a credential without checking status may accept a credential the issuer no longer stands behind.

## **Verifiable Presentations**

A Verifiable Presentation (VP) is data derived from one or more credentials and shared with a specific verifier. A presentation can include one credential, parts of one credential, or data from more than one credential, depending on the credential format and proof mechanism.

A holder uses presentations to respond to verifier requests. A verifier asks for the data it needs. The wallet shows the request to the holder. The holder approves or rejects the disclosure. The wallet then builds a presentation that fits the request and the credential format.

Selective disclosure depends on the credential format and proof mechanism. The W3C VC Data Model defines selective disclosure as the holder’s ability to make fine-grained choices about what to share. The same specification treats data minimization as a best practice: verifiers should request the minimum information needed for a transaction. A credential format that supports selective disclosure can let Alice prove she is over 21 without revealing her full birth date. A format that lacks that feature may require sharing more data.

## **The Roles in the Trust Triangle**

SSI discussions often use the “Triangle of Trust” to describe issuer, holder, and verifier. Treat the triangle as roles in an interaction, not permanent labels for people or organizations.

An issuer creates a credential and takes responsibility for the claims it makes. A department of motor vehicles can issue a driver’s license credential. A university can issue a degree credential. A gym can issue a membership credential. The issuer’s authority comes from the surrounding context: law, accreditation, contract, community rules, reputation, or governance.

A holder receives credentials and creates presentations from them. The holder may be a person using a mobile wallet, a company using a Cloud Agent, or software managing credentials for devices. Holder control means the holder decides whether to present a credential in a given interaction, subject to wallet design, custody model, law, and policy.

A verifier receives a presentation and decides whether to accept it. Verification usually checks syntax, cryptographic proofs, issuer keys, holder binding, credential status, and schema. Validation checks business rules. For a bar, “over 21 and issued by a recognized state DMV” may be enough. For a hospital employee credential, the verifier may need role, facility, license status, and trust registry checks.

Roles are interaction-specific. The same entity can hold one credential, verify another credential, and issue a third credential.

## **Trust Registries and Governance**

A DID can prove control over keys. A credential can prove that an issuer made a claim. A verifier still needs a way to decide whether that issuer has the right authority for the verifier's context. Trust registries publish that authorization information for a defined ecosystem.

The Trust over IP Foundation describes a trust registry query in plain terms: “Does entity X hold authorization Y under ecosystem governance framework Z?” The ToIP Trust Registry Query Protocol v2.0 announcement frames TRQP as a read-only way to discover who is authorized to do what within a digital trust ecosystem. LF Decentralized Trust describes a trust registry as a system of record containing authoritative information that relying parties use for trust decisions.

A trust registry does not create authority by itself. Authority comes from the governance framework behind it. For a real estate credential, the registry might list licensed agents and the credential types they can issue or verify. For a university degree, a registry might list accredited institutions. For a supply-chain credential, it might list auditors accepted by a particular industry group.

A verifier should treat technical verification and acceptance policy as separate checks. Verification checks proofs, keys, syntax, and status. Acceptance policy checks whether the issuer and credential type fit the relying party's rules.

## **Exchange Protocols**

DIDs and VCs define data models and verification material. Applications still need protocols to exchange messages, issue credentials, and request presentations.

DIDComm Messaging v2.1 defines encrypted message formats used by many agent-to-agent SSI systems. DIDComm encrypted messages hide content from everyone except authorized recipients, disclose and prove the sender to those recipients in authenticated mode, and provide integrity guarantees. Identus uses DIDComm V2 for Cloud Agent-to-Cloud Agent communication and for many agent flows.

The OpenID Foundation defines OAuth-based protocols for credential exchange. OpenID4VCI 1.0 defines an API for issuing Verifiable Credentials. OpenID4VP 1.0 defines a protocol for requesting and presenting credentials. Production ecosystems may support DIDComm, OpenID4VCI, OpenID4VP, QR-code handoff, offline presentation, or a mix of these paths.

## **How This Maps to Identus**

Identus gives developers components for these SSI roles, so application code can use agents, SDKs, and APIs instead of reimplementing the standards stack.

The Identus Cloud Agent can issue, hold, and verify VCs; manage DIDs and DID-based connections; expose a REST API; and use DIDComm V2 for agent communication. Typical uses include custodial wallets, enterprise issuers, verifier services, and backend workflows.

The Identus DID management documentation explains that Cloud Agent manages PRISM DIDs and Peer DIDs. PRISM DIDs fit public issuer identity and ledger-backed resolution. Peer DIDs fit DIDComm activities where relationship-specific identifiers reduce correlation.

The Identus Quick Start Guide describes PRISM Node as the Verifiable Data Registry component used to anchor key information for issuance and verification, and describes mediators as services that store and relay messages between Cloud Agents and wallet SDKs. PRISM Node supports public DID resolution. Mediators handle message relay for offline or intermittently connected agents without reading encrypted DIDComm content.

## **Developer Takeaways**

SSI lets issuers, holders, and verifiers exchange claims with cryptographic proof and holder participation. DIDs identify and resolve verification material. DID Documents publish public keys and services, not private identity profiles. Verifiable Credentials carry issuer claims. Verifiable Presentations let holders respond to verifier requests. Verification checks proofs and status. Validation applies policy. Trust registries and governance help verifiers decide which issuers and credential types count in a specific ecosystem.

In Identus, these ideas map to components: PRISM Node for public DID resolution, Cloud Agent for server-side issuer/holder/verifier work, Edge Agent SDKs for wallets, DIDComm for secure agent messages, and mediators for routing when edge agents are offline.

# DIDs and DID Documents

## Overview

A **Decentralized Identifier (DID)** is a URI for a subject. The subject can be a person, organization, device, software agent, data model, or another entity chosen by the DID controller. The W3C DID Core specification defines a DID as a URI with three parts: the `did:` scheme, a method name, and a method-specific identifier.

The DID itself is only the identifier. A resolver resolves the DID and returns a DID resolution result. A successful result includes a **DID Document**, resolution metadata, and DID Document metadata. The W3C DID Resolution specification defines this resolver interface and leaves the method-specific retrieval steps to the DID method.

A **DID Document** publishes the public information software needs to interact with the DID subject: verification methods, verification relationships, and services. A DID Document should not contain private keys, secrets, or personal profile data. DID Core warns that public DID Documents can create privacy and correlation risk, so personal data belongs in credentials, peer-to-peer exchanges, or controlled service endpoints rather than the public document.

Idenitrus developers use `did:prism` and `did:peer` for different jobs. `did:prism` fits public issuer and verifier identities that need ledger-backed resolution. `did:peer` fits relationship-specific DIDComm activity. A wallet, Cloud Agent, or mediator can use separate Peer DIDs to reduce correlation between relationships. The Idenitrus DID management documentation describes Cloud Agent support for both managed PRISM DIDs and managed Peer DIDs.

## DID Syntax and DID Methods

The generic syntax is:

```
did:<method>:<method-specific-id>
```

For `did:prism`, the PRISM DID method specification defines this shape:

```
did:prism:<initial-hash>[:<encoded-state>]
```

The short form contains the `did:prism:` prefix and a 64-character initial hash. The long form appends encoded initial state after another colon. PRISM uses the long form before the controller anchors the DID. After the controller publishes the DID operation and the PRISM VDR accepts it, software can use the short form as the published PRISM DID.

The encoded state in a long-form PRISM DID is not a JSON DID Document. It is method-specific state encoded by the PRISM method so a resolver can construct the initial DID Document before a public create operation appears in the VDR.

A **DID method** defines how software creates, resolves, updates, and deactivates DIDs and DID Documents for that method. DID Core defines the shared data model. The method specification defines the registry, protocol operations, encoding, validation rules, and lifecycle.

For `did:prism`, the PRISM method defines create, update, and deactivate operations. PRISM nodes read operations from the VDR and maintain the current state needed to construct DID Documents. The PRISM VDR specification describes SSI entries as event chains with create, update, and deactivate events.

## DID Subjects and Controllers

The DID identifies the DID subject. The DID method authorizes the DID controller to change the DID Document. These roles can be the same entity, but they do not have to be.

For example, a university can be the subject of `did:prism:...`. The university can run an Identus Cloud Agent that holds the controller keys and publishes DID updates through PRISM Node. The university is still the issuer in the credential exchange; the Cloud Agent is infrastructure acting for the university.

The top-level **controller** property in a DID Document names one or more controller DIDs. DID Core treats this authorization separately from **authentication**. A verifier that checks an authentication proof checks the **authentication** relationship. Software that processes DID update authority follows the DID method's controller rules.

The **controller** property inside a **verificationMethod** has a different scope. It identifies the controller of that verification method. It can match the DID Document `id`, or it can point to another DID when a system delegates key control.

## DID Document Structure

DID Documents share a common data model and can have different representations. DID Core and PRISM examples use JSON-LD with `@context`; JSON representations can omit JSON-LD context.

Common DID Document properties are:

| Property                          | What software uses it for                                                                                        |
|-----------------------------------|------------------------------------------------------------------------------------------------------------------|
| <code>id</code>                   | The DID of the subject described by the DID Document.                                                            |
| <code>controller</code>           | One or more DIDs authorized to control the DID Document under the DID method's rules.                            |
| <code>verificationMethod</code>   | Public verification material, such as JWKs, plus an <code>id</code> , <code>type</code> , and method controller. |
| <code>authentication</code>       | Verification methods approved for challenge-response authentication as the DID subject.                          |
| <code>assertionMethod</code>      | Verification methods approved for making claims, including issuing Verifiable Credentials.                       |
| <code>keyAgreement</code>         | Verification methods approved for key agreement, including DIDComm encryption setup.                             |
| <code>capabilityInvocation</code> | Verification methods approved for invoking object capabilities.                                                  |
| <code>capabilityDelegation</code> | Verification methods approved for delegating object capabilities.                                                |
| <code>service</code>              | Endpoints or service descriptors for interaction, such as DIDComm messaging.                                     |
| <code>@context</code>             | JSON-LD context used by JSON-LD representations.                                                                 |

Verification methods can be embedded directly in a verification relationship or referenced by DID URL. PRISM examples define methods once under `verificationMethod` and reference them from `authentication`, `assertionMethod`, or `keyAgreement`.

## Example PRISM DID Document

This example uses fake, shortened values so the structure stays readable. Do not treat these identifiers or keys as resolvable PRISM data.

```
{
  "@context": [
    "https://www.w3.org/ns/did/v1",
    "https://w3id.org/security/suites/jws-2020/v1",
    "https://didcomm.org/messaging/contexts/v2"
  ],
  "id": "did:prism:example-university",
  "verificationMethod": [
```

```

{
  "id": "did:prism:example-university#authentication-key-1",
  "type": "JsonWebKey2020",
  "controller": "did:prism:example-university",
  "publicKeyJwk": {
    "kty": "OKP",
    "crv": "Ed25519",
    "x": "fake-authentication-public-key"
  }
},
{
  "id": "did:prism:example-university#issuing-key-1",
  "type": "JsonWebKey2020",
  "controller": "did:prism:example-university",
  "publicKeyJwk": {
    "kty": "OKP",
    "crv": "Ed25519",
    "x": "fake-issuing-public-key"
  }
},
{
  "id": "did:prism:example-university#key-agreement-key-1",
  "type": "JsonWebKey2020",
  "controller": "did:prism:example-university",
  "publicKeyJwk": {
    "kty": "OKP",
    "crv": "X25519",
    "x": "fake-key-agreement-public-key"
  }
}
],
"authentication": [
  "did:prism:example-university#authentication-key-1"
],
"assertionMethod": [
  "did:prism:example-university#issuing-key-1"
],
"keyAgreement": [
  "did:prism:example-university#key-agreement-key-1"
],
"service": [
  {
    "id": "did:prism:example-university#didcomm-1",
    "type": "DIDCommMessaging",
    "serviceEndpoint": [
      {

```

```
    "uri": "https://agent.example.edu/didcomm",  
    "accept": ["didcomm/v2"],  
    "routingKeys": ["did:peer:example-mediator#key-1"]  
  }  
]  
}  
]  
}
```

In the example, the issuer's software can use `#issuing-key-1` to sign a Verifiable Credential, and a verifier can check that the referenced key appears in `assertionMethod`. A DIDComm implementation can use `#key-agreement-key-1` to prepare encrypted messages and the `DIDCommMessaging` service to learn the accepted DIDComm profile, endpoint URI, and routing keys.

## DID Lifecycle

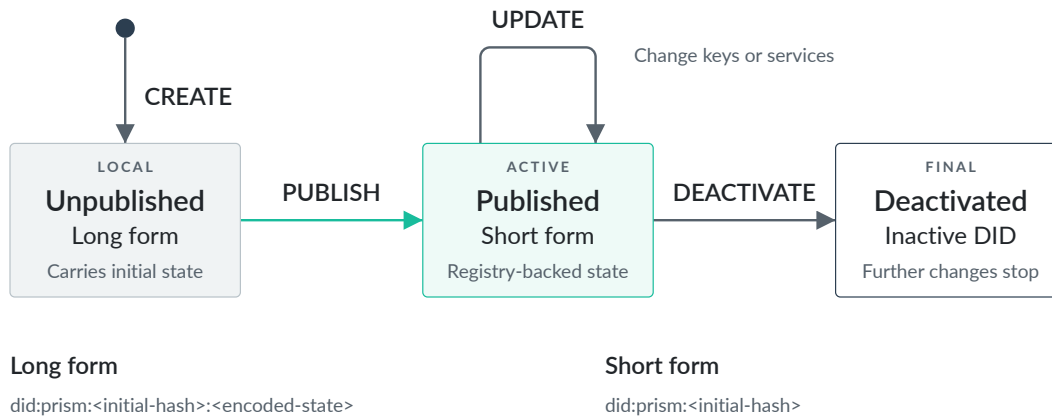
Every DID method defines its own lifecycle rules. The common operations are create, resolve, update, and deactivate. Identus developers see those operations through Cloud Agent APIs, resolver APIs, SDK resolver configuration, and PRISM Node behavior.

For a managed PRISM DID in Cloud Agent, the controller creates a DID from a document template. Cloud Agent derives PRISM key material from a wallet seed and derivation path, stores the derivation path, and can reconstruct key material at runtime from the seed. The Identus Quick Start creates a long-form PRISM DID, publishes it through Cloud Agent, and then uses the short form as `publishedPrismDID` for schema and credential flows.

PRISM updates publish method operations that change the DID state, such as adding or removing verification methods or services. The VDR state machine treats deactivation as a final state. After deactivation, resolvers should no longer treat the DID as active.

## PRISM DID lifecycle

Conceptual states of one DID



Both forms identify the same DID. Updates change its document.

Arrows show successful operations. Resolution reads state without changing it.

Figure 1: The controller signs registry operations. Publication, updates, and deactivation take effect when the registry accepts the confirmed operations. Deactivation ends the DID’s lifecycle.

For a managed Peer DID, Cloud Agent generates random key material and stores it in secret storage. Peer DIDs are not used as global public issuer identifiers. They fit DIDComm relationships and mediation, where each relationship can use separate identifiers and keys.

## Resolvers

A resolver takes a DID and returns the DID Document plus metadata. The resolver must understand the DID method. A generic resolver can route different methods to method-specific drivers, but the method driver still performs the method-specific retrieval and validation.

For `did:prism`, a resolver needs the current PRISM state for the DID. Identus documents these resolution paths: Cloud Agent with PRISM Node, Universal Resolver support for PRISM DIDs, SDK resolver configuration, and community indexers. The Identus DID PRISM Resolver documentation describes Cloud Agent and PRISM Node as a solution for creating, updating, deactivating, and resolving PRISM DIDs.

Resolver choice is a trust decision. A verifier can use a hosted resolver, run its own resolver, or resolve against local indexed state. The verifier software should treat resolver output as

input to verification, not as the whole trust decision. Credential verification still checks the proof, the verification relationship, credential status, schema, and verifier policy.

## Controllers

Controllers are entities authorized to change the DID Document under the DID method's rules. A controller can be a person using a wallet, an organization running Cloud Agent, or a service acting under an organization's operational control. The DID Document records controllers as DIDs; the legal or governance authority behind those controllers lives outside the DID Document.

In `did:prism`, the controller proves authority through the method's signed operations. PRISM VDR validation rules require create operations to be signed with the DID's master key and update or deactivate events to be signed by a current master key. Cloud Agent-managed PRISM DID APIs perform this protocol work for the application, but the controller model still determines who can rotate keys, add services, or deactivate the DID.

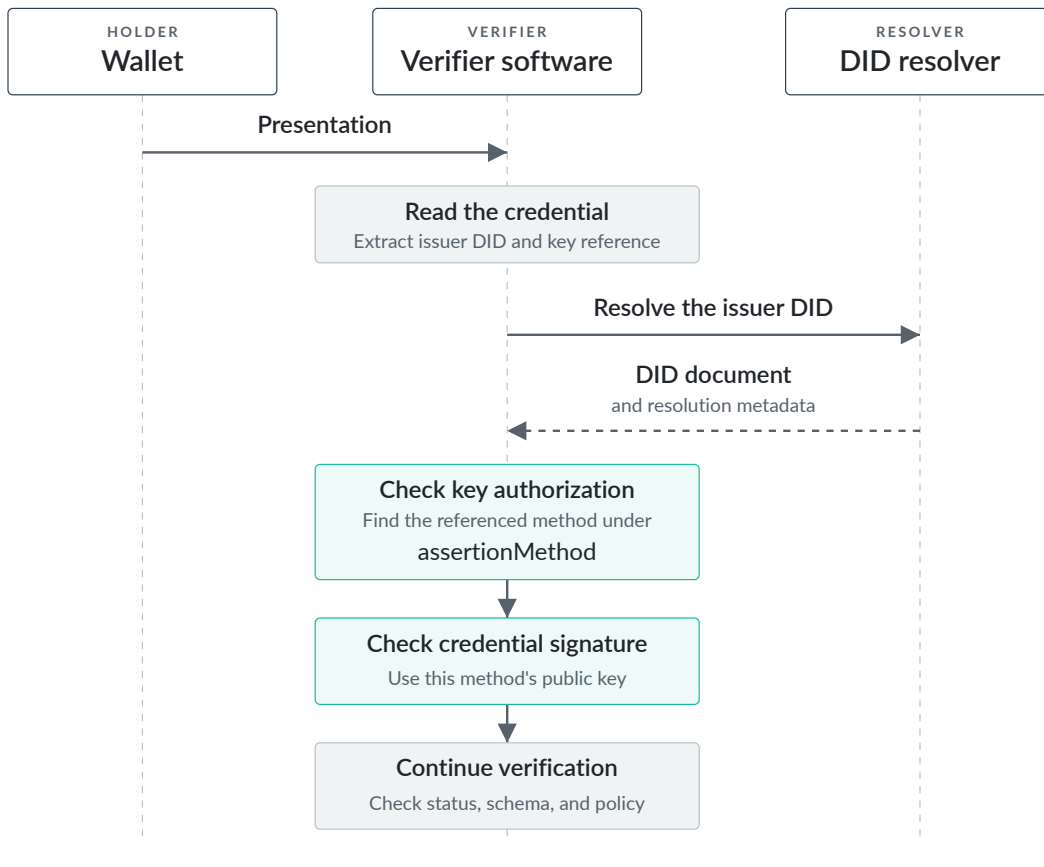
## Verification Flow

A verifier that checks a credential issued from a PRISM DID uses this flow.

1. The verifier receives a presentation from the holder's wallet or Edge Agent.
2. The verifier extracts the issuer DID and the verification method referenced by the credential proof.
3. The resolver resolves the issuer DID to a DID Document.
4. The verifier dereferences the verification method and checks that the method appears under `assertionMethod`.
5. The verifier checks the cryptographic proof with the public key in the verification method.
6. The verifier checks credential status, schema, and policy, including whether the issuer is trusted for the requested transaction.

## Finding and checking an issuer key

Issuer-key verification for a credential issued from a PRISM DID



Successful path. The verifier stops if resolution, key authorization, or signature checks fail.

Figure 2: The resolver supplies the DID document. The verifier checks the issuer key's authorization and the credential signature, then applies the remaining credential checks and trust policy.

DID verification relationships prevent key reuse across proof purposes. A key listed only under `authentication` cannot be used to issue a credential. A key listed only under `assertionMethod` cannot be used for DIDComm key agreement. The verifier software has to check the relationship that matches the operation it is validating.

## Privacy Checks

Public DIDs are useful for issuers, verifiers, schemas, and trust registries, but they create correlation. A public issuer DID should remain stable so verifiers can resolve issuer keys and policy systems can refer to the issuer. A holder's wallet should use pairwise or relationship-specific DIDs for DIDComm connections unless the holder intends public correlation.

## *DIDs and DID Documents*

Before publishing a DID Document, the controller should check that it contains only the public material needed for the DID method and protocol flows:

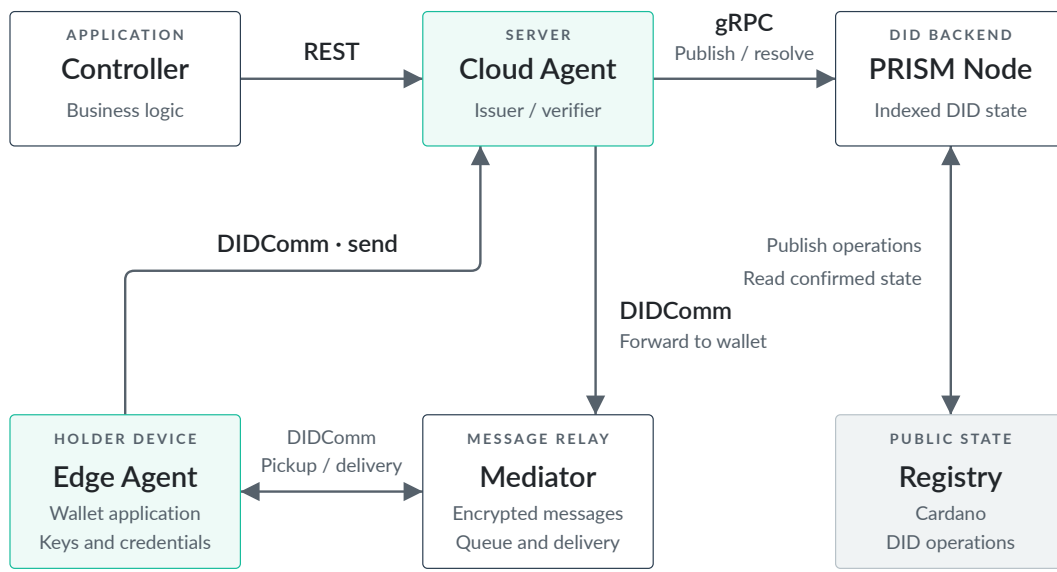
1. No private keys, seeds, bearer tokens, credentials, or personal profile attributes.
2. No service endpoint URL that embeds a username, customer identifier, account number, or other correlating value.
3. No reused verification method across relationships intended to stay unlinkable.
4. No descriptive `type` or custom property that reveals the subject's category without a protocol need.

DIDs stay focused on public verification and routing. Credentials and presentations carry claims. Agents and wallets handle disclosure to specific verifiers.

# Identus Concepts

## Identus components and communication paths

PRISM Node configuration with a mediated holder wallet



Arrows show requests and message delivery. Two-way paths include pickup or state retrieval.

Figure 1: The controller runs business logic through the Cloud Agent API. The wallet exchanges DIDComm messages with the Cloud Agent and retrieves incoming messages from the mediator. PRISM Node publishes DID operations and resolves DID state using the registry.

Identus is made up of several open source components. Each could be used or forked separately but they are designed to work well together.

## **PRISM Node**

PRISM Node implements the `did:prism` method and serves as a second-layer node for the Distributed Ledger, currently it only supports Cardano blockchain or local database but in the future it will be acting as a comprehensive interface to multiple VDR (Verifiable Data Registries). The node can resolve PRISM DID and write transactions to a blockchain or database, maintaining an indexed internal state that's synchronized with the underlying blockchain for efficient lookup operations.

As a critical component in the Identus ecosystem, PRISM Node provides a secure and trustworthy platform for storing and managing decentralized identifiers. It handles the creation, update, resolution, and deactivation of PRISM DIDs by generating transactions with the necessary operation information, verifying and validating these operations, and publishing them to the blockchain. Once transactions are confirmed, the node updates its internal state accordingly.

The PRISM Node's architecture enables users to:

- Create unpublished DIDs via Apollo building block with the option to announce them publicly later. This means that not all DIDs are required to be published on a VDR, for example, as a Holder you don't need your DID to be public, but as an Issuer, the Cloud Agent will require the issuing DID to be public and anchored in a VDR. In this case, PRISM Node will handle that operation for you.
- Update DID documents by publishing update operations on chain.
- Deactivate DIDs by publishing deactivation operations on chain.
- Resolving DIDs by querying historical changes on chain.
- Track the status of operations submitted to the node.

This second-layer approach is essential for making DIDs scalable and efficient, as it provides the necessary off-chain processing and data storage capabilities while leveraging the security and immutability of the underlying blockchain. PRISM Node is expected to be online at all times to ensure reliable service.

## **Cloud Agent**

Written in Scala, the Cloud Agent runs on a server and communicates with clients and peers via a REST API. It is a critical component of an Identus application, able to manage identity wallets and their associated operations, as well as issue Verifiable Credentials. The Cloud Agent is expected to be online at all times.

The Cloud Agent is designed to be scalable, robust, and standards-compliant, providing comprehensive self-sovereign identity services. It supports W3C standards, DIDCommV2, and Hyperledger Aries protocols, ensuring interoperability within the broader SSI ecosystem. Key capabilities include:

- Support for multiple agent roles including Issuer, Holder, Verifier
- Management of W3C Standard Verifiable Credentials (JSON and JSON-LD formats encoded as JWT), SD-JWT and AnonCreds
- Implementation of DIF Presentation Exchange for credential requests and submissions
- Support for `did:prism` and `did:peer` (version 2) DID methods

- Full implementation of DIDCommV2 messaging and protocols
- Compatibility with Hyperledger Aries RFCs including DID exchange, out-of-band protocol, issue credential, and present proof

The Cloud Agent's REST API enables developers to build controllers in any programming language without needing deep expertise in the underlying SSI standards. This architecture allows business logic to be separated from the identity infrastructure, making it easier to develop specialized applications while leveraging the full power of decentralized identity.

When deployed, the Cloud Agent interacts with the PRISM Node over gRPC protocol, using it as the Verifiable Data Registry to anchor DIDs on a distributed ledger for high security and availability.

## **Building Blocks**

Identus separates the handling of important SSI operations into separate, focused libraries called “building blocks”. These modular components can be combined and configured to meet various use cases and product requirements. This modular architecture provides excellent flexibility and customization options, allowing developers to implement decentralized identity solutions tailored to their specific needs.

### **Apollo - Cryptography**

Apollo is a comprehensive cryptographic primitives toolbox that Identus uses to ensure data integrity, authenticity, and confidentiality. It provides the foundation for secure communication and data protection throughout the Identus ecosystem.

Apollo employs cryptographic hash functions to create digital fingerprints of data, allowing the detection of any unauthorized modifications. For example, when a verifier receives a credential, Apollo's cryptographic functions can verify that the credential hasn't been tampered with since it was issued.

Additionally, Apollo implements digital signatures to authenticate the identity of senders and recipients, and uses encryption algorithms to protect sensitive data from unauthorized access. In a healthcare scenario, Apollo's encryption would ensure that patient credentials remain confidential when shared between authorized parties.

### **Castor - DID**

Castor enables the creation, management, and resolution of Decentralized Identifiers (DIDs). It currently supports the native `did:prism` method and the `did:peer` method but the are discussions aligning the team to build a more flexible architecture that would allow anyone to write plugins that could support other DID methods.

When a user creates a new digital identity in an Identus application, Castor generates the DID and associated cryptographic material. For instance, a university issuing student

credentials would use Castor to create and manage DIDs for both the institution and potentially for each student, establishing the foundation for trusted digital relationships.

Castor's resolver component can look up a DID and retrieve its associated DID Document, which contains the public keys, authentication mechanisms, and service endpoints needed for secure interactions with that identity.

### **Pollux - Verifiable Credential**

Pollux handles all Verifiable Credential operations, allowing users to issue, manage, and verify credentials in a privacy-preserving manner. This building block is essential for implementing the core functionality of credential exchange in self-sovereign identity systems.

In a real-world employment scenario, a company could use Pollux to issue employee credentials, which employees could then store in their digital wallets. When applying for a loan, an employee could selectively disclose relevant employment information from this credential without revealing unnecessary personal details. The bank could then use Pollux's verification capabilities to confirm the credential's authenticity and validity without contacting the employer directly.

Pollux also manages credential status, enabling issuers to revoke credentials when necessary and allowing verifiers to check if a credential is still valid before accepting it.

### **Mercury - DIDComm**

Mercury provides an interface to the DIDCommV2 protocol, enabling secure, private communication between DIDs regardless of the underlying transport mechanisms. This building block establishes the foundation for all agent-to-agent communications in the Identus ecosystem.

For example, when a citizen wants to share a government-issued credential with a service provider, Mercury facilitates the encrypted, authenticated message exchange between the citizen's wallet and the service provider's verification system. This communication happens peer-to-peer, without requiring centralized intermediaries to facilitate the exchange.

Mercury's transport-agnostic design means that these secure communications can occur over various channels, including HTTP, WebSockets, or Bluetooth, making it versatile for different deployment scenarios from web applications to mobile devices.

More detailed information on each of the Building Blocks can be found in the Identus Documentation.

## Edge Agent

Edge Agents bring agent capabilities to client applications such as websites, mobile apps, and other user-facing software. Unlike Cloud Agents, Edge Agents cannot be assumed to be online at all times, and therefore rely on sending and receiving all communications through an online proxy called a Mediator.

Edge Agents are implemented as SDKs that developers can integrate into their applications, providing a comprehensive suite of SSI functionality directly on the client side. These SDKs handle critical operations including:

- Creating and managing DIDs
- Storing and managing Verifiable Credentials
- Secure communication via DIDComm
- Cryptographic operations for signing and verification
- Local secure storage of identity data

Identus provides Edge Agent SDKs in multiple programming languages to support various platforms:

- **TypeScript SDK:** For web applications
- **Swift SDK:** For iOS applications
- **Kotlin Multiplatform SDK:** For Android applications and cross-platform development

Each SDK implements the same core building blocks (Apollo, Castor, Mercury, Pollux, and Pluto interfaces) as the Cloud Agent, ensuring consistent functionality and interoperability across the entire Identus ecosystem. This architectural consistency allows developers to create seamless experiences where identity operations can be performed either on the client or server side as appropriate for their use case.

Edge Agents typically function as digital wallets, enabling users to maintain control over their credentials and identity data on their personal devices. This approach aligns with the core principles of Self-Sovereign Identity by keeping the user in control of their data and minimizing dependency on centralized services.

## Mediator

Mediators act as middlemen between Peer DIDs. In order for any agent to send a message to any other agent, it must know the `to` and `from` DIDs of each message. The sender and recipient together make up a cryptographic connection called a `DIDPair`. Mediators maintain queues of messages for each `DIDPair`. If an Edge Agent is offline, the Mediator will hold incoming messages for them until the agent is back online and able to receive them. Mediators can deliver messages when polled, or push via web sockets. Mediators are expected to be online at all times and be highly available.

Identus officially supports and releases updates for their own Mediator implementation but there are a couple of alternative implementations close to the Identus community. In theory, any DIDCommV2 compatible mediator should work with Identus so this is not an exhaustive list.

- PRISM Mediator
- RootsID Mediator
- Blocktrust Mediator

Both RootsID and Blocktrust provide hosted instances of their mediators that are publicly accessible. While extremely helpful during development, these are not recommended for production Identus deployments as they have no uptime guarantee and will not scale past a small number of concurrent users. We will discuss how to run your own Mediator in Chapter .

## Verifiable Data Registry (VDR)

The Verifiable Data Registry (VDR) addresses the critical challenge of ensuring authenticity and integrity for publicly available data in an environment where data is generated and consumed at unprecedented scales. Traditional systems often rely on centralized authorities, introducing single points of failure and undermining trust, especially when multiple independent parties need to rely on the same data.

Key challenges include enabling decentralized verification, guaranteeing data integrity and authenticity without central oversight, ensuring interoperability across diverse storage technologies (databases, blockchains, in-memory caches), and facilitating scalable, trustless collaboration.

The VDR system tackles these issues by providing a unified API and a modular, extensible framework for storing, mutating, retrieving, and removing data. It decouples the application layer from the underlying storage mechanisms through two main pluggable components:

- **Drivers:** These are plugins that implement the actual data storage and retrieval logic. Each driver is tailored to a specific storage backend (e.g., a database, a blockchain, or in-memory storage). Drivers are responsible for executing operations like creating, reading, updating, and deleting data. They also handle the generation and verification of cryptographic proofs (hashes for immutable data, digital signatures for mutable data) to ensure data integrity.
- **URL Managers:** These components construct and resolve URLs that reference the stored data. They embed necessary metadata (like driver identifiers, driver families, and cryptographic proofs) into these URLs using standard query parameters. This allows the VDR system to select the correct driver and verify data integrity when a URL is presented.

By abstracting these operations, the VDR layer ensures consistent and verifiable data operations regardless of where or how the data is stored. It employs cryptographic hashes for immutable data and digital signatures for mutable data, embedded in URLs or retrievable

## *Identus Concepts*

via the driver—to guarantee integrity. This architecture fosters a trustless environment where multiple parties can independently verify data authenticity and integrity, enhancing security and collaboration. The VDR system’s design allows for adaptability to various storage backends while maintaining consistent methods for data verification and access.

## **Section II - Getting Started**

# Installation - Local Environment

## Overview

Hyperledger Indentus maintains component code across separate repositories. The Cloud Agent repository contains the server-side agent used in this chapter. A controller application sends HTTP requests to the Cloud Agent REST API. The Cloud Agent manages DIDs, DIDComm V2 messages, credential issuance, credential verification, credential storage, and tenant configuration. The official Cloud Agent README describes it as a server-side W3C/Aries cloud agent. Holder wallet applications use the Edge Agent SDKs.

The local setup runs the Cloud Agent in a development configuration. Docker starts the Cloud Agent with its supporting services, including PostgreSQL, HashiCorp Vault, APISIX, and a PRISM Node. The official Quick Start describes this setup as single-tenant, with API key authentication disabled and an in-memory ledger for published DID storage.

This chapter starts two local Cloud Agent instances:

- **issuer** on port 8000, used to create issuer DIDs, schemas, and credential offers.
- **verifier** on port 9000, used later for proof request flows.

For the REST API chapter, you can run only the issuer instance. The verifier becomes useful when the book reaches connections, issuance, and verification flows.

## Version Selection

Use the platform release notes before changing component versions. The current platform release page lists Indentus Platform **v2.16** as the latest platform release and includes Cloud Agent 2.1.0, Mediator 1.2.0, NeoPRISM 0.6.2, and SDK-TS 7.0.0. The Quick Start pins the local issuer/verifier tutorial to Cloud Agent 2.0.0 and PRISM Node 2.6.0.

This chapter follows the Quick Start version pair. Treat **AGENT\_VERSION** and **PRISM\_NODE\_VERSION** as a tested pair. If you change one value, check the component release notes and rerun the health checks at the end of this chapter.

## Prerequisites

Install Git, Docker, and Docker Compose before running the local Cloud Agent stack. Docker Desktop includes the Docker CLI and Compose plugin on macOS and Windows. Linux users can use Docker Engine with the Compose plugin.

```
git --version
docker --version
docker compose version
```

Each command should print a version. If one command fails, install or repair that tool before starting the Cloud Agent.

On Windows, use WSL 2 and run the Linux commands inside the WSL distribution. The Microsoft WSL guide shows how to install a distribution, list installed distributions, and confirm whether a distribution uses WSL 1 or WSL 2.

## Clone the Cloud Agent Repository

Clone the current Cloud Agent repository and keep the local directory name used by the official Quick Start:

```
git clone https://github.com/hyperledger-identus/cloud-agent identus-cloud-agent
cd identus-cloud-agent
```

Older Identus material may use <https://github.com/hyperledger/identus-cloud-agent>. Identus Platform v2.15 records the repository move to [hyperledger-identus/cloud-agent](https://github.com/hyperledger-identus/cloud-agent).

## Configure Local Agent Instances

The `infrastructure/local` directory contains the scripts and environment files for local runs. The local README states that the scripts pull remote images, `.env` controls image versions, `run.sh` starts named instances, and `stop.sh` stops named instances.

Create the issuer configuration:

```
cat > ./infrastructure/local/.env-issuer <<'EOF'
API_KEY_ENABLED=false
AGENT_VERSION=2.0.0
PRISM_NODE_VERSION=2.6.0
PORT=8000
NETWORK=identus
```

```
VAULT_DEV_ROOT_TOKEN_ID=root
PG_PORT=5432
EOF
```

Create the verifier configuration:

```
cat > ./infrastructure/local/.env-verifier <<'EOF'
API_KEY_ENABLED=false
AGENT_VERSION=2.0.0
PRISM_NODE_VERSION=2.6.0
PORT=9000
NETWORK=identus
VAULT_DEV_ROOT_TOKEN_ID=root
PG_PORT=5433
EOF
```

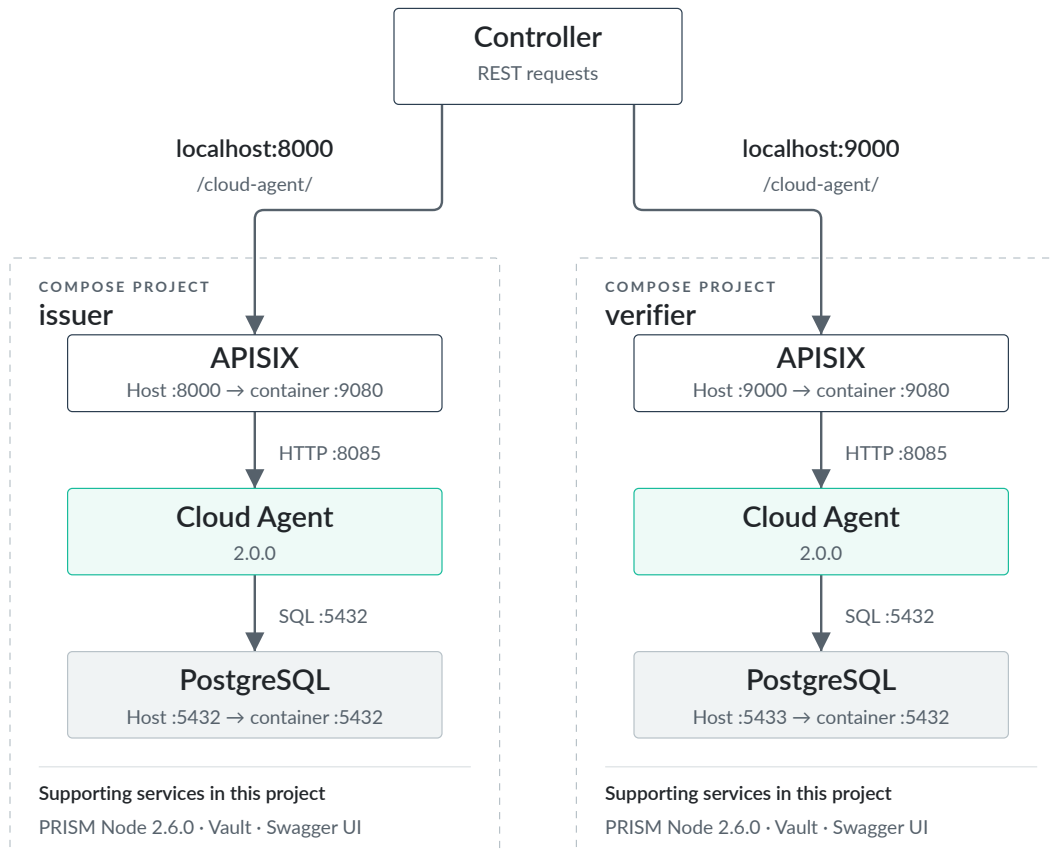
 **Warning**

`API_KEY_ENABLED=false` disables API key authentication. Use this setting for local development only.

The `PORT` values expose the two REST APIs on different host ports. The `PG_PORT` values prevent the two PostgreSQL containers from binding to the same host port. The `NETWORK=identus` value is retained from the official Quick Start configuration; the current local Compose file creates the runtime network from the named Compose project.

## Two local Cloud Agent instances

Separate Compose projects on one development machine



Host ports differ; container ports can repeat inside separate Compose networks.

Figure 1: The controller selects an instance through its host API port. Each Compose project starts its own agent, database, and supporting services. PostgreSQL exposes its host port on the loopback interface; the agent uses the database's internal port.

Current Hyperledger Indentus releases publish the Cloud Agent image on Docker Hub as [docker.io/hyperledgerindentus/indentus-cloud-agent](https://hub.docker.com/r/hyperledgerindentus/indentus-cloud-agent). The older local README mentions `GITHUB_TOKEN` and `ghcr.io`; that note predates the Docker registry move recorded in Indentus Platform v2.15.

## Start the Issuer Cloud Agent

Run the issuer from the repository root. Use the command for your operating system.

macOS:

```
./infrastructure/local/run.sh -n issuer -b -w -e ./infrastructure/local/.env-issuer -p 8000
```

Linux:

```
./infrastructure/local/run.sh -n issuer -b -w -e ./infrastructure/local/.env-issuer -p 8000
```

The first run downloads container images and creates Docker volumes. Wait for Docker to report healthy containers, then check the issuer health endpoint:

```
curl http://localhost:8000/cloud-agent/_system/health
```

The response should include the configured Cloud Agent version:

```
{"version":"2.0.0"}
```

The Cloud Agent serves the issuer REST API at <http://localhost:8000/cloud-agent/>. Swagger UI is available at <http://localhost:8000/apidocs/>, and the OpenAPI document is available at <http://localhost:8000/docs/cloud-agent/api/docs.yaml>.

## Start the Verifier Cloud Agent

Start the verifier when you need a second Cloud Agent actor for proof request and verification flows.

macOS:

```
./infrastructure/local/run.sh -n verifier -b -w -e ./infrastructure/local/.env-verifier -p 9000
```

Linux:

```
./infrastructure/local/run.sh -n verifier -b -w -e ./infrastructure/local/.env-verifier -p 9000
```

Check the verifier health endpoint:

```
curl http://localhost:9000/cloud-agent/_system/health
```

Expected response:

```
{"version":"2.0.0"}
```

The Cloud Agent serves the verifier REST API at <http://localhost:9000/cloud-agent/>. Swagger UI is available at <http://localhost:9000/apidocs/>, and the OpenAPI document is available at <http://localhost:9000/docs/cloud-agent/api/docs.yaml>.

## Stop Local Instances

Stop each named instance with the same `-n` value used at startup:

```
./infrastructure/local/stop.sh -n issuer  
./infrastructure/local/stop.sh -n verifier
```

To remove the local Docker volumes for an instance, add `-d`:

```
./infrastructure/local/stop.sh -n issuer -d  
./infrastructure/local/stop.sh -n verifier -d
```

Use `-d` when you want a clean local state. Omit it when you want to keep local wallets, DIDs, schemas, credential records, and other development data across restarts.

## Local SSI Model

Each Cloud Agent instance acts as one SSI actor in this local setup. The issuer controls issuer DIDs and signs credentials. The verifier creates proof requests and verifies presentations. A holder wallet enters the flow later through an Edge Agent SDK or wallet application.

The local PRISM Node gives the Cloud Agent a development VDR target for `did:prism` operations. The in-memory ledger keeps the setup fast and disposable. Production deployments use different configuration for persistence, tenant isolation, API authentication, secrets, and Cardano network access.

# Agent REST API

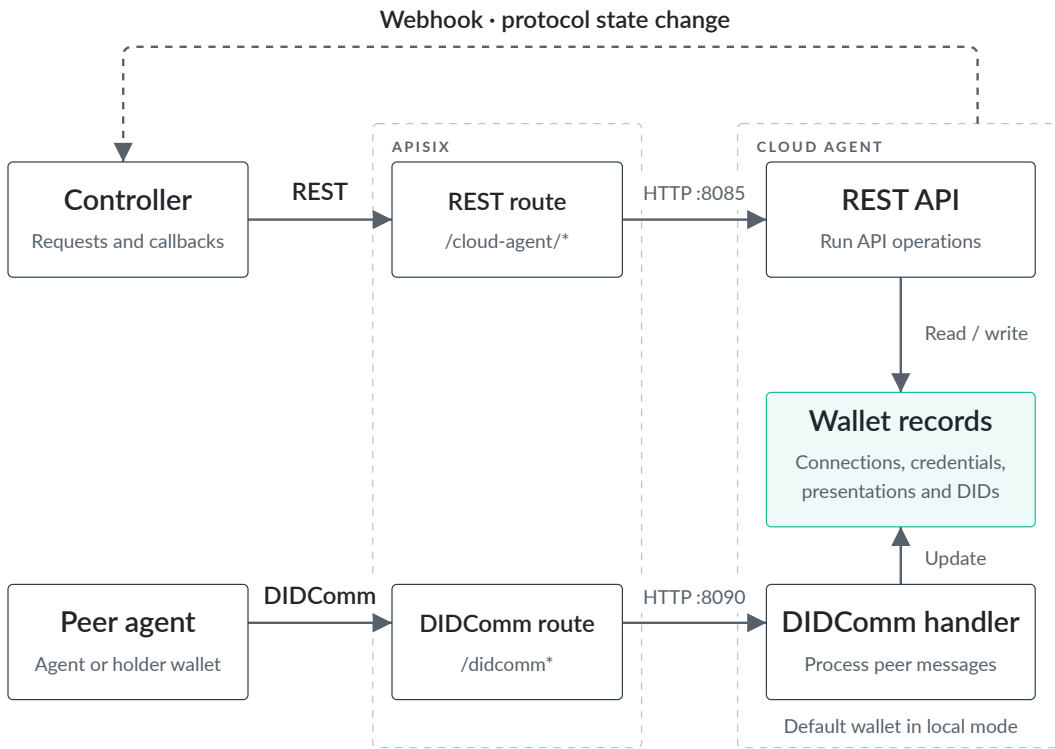
## The Cloud Agent API

The local Cloud Agent exposes two public protocol surfaces through APISIX. Your controller application uses the REST API to create DIDs, register credential schemas, issue Verifiable Credentials, manage connection records, request presentations, and inspect protocol state. Other agents and wallets use the DIDComm endpoint to deliver encrypted agent messages.

Those two surfaces share the same wallet state. A REST request changes or reads records in the Cloud Agent wallet. A DIDComm message may change the same records after the Cloud Agent processes an inbound connection, issuance, or presentation message. The Cloud Agent README describes this pattern as a controller that sends HTTP requests to the agent and processes webhook notifications from it.

## REST and DIDComm share wallet state

Two inbound routes and a configured notification path



Solid arrows show requests and record access. The dashed arrow shows an asynchronous notification.

Figure 1: A controller API action can continue through later DIDComm messages that change the same protocol record. The Cloud Agent sends state-change events to the controller's configured webhook endpoint.

The local stack from the previous chapter runs in single-tenant mode. In that mode, the Cloud Agent uses the default entity and the default wallet for REST API and DIDComm operations. The Cloud Agent authentication documentation defines both IDs as 00000000-0000-0000-0000-000000000000.

You can confirm that default wallet initialization in the container logs:

```
docker logs local-cloud-agent-1 | grep "default"

... Initializing default wallet.
... Default wallet seed is not provided. New seed will be generated.
... Entity created: Entity(00000000-0000-0000-0000-000000000000,default,00000000-0000-0000-
```

Later, the example application will use multi-tenant mode. In multi-tenant mode, the Cloud Agent serves multiple tenants from one shared Cloud Agent instance. The multi-tenancy documentation defines an entity as the tenant representation and a wallet as the isolated container for that tenant's DIDs, connections, credentials, keys, credential schemas, and related assets. A service-managed wallet fits a server-side issuer, verifier, or custodial wallet service where the operator manages the runtime, database, secret storage, API access, and backups.

The `_system/health` endpoint from the previous chapter reports the running service version. The system API exposes one more endpoint for runtime metrics:

```
curl http://localhost/cloud-agent/_system/metrics
# HELP jvm_memory_bytes_used
# TYPE jvm_memory_bytes_used gauge
jvm_memory_bytes_used{area="heap",} 1.07522616E8
jvm_memory_bytes_used{area="nonheap",} 1.74044936E8
...
```

The Cloud Agent OpenAPI specification describes the metrics endpoint as Prometheus text output from the internal metrics registry. Use it when you need local runtime data for memory, latency, or health investigations.

## OpenAPI Specification

The OpenAPI Specification (OAS) is a standard description format for HTTP APIs. It gives humans and tools a shared contract for paths, request bodies, response bodies, authentication schemes, and schemas. The Cloud Agent source repository includes an OpenAPI 3.1 document titled *Identus Cloud Agent API Reference*, and the local Docker stack exposes that document through APISIX.

For the local agent started in the previous chapter, use this URL as the version-matched API contract:

```
http://localhost/docs/cloud-agent/api/docs.yaml
```

If you started the agent with a different `run.sh --port` value, replace `localhost` with `localhost:<port>`. Swagger UI reads this same document. Postman and client generators can import it to create a collection or client stub for the exact Cloud Agent version you are running.

The hosted Identus docs provide current tutorials and conceptual material at <https://hyperledger-identus.github.io/docs/>. For endpoint-level work in this local stack, prefer the OpenAPI document served by your running agent. It avoids mismatches between the book, a hosted page, and the Docker image version.

## APISIX Gateway

APISIX proxies the Cloud Agent services inside the local Docker stack. The `run.sh` script binds APISIX to the port you selected, with 80 as the default. The Cloud Agent's shared APISIX configuration defines these routes:

| Local route                                                  | Upstream service              | Purpose                                               |
|--------------------------------------------------------------|-------------------------------|-------------------------------------------------------|
| <code>http://localhost/cloud-agent/</code>                   | <code>cloud-agent:8085</code> | REST API for controller applications.                 |
| <code>http://localhost/docs/cloud-agent/api/docs.yaml</code> | <code>cloud-agent:8085</code> | OpenAPI document for the running Cloud Agent.         |
| <code>http://localhost/apidocs/</code>                       | <code>swagger-ui:8080</code>  | Swagger UI for interactive API calls.                 |
| <code>http://localhost/didcomm/</code>                       | <code>cloud-agent:8090</code> | Public DIDComm endpoint for encrypted agent messages. |

The DIDComm endpoint is the transport endpoint advertised in invitations and DID documents. A peer uses it to send encrypted DIDComm messages to this Cloud Agent. The DIDComm chapter covers the message model and protocol flow later in the book.

APISIX routes match incoming requests, apply route plugins, and forward requests to upstream services. The Cloud Agent local configuration uses `proxy-rewrite` to strip the public route prefix before forwarding the request, and it enables the APISIX `cors` plugin on the REST and DIDComm routes.

### Warning

The local APISIX CORS configuration allows all origins on the `/cloud-agent/*` and `/didcomm*` routes. That setting is convenient for local browser testing. A deployed service should restrict allowed origins to the domains that host the controller application, admin tools, or wallet front ends that need browser access.

## Swagger UI

Swagger UI renders API documentation and an interactive request form from an OpenAPI document. The local Docker stack includes a Swagger UI container, and APISIX exposes it at `http://localhost/apidocs/`.

Open `http://localhost/apidocs/` in your browser. In the server list, select:

- `http://localhost/cloud-agent` - The local instance of the Cloud Agent behind the APISIX proxy.

Click **Authorize**. Swagger UI opens a modal for the **apikey** header. The local stack has API key authentication disabled by default, so the Cloud Agent will accept the request even if Swagger UI sends any value. Use **test** for now. In later chapters, after the book enables API key authentication, this field must contain the API key assigned to the default entity or tenant entity.

After authorizing, the modal should look like this:

## Available authorizations ✕

### apiKeyAuth (apiKey)

**Authorized**

API Key Authentication. The header **apikey** must be set with the API key.

Name: apikey

In: header

Value: **\*\*\*\*\***

LogoutClose

### adminApiKeyAuth (apiKey)

Admin API Key Authentication. The header **x-admin-api-key** must be set with the Admin API key.

Name: x-admin-api-key

In: header

Value:

AuthorizeClose

Figure 2: Swagger UI Apikey Modal

Close the modal and try the first request. Expand **GET /connections** and click **Try it out**. Leave **offset**, **limit**, and **thid** blank. Click **Execute** to send the request.

The response should look similar to this:

```
{ "contents": [], "kind": "ConnectionsPage", "self": "", "pageOf": "" }
```

An empty `contents` array means the default wallet has no connection records yet. That is the expected result for a new local agent.

**i** Note

Swagger UI can generate a `curl` command for the request it sends. You can paste that command in your terminal to run the same API call outside the browser. For example:

```
curl -X 'GET' \
  'http://localhost/cloud-agent/connections' \
  -H 'accept: application/json' \
  -H 'apikey: test'
{"contents": [], "kind": "ConnectionsPage", "self": "", "pageOf": ""}
```

## Postman

Swagger UI is useful for quick checks against the running agent. Postman is better when you need saved environments, request variables, scripted assertions, shared collections, or repeated manual testing across issuer, holder, and verifier agents.

Postman can import OpenAPI definitions from a file, a URL, pasted YAML or JSON, or a repository. Use the local Cloud Agent OpenAPI URL so the collection matches your running Docker image.

1. Install Postman if you do not already have it.
2. Copy the local OpenAPI URL: `http://localhost/docs/cloud-agent/api/docs.yaml`. If you changed the `run.sh --port` value, include that port in the URL.
3. In Postman, go to **File** -> **Import**.
4. Paste the OpenAPI URL in the import box, or download the YAML from that URL and import the file.
5. Import the definition as a collection.

After import, Postman should show a collection named **Identus Cloud Agent API Reference**. Set any collection base URL or server variable to `http://localhost/cloud-agent` if Postman does not select that server for you.

## Tutorials

The official Identus tutorials cover the main API flows: connections, DID management, credential schemas, credential issuance, presentation requests, webhooks, multi-tenancy, and VDR interaction. Use those tutorials as the endpoint reference for the next chapters. This book will connect those API operations to the example application, the wallet model, DIDComm flows, and verifier policy checks.

# Mediator

## Overview

The Hyperledger Indentus Mediator is a DIDComm V2 routing service. It gives mobile wallets, browser wallets, and other agents with changing connectivity a stable endpoint where other agents can send encrypted DIDComm messages.

In a mediated DIDComm flow, the holder wallet first establishes mediation with the mediator. The mediator returns routing information. The holder wallet then advertises that routing information in later DIDComm service entries and connection records. An issuer or verifier sending a DIDComm message to that holder encrypts the message for the holder, wraps it in a DIDComm **forward** message for the mediator, and sends the wrapped message to the mediator endpoint. The mediator can decrypt the outer routing envelope, but it cannot read the holder's encrypted message body.

The mediator stores pending holder messages in MongoDB. The holder wallet later uses DIDComm Message Pickup to check queue status, request delivery, and confirm received messages. This model lets an issuer or verifier send messages when the holder wallet is offline, without exposing the holder's device address to every connection.

The mediator is not a Verifiable Data Registry and does not publish DIDs. It handles DIDComm transport and storage. PRISM Node handles ledger-backed `did:prism` operations. Cloud Agent and Edge Agent SDKs use the mediator when their DIDComm counterparty needs a stable relay endpoint.

## Protocol surface

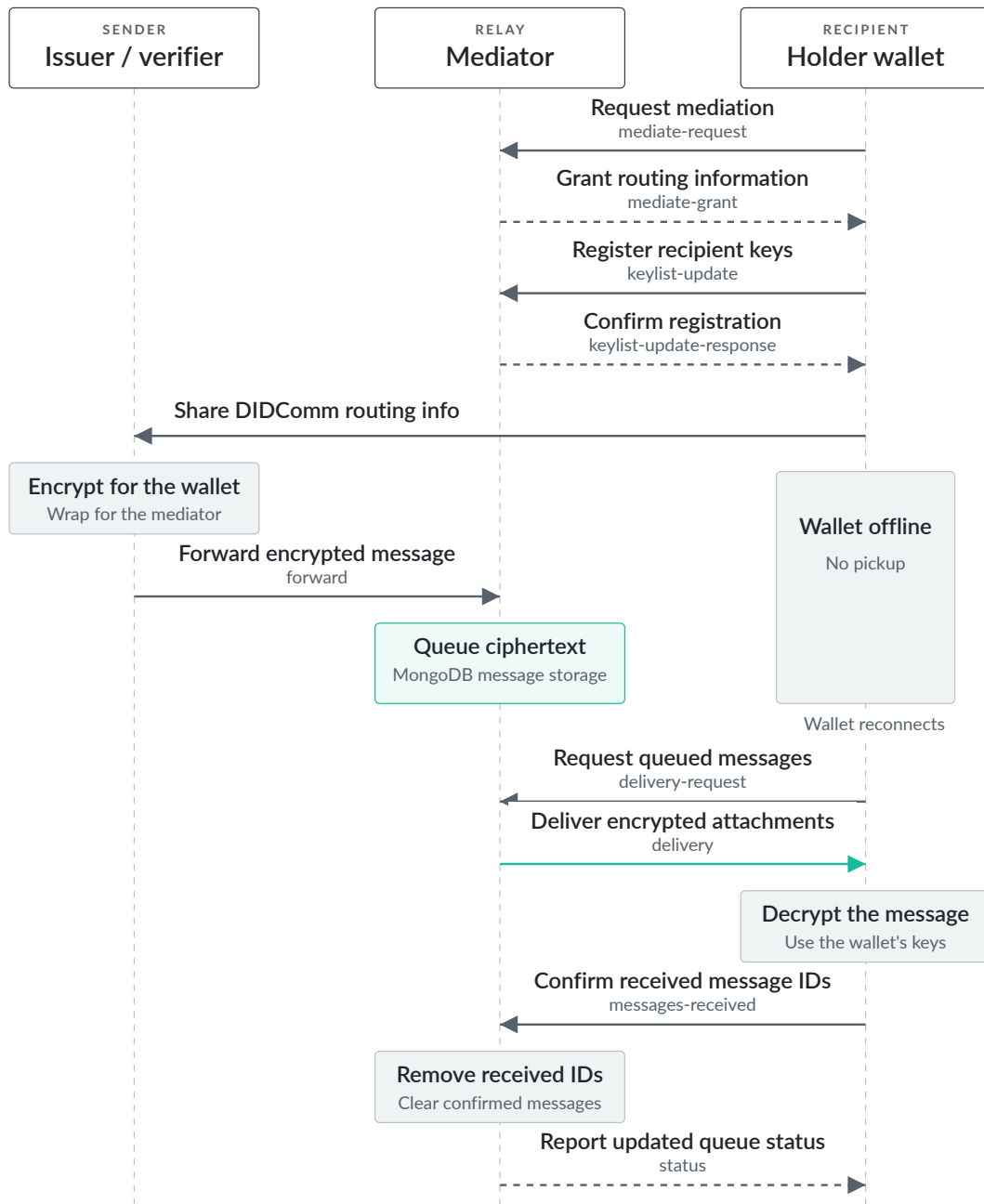
The current Mediator repository documents support for these DIDComm protocols:

- <https://didcomm.org/routing/2.0>
- <https://didcomm.org/coordinate-mediation/2.0>
- <https://didcomm.org/messagepickup/3.0>
- <https://didcomm.org/trust-ping/2.0>
- <https://didcomm.org/report-problem/2.0>
- <https://didcomm.org/basicmessage/2.0>

For setup, the important protocols are Coordinate Mediation, Routing, and Message Pickup. Coordinate Mediation lets a recipient wallet request mediation and register recipient keys. Routing defines the **forward** message used to send traffic through the mediator. Message Pickup lets the recipient wallet retrieve queued messages.

## Mediation setup and offline delivery

Coordinate Mediation 2.0 · Routing 2.0 · Message Pickup 3.0



Successful pickup path. The mediator reads routing information; the wallet decrypts the payload.

Figure 1: The mediator retains queued messages until the wallet confirms their message IDs. Pickup requests use `return_route`: all so the mediator can reply over the wallet's connection. The diagram shows delivery after an offline interval.

## Version selection

Check both release streams before pinning a mediator image. The current Identus Platform v2.16 release lists Mediator 1.2.0. The standalone Mediator repository lists v1.2.1 as the latest stable Mediator release.

This chapter uses `MEDIATOR_VERSION=1.2.1` for the standalone mediator setup. If you are reproducing the full Identus Platform v2.16 component set, use `MEDIATOR_VERSION=1.2.0` instead.

## Prerequisites

Install Git, Docker, and Docker Compose before running the mediator stack.

```
git --version
docker --version
docker compose version
```

Each command should print a version. If one command fails, install or repair that tool before starting the mediator.

## Clone the mediator repository

Clone the current repository:

```
git clone https://github.com/hyperledger-identus/mediator identus-mediator
cd identus-mediator
```

Older Identus material may use `https://github.com/hyperledger/identus-mediator`. Current Identus repositories live under the `hyperledger-identus` GitHub organization.

## Local configuration files

The official repository already includes `docker-compose.yml` and `initdb.js`. You do not need to create either file when you run from the cloned repository. Read both files before changing the mediator deployment. Those files define the image, database, identity keys, public DIDComm endpoints, and health check.

The current local Compose file has this shape:

```

services:
  mongo:
    image: mongo:6.0
    ports:
      - "27017:27017"
    command: ["--auth"]
    environment:
      - MONGO_INITDB_ROOT_USERNAME=admin
      - MONGO_INITDB_ROOT_PASSWORD=admin
      - MONGO_INITDB_DATABASE=mediator
    volumes:
      - ./initdb.js:/docker-entrypoint-initdb.d/initdb.js

  identus-mediator:
    image: docker.io/hyperledgeridentus/identus-mediator:${MEDIATOR_VERSION:-latest}
    ports:
      - "8080:8080"
    environment:
      - KEY_AGREEMENT_D=Z6D8LduZgZ6Lnr0HPrMTS6uU2u5Btsrk1SGs4fn8M7c
      - KEY_AGREEMENT_X=Sr4SkIskjN_VdKTn0zkjYbhGTWardUNE4j_DmUpnQGw
      - KEY_AUTHENTICATION_D=INXCnxFE10atLIIQYruHzGd5sUivMRyQ0zu87qVerug
      - KEY_AUTHENTICATION_X=MBjnXZxkMcoQVVL21hahWAw43RuAG-i64ipbeKKqwoA
      - SERVICE_ENDPOINTS=${SERVICE_ENDPOINTS:-http://localhost:8080;ws://localhost:8080/ws}
      - MONGODB_USER=admin
      - MONGODB_PASSWORD=admin
      - MONGODB_PROTOCOL=mongodb
      - MONGODB_HOST=mongo
      - MONGODB_PORT=27017
      - MONGODB_DB_NAME=mediator
    depends_on:
      - mongo
    healthcheck:
      test: curl --fail http://localhost:8080/health || exit 1
      interval: 30s
      timeout: 8s
      retries: 3
    extra_hosts:
      - "host.docker.internal:host-gateway"

```

The `mongo` service stores mediation accounts and queued messages. The local file exposes MongoDB on host port 27017 for debugging. Wallets and Cloud Agents do not need that host port. Production deployments should keep MongoDB private to the deployment network.

The `identus-mediator` service runs the mediator image from Docker Hub. `MEDIATOR_VERSION` selects the image tag. The `ports` mapping exposes the mediator HTTP and WebSocket

## Mediator

service on host port 8080. The mediator uses `SERVICE_ENDPOINTS` when it builds its Peer DID and out-of-band invitation, so this value must name an endpoint that the holder wallet can reach.

The demo key values in the local Compose file create a stable mediator identity for local development. Do not reuse those keys for a shared or production mediator. Generate a new X25519 key pair for key agreement and a new Ed25519 key pair for authentication, then provide the four JWK fields through deployment configuration.

The Mongo initialization file creates the database user, collections, indexes, and TTL rule:

```
db.createUser({
  user: "admin",
  pwd: "admin",
  roles: [
    { role: "readWrite", db: "mediator" }
  ]
});

const database = 'mediator';
const collectionDidAccount = 'user.account';
const collectionMessages = 'messages';
const collectionMessagesSend = 'messages.outbound';

use(database);

db.createCollection(collectionDidAccount);
db.createCollection(collectionMessages);
db.createCollection(collectionMessagesSend);

db.getCollection(collectionDidAccount).createIndex({ 'did': 1 }, { unique: true });
db.getCollection(collectionDidAccount).createIndex({ 'alias': 1 }, { unique: true, partialF
db.getCollection(collectionDidAccount).createIndex({ "messagesRef.hash": 1, "messagesRef.re

const expireAfterSeconds = 7 * 24 * 60 * 60;
db.getCollection(collectionMessages).createIndex(
  { ts: 1 },
  {
    name: "message-ttl-index",
    partialFilterExpression: { "message_type" : "Mediator" },
    expireAfterSeconds: expireAfterSeconds
  }
)
```

`user.account` stores mediation account records keyed by DID. `messages` stores mediator protocol messages and queued user payload references. `messages.outbound` stores outbound

message records. The TTL index matches records whose `message_type` is `Mediator`; queued user messages stay until the recipient retrieves them and confirms receipt.

A local `.env` file can pin the mediator image and public endpoints:

```
MEDIATOR_VERSION=1.2.1
SERVICE_ENDPOINTS=http://localhost:8080;ws://localhost:8080/ws
```

Use a LAN IP address or public domain in `SERVICE_ENDPOINTS` when a mobile wallet must connect from outside the host machine. Keep the URL scheme and port aligned with the endpoint you expose through Docker, a reverse proxy, or a load balancer.

## Start the mediator

The repository includes the local `docker-compose.yml`. It starts two services:

- `mongo`, the MongoDB database used for accounts and queued messages.
- `identus-mediator`, the JVM mediator service exposed on port 8080.

The current Compose file maps host port 8080 to the mediator container. Check that no other local service uses that port before startup:

```
docker ps --format '{{.Names}} {{.Ports}}' | grep 8080
```

If the command prints another container using 8080, stop that service or adapt the Compose port mapping before starting the mediator. Keep the exposed host port and `SERVICE_ENDPOINTS` in agreement, since wallets read `SERVICE_ENDPOINTS` from the mediator's DIDComm invitation.

Run the command for your operating system from the repository root.

macOS:

```
MEDIATOR_VERSION=1.2.1 SERVICE_ENDPOINTS="http://$(ipconfig getifaddr $(route get default |
```

Linux:

```
MEDIATOR_VERSION=1.2.1 SERVICE_ENDPOINTS="http://$(ip addr show $(ip route show default | a
```

The `SERVICE_ENDPOINTS` value becomes part of the mediator's Peer DID service entries and out-of-band invitation. Use an address that the wallet can reach. A browser wallet running on the same host can use `localhost`; a mobile wallet on the same network needs the host machine's LAN IP address or a public domain. For production deployments, use HTTPS and WSS endpoints.

## Check the running mediator

Check the containers:

```
docker compose ps
```

The mediator service defines a Docker health check against `/health`. After startup, Docker should report `identus-mediator` as healthy.

Check the health endpoint:

```
curl -i http://localhost:8080/health
```

Expected result:

```
HTTP/1.1 200 OK
```

Check the running mediator version:

```
curl http://localhost:8080/version
```

Expected result:

```
1.2.1
```

Fetch the mediator Peer DID:

```
curl http://localhost:8080/did
```

The response should start with `did:peer:..`. Holder wallet software uses this DID as the mediator DID when it starts mediation.

Fetch the mediation invitation:

```
curl http://localhost:8080/invitation
```

The response is a DIDComm out-of-band invitation. Its `from` field is the mediator Peer DID. Its body should include `goal_code` set to `request-mediate` and `accept` containing `didcomm/v2`.

To get the URL-encoded invitation used for QR-code flows, call:

```
curl http://localhost:8080/invitation00B
```

The response should contain an `_oob=` parameter.

## Configuration notes

The local Compose file includes demo identity keys. Do not use them outside local development. A production mediator needs its own X25519 key agreement key and Ed25519 authentication key. The Mediator repository includes a key generation guide for `KEY_AGREEMENT_D`, `KEY_AGREEMENT_X`, `KEY_AUTHENTICATION_D`, and `KEY_AUTHENTICATION_X` values in JWK-compatible form.

MongoDB can be configured with individual variables:

```
MONGODB_PROTOCOL
MONGODB_HOST
MONGODB_PORT
MONGODB_USER
MONGODB_PASSWORD
MONGODB_DB_NAME
```

Mediator 1.2.0 added `MONGODB_CONNECTION_STRING`. If present, this full connection string takes precedence over the individual MongoDB variables.

The mediator stores two message categories. **Mediator** messages cover mediation setup, keylist operations, pickup requests, and other mediator protocol traffic. These records can expire through the TTL index configured in `initdb.js`. **User** messages are encrypted payloads waiting for holder pickup. The mediator keeps them until the recipient retrieves them and confirms receipt through Message Pickup.

## Stop the mediator

Stop the stack without deleting the database volume:

```
docker compose down
```

Remove the containers and local MongoDB data:

```
docker compose down -v
```

Use `-v` when you want a clean local mediator state. Omit it when you want to keep registered mediation accounts and queued development messages across restarts.

## **Section III - Building**

# Example Project

## Overview - Airline Ticket Wallet

One of the best ways to learn and understand a software platform is to build something with it. We have written an open source, example Identus application, in TypeScript, Swift, and Kotlin, to illustrate how to create real-world solutions.

**Flight Tix**, shows how to issue Verifiable Credentials that represent users and objects, and how to present proof and verify those credentials.

**Flight Tix** is available for each Identus Edge SDK, please see each example's repository for more detail:

- TypeScript: <https://github.com/identusbook/example-ts>
- Swift: <https://github.com/identusbook/example-ios>
- Kotlin: <https://github.com/identusbook/example-android>

# Wallets

## Overview

An SSI wallet is software that stores and protects the material a holder, issuer, or verifier needs to act in an identity protocol. In the W3C Verifiable Credentials Data Model 2.0, a credential repository stores and protects access to a holder's credentials. In W3C DID Core, a DID resolves to a DID document that can expose public verification methods and service endpoints. The private keys, credentials, DIDComm records, and local wallet state live in wallet storage, not in the DID document.

Identus uses the word wallet in two common places:

- An Edge Agent wallet runs inside a holder-facing application, such as a browser app, mobile app, or desktop app. The application embeds an Identus Edge SDK and provides storage through Pluto.
- A Cloud Agent wallet is a server-side wallet container accessed through the Cloud Agent REST API. A controller or tenant uses API calls and webhooks rather than direct in-process SDK calls.

Do not treat a ledger, PRISM Node, or DID resolver as a wallet backup. Public DID state can help other parties resolve issuer keys and service endpoints. It cannot reconstruct holder-held credentials, Peer DID private keys, DIDComm message history, connection records, or presentation state. A production wallet needs an explicit storage, encryption, backup, and recovery design.

For the airline ticket example in this section, the airline runs Cloud Agent as an issuer. The traveler uses an Edge Agent wallet as the holder. Airport security can use Cloud Agent, an Edge SDK, or another verifier implementation, depending on the deployment.

## Wallet Responsibilities

A wallet has more work to do than storing credentials. It owns the local state needed to continue protocol flows across app restarts, device changes, and network interruptions.

The wallet stores or references:

- DID records and DID metadata.
- Private keys, wallet seeds, or secret references used by DID operations.
- Verifiable Credentials received from issuers.
- Presentation records created for verifiers.

- DIDComm messages, connection records, and protocol state.
- Mediator configuration for offline delivery.
- Credential status and schema references needed by later verification flows.

The wallet uses that state to perform protocol work. The holder wallet receives credential offers, asks the holder for consent, stores issued credentials, creates presentations, and sends DIDComm responses. The issuer wallet signs credentials and tracks issuance records. The verifier wallet or verifier agent receives presentations, checks cryptographic proofs, resolves issuer material, checks credential status, and then applies verifier policy.

Keep the verification layers separate. A cryptographic check answers whether the presentation, credential proof, issuer key, holder binding, and status data verify. A policy check answers whether the verifier accepts that issuer, credential type, schema, subject, freshness, or assurance level for the business action.

## Edge Agent Wallets

Indutus Edge Agent SDKs let an application run wallet and agent capabilities close to the holder. Current Indutus repositories provide:

- TypeScript SDK for browser and Node.js applications. The current TypeScript SDK docs name the package `@hyperledger/identus-sdk` and note the rename from `@hyperledger/identus-edge-agent-sdk`.
- Swift SDK for Apple platforms.
- Kotlin Multiplatform SDK for Android and JVM applications.

The SDKs use the same architectural vocabulary:

- Apollo provides cryptographic operations.
- Castor creates, manages, and resolves DIDs.
- Pollux handles credential operations in the Swift and Kotlin SDKs. The current TypeScript SDK exposes credential capabilities through its modules and plugins.
- Mercury handles DIDComm v2 messages and related secure messaging work.
- Pluto provides the storage interface.
- Agent or EdgeAgent composes the building blocks into a higher-level agent API.

Start with Agent or EdgeAgent for application code. Direct calls into Apollo, Castor, Mercury, Pollux, or Pluto fit cases where the application needs a lower-level operation that the agent API does not expose. For example, a wallet that implements a custom DIDComm protocol can build and pack messages through Mercury, then store the resulting protocol records through the same wallet storage layer.

## Pluto Storage

Pluto is the key implementation boundary in an Edge Agent wallet. Identus defines the storage interface, and the application provides the storage implementation that matches its platform and threat model.

For a browser wallet, the implementation can use IndexedDB or another browser database. For a mobile wallet, it can use the platform database plus Keychain or Keystore-backed key protection. For a server-side test wallet, an in-memory store works for a disposable run. Production storage should encrypt sensitive data at rest, bind encryption keys to the platform security model where possible, and support tested backup and restore.

Storage design changes wallet behavior. If the application stores credentials but loses private keys, the holder can lose the ability to prove control of the DID used during issuance or presentation. If the application stores keys but loses credentials, the holder can still control the DID but no longer has the credential payload. If the application loses DIDComm protocol records, it can fail to resume issuance, connection, or proof flows after restart.

Treat community Pluto stores as dependencies to evaluate, not as Identus defaults. Check maintenance status, encryption behavior, migration support, and compatibility with the SDK version used by the application before selecting one.

## Cloud Agent Wallets

Cloud Agent runs on a server and exposes wallet operations through REST APIs and webhook-driven workflows. The Cloud Agent README describes it as a W3C and Aries standards-based cloud agent that supports DIDComm v2, credential issuance, credential verification, credential holding, secret management, and multi-tenancy.

A Cloud Agent wallet fits services that need server-side identity operations. An airline can use Cloud Agent to manage issuer DIDs, sign ticket credentials, send offers, and track issuance state. An airport verifier can use Cloud Agent to request presentations and receive verification results. A company can run Cloud Agent in multi-tenant mode when each customer or department needs a separate wallet.

Cloud Agent custody has a different trust boundary from an Edge Agent wallet. The tenant or business controller interacts with the wallet through an API. The service operator controls the runtime, database, secret storage, networking, and operational access. A service-managed wallet can be a good fit for organizations and delegated user wallets, but the deployment must define who can administer wallets, export data, rotate secrets, recover seeds, and inspect logs.

## Multi-Tenant Wallets

In Cloud Agent multi-tenancy, an administrator creates a wallet, creates an entity for the tenant, and provisions an authentication method for that entity. The Identus tenant onboarding documentation describes the wallet as the container for tenant assets, including

DIDs, credentials, and connections. After provisioning, Cloud Agent scopes tenant API calls to that wallet.

This model fits service-managed wallets. It does not remove custody risk. The administrator API, tenant authentication, wallet identifiers, database rows, Vault paths, and webhook routing must all preserve tenant separation.

### Cloud Agent Key Material

Identus Cloud Agent uses different key-management paths for PRISM DIDs and Peer DIDs.

For managed PRISM DIDs, Cloud Agent derives key material from a wallet seed and derivation path. The DID management documentation states that Cloud Agent stores the derivation path rather than the PRISM key material itself, then reconstructs key material at runtime from the seed and path.

For managed Peer DIDs, Cloud Agent generates key material and stores it in secret storage. Peer DIDs support DIDComm activity, so these keys protect relationship-specific communications.

The Cloud Agent secrets storage documentation names HashiCorp Vault as the default secret storage service. It describes secret types such as seeds, private keys, credential-definition data, and AnonCreds link secrets. In multi-tenant configuration, Vault asset paths include the wallet ID so each wallet's secrets live under its own path.

### Choosing Edge or Cloud Custody

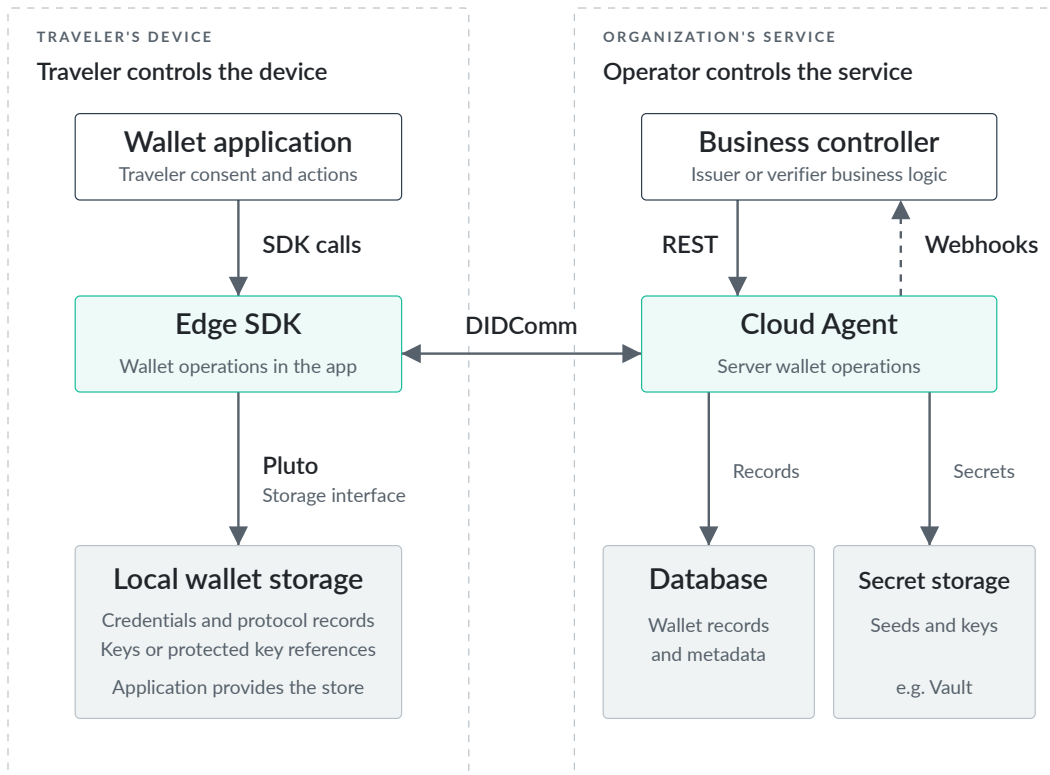
Use an Edge Agent wallet when the holder should keep credentials and keys in a user-controlled application. This model fits traveler wallets, employee wallets, citizen wallets, and mobile proof presentation. The application team must own storage, encryption, backup, recovery, mediator use, and local user consent.

Use a Cloud Agent wallet when a server must act for an organization or delegated tenant. This model fits issuers, verifiers, service-managed organizational wallets, and backend workflows that need REST APIs and webhooks. The deployment team must own secret storage, authentication, tenant separation, monitoring, and operational controls.

Many Identus systems use both. The issuer and verifier run Cloud Agent. The holder uses an Edge Agent wallet. DIDComm, credentials, DIDs, and presentation protocols connect the two custody models without requiring the same wallet implementation on every side.

## Edge and Cloud wallet custody

Traveler wallet and organizational wallet in the airline example



Boundaries show runtime and storage custody. DIDComm connects the two wallet implementations.

Figure 1: The application team implements storage, key protection, and recovery for the traveler's wallet. The service operator manages the Cloud Agent runtime, database, secret storage, and recovery. The DIDComm link represents protocol exchange; delivery can use a mediator.

## Airline Ticket Flow

The airline ticket example uses the wallet boundary in a concrete way:

1. The airline creates or selects a Cloud Agent wallet for issuer operations.
2. The airline creates an issuer `did:prism` with an `assertionMethod` verification method and publishes the DID when verifiers need ledger-backed resolution.
3. The traveler opens an Edge Agent wallet. The wallet creates or selects holder DIDs and stores local secret material through Pluto.
4. The airline sends a ticket credential offer to the traveler wallet through DIDComm or another supported issuance path.

5. The traveler wallet shows the offer, records holder consent, requests the credential, receives it, and stores it.
6. Airport security requests proof of ticket status, flight, passenger binding, or another accepted claim set.
7. The traveler wallet creates a presentation from the stored credential and sends it to the verifier.
8. The verifier software checks the presentation proof, issuer DID resolution, credential status, holder binding, schema, and format-specific rules.
9. Airport security policy decides whether the verified result satisfies the checkpoint rule.

Steps 8 and 9 are separate decisions. The verifier software can report that the credential proof is valid, the issuer DID resolved, and the credential is active. Airport policy can still reject the presentation if the flight date, airport, issuer, credential type, or passenger binding does not match the checkpoint rule.

## Implementation Notes

For Edge Agent wallets:

- Pick the SDK for the host platform before designing storage.
- Treat Pluto as a required wallet component, not an optional cache.
- Encrypt wallet contents that include credentials, DIDComm records, seeds, private keys, or secret references.
- Test restore on a clean device or browser profile.
- Use `did:peer` for relationship-specific DIDComm activity and `did:prism` for public resolution.

For Cloud Agent wallets:

- Decide whether the deployment uses a default wallet or multi-tenancy before onboarding users.
- Keep administrator credentials separate from tenant credentials.
- Place wallet seeds and private key material in the configured secret storage.
- Back up the Cloud Agent database and secret storage as one recovery unit.
- Audit webhook delivery, tenant API keys, wallet IDs, and Vault paths during tenant onboarding.

A team completes wallet work only after it tests restore and protocol resumption. A wallet that can issue or receive credentials during a happy-path demo can still fail in production if the holder changes devices, the browser storage is cleared, the mediator queue grows, or a Cloud Agent tenant needs recovery after database restore.

# DIDComm

## Overview

**DIDComm** (*Decentralized Identifier Communication*) is a crucial component in the Self-Sovereign Identity (SSI) ecosystem, providing the secure messaging layer that enables Decentralized Identifiers (DIDs) to interact. The current specification, **DIDComm v2**, evolved from earlier iterations to address the growing needs for privacy, security, and interoperability in digital identity communications. Its fundamental purpose is to enable secure, private, and authenticated communication between entities identified by DIDs, regardless of their underlying infrastructure or technology stack, transforming DIDs from static identifiers into dynamic communication endpoints capable of engaging in rich interactions.

Within the SSI technology stack, DIDComm sits above the foundational DID layer (which provides identifiers and cryptographic material) and below the application-specific protocols that define particular interactions like credential exchange. This positioning makes DIDComm the connective tissue of the SSI interactions in Identities, enabling all higher-level identity interactions.

## Key Characteristics

DIDComm’s design incorporates several distinctive characteristics that make it particularly well-suited for decentralized identity communications:

**Transport agnosticism** allows DIDComm messages to travel over virtually any communication channel—HTTP(S), WebSockets, Bluetooth, NFC, mesh networks or even QR codes. This flexibility means that identity interactions aren’t tied to specific network infrastructures, enabling truly peer-to-peer communications even in offline or intermittent connectivity scenarios.

**End-to-end encryption** ensures that message contents remain confidential between the sender and intended recipient(s), even when traversing untrusted networks or intermediaries. Using public key cryptography derived from DIDs, DIDComm creates secure communication channels that protect sensitive identity information.

**Authentication and trust** are inherent in DIDComm, as every message can be cryptographically verified to have originated from a specific DID. This authentication happens without centralized authorities, allowing parties to establish trust directly with one another.

**Asynchronous capabilities** enable communications that don’t require both parties to be online simultaneously. Messages can be queued, stored, and forwarded until they reach

their destination, making DIDComm suitable for a wide range of real-world scenarios where continuous connectivity isn't guaranteed.

**Message routing and forwarding** mechanisms allow communications to traverse complex paths, including through mediators and relays, while maintaining end-to-end security. This capability is essential for entities behind firewalls or NATs, or for preserving additional privacy by obscuring network-level metadata.

## Message Structure

DIDComm Messaging messages are structured as encrypted JSON Web Message (JWM) envelopes. This standardized format ensures interoperability while providing the necessary security properties.

A typical DIDComm message consists of:

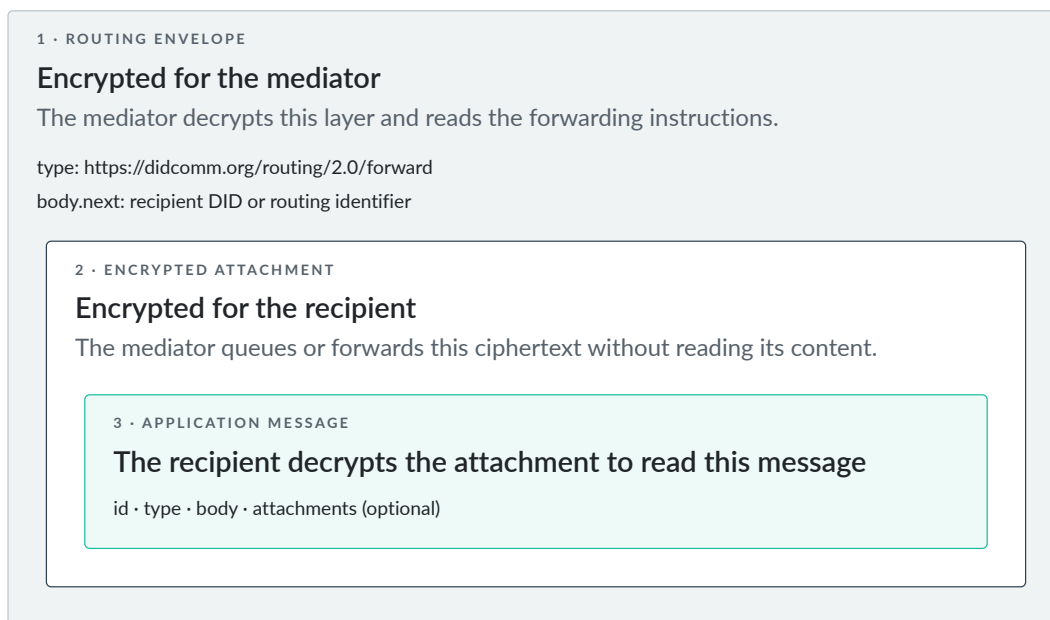
- **Headers:** Metadata about the message, including IDs, types, timing information, and routing details
- **Body:** The actual content or payload of the message
- **Attachments:** Optional additional data, which might include structured data, documents, or media

These components are assembled into a JWM, which is then typically encrypted and/or signed according to the security requirements of the interaction. The resulting structure provides a consistent envelope format that can carry any type of content while ensuring its security and integrity.

Each message contains a unique identifier and can reference other messages through threading mechanisms, enabling complex multi-message conversations. Messages also declare their type, which connects them to specific protocols that define the expected sequence and semantics of the interaction.

## Inside a mediated DIDComm message

One mediator hop; encryption layers shown expanded



The mediator reads the next routing destination. The recipient reads the application content.

Figure 1: The sender encrypts the application message for the recipient, attaches that ciphertext to a forward message, and encrypts the outer message for the mediator. The expanded layers show contents after each decryption step.

## Protocols

DIDComm defines not just message formats but also a framework for protocols—standardized sequences of messages that accomplish specific tasks. These protocols enable interoperability by ensuring that different implementations understand the same message sequences and semantics.

The protocol framework includes mechanisms for discovering which protocols an agent supports and for versioning protocols as they evolve. This allows for graceful upgrades and backward compatibility in the ecosystem.

Several common protocols have emerged in the SSI ecosystem:

- **Connection establishment protocols** define how two parties can establish a secure DIDComm channel

- **Credential issuance protocols** standardize how verifiable credentials are offered and issued
- **Credential presentation protocols** define how credentials can be requested and presented
- **Trust ping protocols** provide simple mechanisms to verify that a communication channel is active

By standardizing these interaction patterns, DIDComm enables different implementations to work together seamlessly, fostering an open ecosystem rather than siloed solutions.

You can find all currently published protocols in here, as these are maintained by the community, you are also encouraged to build and define your own protocols that fit your particular use case, even if you may not decide to publish them.

## Example interaction

To illustrate how DIDComm works in practice, consider a typical credential issuance scenario:

1. An Issuer and Holder establish a DIDComm connection, exchanging DIDs and service endpoints
2. The Issuer sends an offer message indicating which credentials it can provide
3. The Holder responds with a request message for a specific credential
4. The Issuer creates the credential and sends it in an issuance message
5. The Holder acknowledges receipt with an acknowledgment message

Throughout this interaction, all messages are encrypted end-to-end, ensuring that even if they pass through intermediaries, the content remains private between the Issuer and Holder. The messages might travel over different transport mechanisms—perhaps starting with an HTTPS connection but switching to Bluetooth for later messages if the parties come into proximity.

In mediated scenarios, the flow becomes more complex but even more powerful. A Holder might receive messages through a mediator service that provides consistent message delivery even when the Holder’s device is offline. The mediator receives encrypted messages, stores them until the Holder connects, and then forwards them without ever being able to read the encrypted contents.

## Benefits

DIDComm delivers several crucial benefits that advance the core principles of Self-Sovereign Identity:

**Privacy preservation** stands at the forefront of DIDComm’s design. By encrypting message contents and enabling pseudonymous interactions through pairwise DIDs, DIDComm allows

individuals to control exactly what information they share and with whom. The transport-agnostic nature also helps prevent correlation through network metadata.

**Decentralized communication** frees identity interactions from dependence on centralized messaging providers or identity hubs. Parties can communicate directly or through mediators of their choosing, avoiding vendor lock-in and single points of failure.

**Interoperability** between different SSI implementations ensures that the ecosystem remains open and competitive. A Holder using one wallet implementation can interact seamlessly with verifiers and issuers using entirely different software stacks, as long as they all support the DIDComm protocols.

**User control** extends beyond just identity data to encompass the communication channels themselves. Individuals can choose how, when, and where they receive communications related to their digital identity, reinforcing the self-sovereign nature of the system.

## DIDComm in Identus

Identus has adopted DIDComm v2 as its standard communication protocol, implementing it throughout the framework to enable secure, private messaging between DIDs. This implementation standardizes many important interactions, including the critical communication between mediators and their peers.

The integration with mediators is particularly important in the Identus architecture. Mediators serve as message handlers that can receive, store, and forward DIDComm messages, enabling asynchronous communication even when recipients are temporarily offline. This capability is essential for practical, real-world identity solutions that must function reliably across diverse connectivity scenarios.

At the moment of writing this chapter Identus supports DIDComm over HTTP endpoints by polling, which is by far the most tested and stable implementation, but also via WebSockets enabled as a feature flag in the Cloud Agent.

For details on how messages are sent and received in Identus via mediators, see Chapter .

# Connections

## Overview

Now that we have a better understanding of Wallets and DIDs, it's time to embark on our first interaction. In this chapter we are going to explore conceptually what a Connection means in SSI, take a deep dive into DID Peers, explain how they work and why they are needed for secure connections, dissect Out of Band invites and finally hands on example code to achieve connecting edge client to an agent.

Before we move forward we highly recommend to at least read the basic Connection tutorial on the official Identus documentation.

## Connections in Self-Sovereign Identity

Connections are fundamental to establishing *trusted interactions* between peers. They enable secure and verifiable communication, allowing entities to exchange credentials and proofs in a decentralized manner. This relationship is established using a specific decentralized identifier standard (**Peer DID**) and is governed by a protocol (**DIDComm**) that ensure the authenticity, integrity, and privacy of the interactions between the connected parties.

There are three roles in an SSI connection:

- **Inviter:** The entity that initiates the connection by sending an invitation.
- **Invitee:** The entity that receives the invitation and responds with a connection request.
- **Mediator:** An intermediary that facilitates message delivery between entities, especially when one or both parties may not always be online.

### Note

We will cover mediators in detail later on. For now what you need to understand is that they are used as a service to relay messages between peers, they will store messages and deliver them whenever a peer comes back online, connects to the mediator and fetches their messages.

## PeerDIDs

They are a special kind of decentralized identifier with some unique properties that allow them to be perfect for use in order to establish private and secure communications between peers.

DID Documents such as PrismDIDs are meant to be publicly available and resolvable by arbitrary parties, therefore storing them in a VDR such as Cardano blockchain is an excellent way to achieve this requirement in a reliable way.

However, when Alice and Bob want to interact with each other, only two parties care about the details of that connection: Alice and Bob. Instead of arbitrary parties needing to resolve their DIDs, only Alice and Bob do. Thus, PeerDIDs essentially describe a key-pair to encrypt and sign data to and from Alice and Bob, routed through their preferred mediators, e.g. When Alice accepts an invite from Bob and they engage the connection protocol, Alice generates a PeerDID that allows her to encrypt and sign data routed through Bob's mediator (mediator Y) that only Bob can decrypt, and vice versa, Bob will generate a PeerDID that allows him to encrypt and sign data routed through Alice's preferred mediator (mediator X) that only Alice can decrypt.

The key benefits of PeerDIDs are:

1. Decentralized by nature.
2. No transaction cost on blockchain.
3. Private (only the concerned parties know about them).
4. Reusable without any reliance on the internet, with no degradation of trust. (adheres to the principles of local-first and offline-first)

Lets resolve a PeerDID, we call resolve to the unpacking and parsing of a DID in order to read its content and use the DID for the interactions that we need to achieve. For this example we will resolve the PeerDID of the local Identus Mediator that you started in the Mediator chapter, which listens on `http://localhost:8080`.

```
curl http://localhost:8080/did
```

```
did:peer:2.Ez6LSghwSE437wnDE1pt3X6hVDUQzSjsHzinpX3XFvMjRAM7y.Vz6Mkhh1e5CEYYq6JBUcTZ6Cp2ranC
```

We can see that the mediator returned a PeerDID when we send a `GET` request to the `/did` endpoint. A `did:peer:2` DID is self-contained: the keys and service endpoints are encoded in the DID string itself, so it can be resolved locally without contacting any network or registry. Here we use the `did-peer-2` Python library, one of the implementations of the Peer DID method specification.

```
pip install did-peer-2
python3 -c "import json, sys; from did_peer_2 import resolve; print(json.dumps(resolve(sys.
    '$(curl -s http://localhost:8080/did)'))"
```

```

{
  "@context": [
    "https://www.w3.org/ns/did/v1",
    "https://w3id.org/security/multikey/v1"
  ],
  "id": "did:peer:2.Ez6LSghwSE437wnDE1pt3X6hVDUQzSjsHzinpX3XFvMjRAm7y.Vz6Mkhh1e5CEYYq6JBUCtZ6Cp2ranCWRrv7Yax3Le4N59R6dd",
  "verificationMethod": [
    {
      "type": "Multikey",
      "id": "#key-1",
      "controller": "did:peer:2.Ez6LSghwSE437wnDE1pt3X6hVDUQzSjsHzinpX3XFvMjRAm7y.Vz6Mkhh1e5CEYYq6JBUCtZ6Cp2ranCWRrv7Yax3Le4N59R6dd",
      "publicKeyMultibase": "z6LSghwSE437wnDE1pt3X6hVDUQzSjsHzinpX3XFvMjRAm7y"
    },
    {
      "type": "Multikey",
      "id": "#key-2",
      "controller": "did:peer:2.Ez6LSghwSE437wnDE1pt3X6hVDUQzSjsHzinpX3XFvMjRAm7y.Vz6Mkhh1e5CEYYq6JBUCtZ6Cp2ranCWRrv7Yax3Le4N59R6dd",
      "publicKeyMultibase": "z6Mkhh1e5CEYYq6JBUCtZ6Cp2ranCWRrv7Yax3Le4N59R6dd"
    }
  ],
  "keyAgreement": [
    "#key-1"
  ],
  "authentication": [
    "#key-2"
  ],
  "service": [
    {
      "type": "DIDCommMessaging",
      "serviceEndpoint": {
        "uri": "http://localhost:8080",
        "accept": [
          "didcomm/v2"
        ]
      },
      "id": "#service"
    },
    {
      "type": "DIDCommMessaging",
      "serviceEndpoint": {
        "uri": "ws://localhost:8080/ws",
        "accept": [
          "didcomm/v2"
        ]
      },
      "id": "#service-1"
    }
  ]
}

```

```

    }
  ],
  "alsoKnownAs": [
    "did:peer:3zQmdayqvm5GBi2QrjAz3y99vCEp7xMvcz8eDLi1KefSq38f"
  ]
}

```

This is what a PeerDID looks like when resolved into its DID Document. The `alsoKnownAs` entry is the equivalent short-form `did:peer:3` identifier, derived from the same DID.

In simple terms, a PeerDID is essentially a JSON payload that contains a set of keys and an optional service endpoints, because this is a mediator PeerDID, it contains service endpoints for `DIDCommMessaging`, in this particular case, you can see it contains two of them, one over regular `http` and other through `websockets`. These values come from the mediator's `SERVICE_ENDPOINTS` setting.

To go deeper in your understanding of PeerDIDs please refer to the full Peer DID Method Specification. In the Hyperledger Indutus ecosystem, only PeerDIDs method 2 are supported at the time of this writing.

## Out of Band invites

Out of Band (OOB) invites are the entry point for some protocols to take place, they usually are encoded in either a JSON payload or a URL and are distributed “out of band”, usually over QR codes, but could be distributed over any medium (Bluetooth, NFC, etc). They gather all required information for one peer to start interacting with another and you can think of them as a way to advertise “coordinates” for anyone that would like to establish an interaction to the inviter.

Following the same example as before, we can see that the local mediator also delivers an OOB invite in a URL form, through its `/invitationOOB` endpoint.

```

curl http://localhost:8080/invitationOOB

?_oob=eyJpZCI6IjA4NzQ3YWJiLTE4MGYtNGQxOC05ZTVjLWIzOGRiM2JiMTJhMiIsInR5cGU0OiJodHRwczovL2RpZ

```

Appended to the mediator's URL, this becomes a full invitation link such as `http://localhost:8080?_oob=eyJpZC...`

If we decode the value of the `_oob` query variable from `base64` we get the `json` payload

```

{
  "id": "08747abb-180f-4d18-9e5c-b38db3bb12a2",
  "type": "https://didcomm.org/out-of-band/2.0/invitation",
  "from": "did:peer:2.Ez6LSghwSE437wnDE1pt3X6hVDUQzSjsHzinpX3XFvMjRAm7y.Vz6Mkhh1e5CEYYq6JBU

```

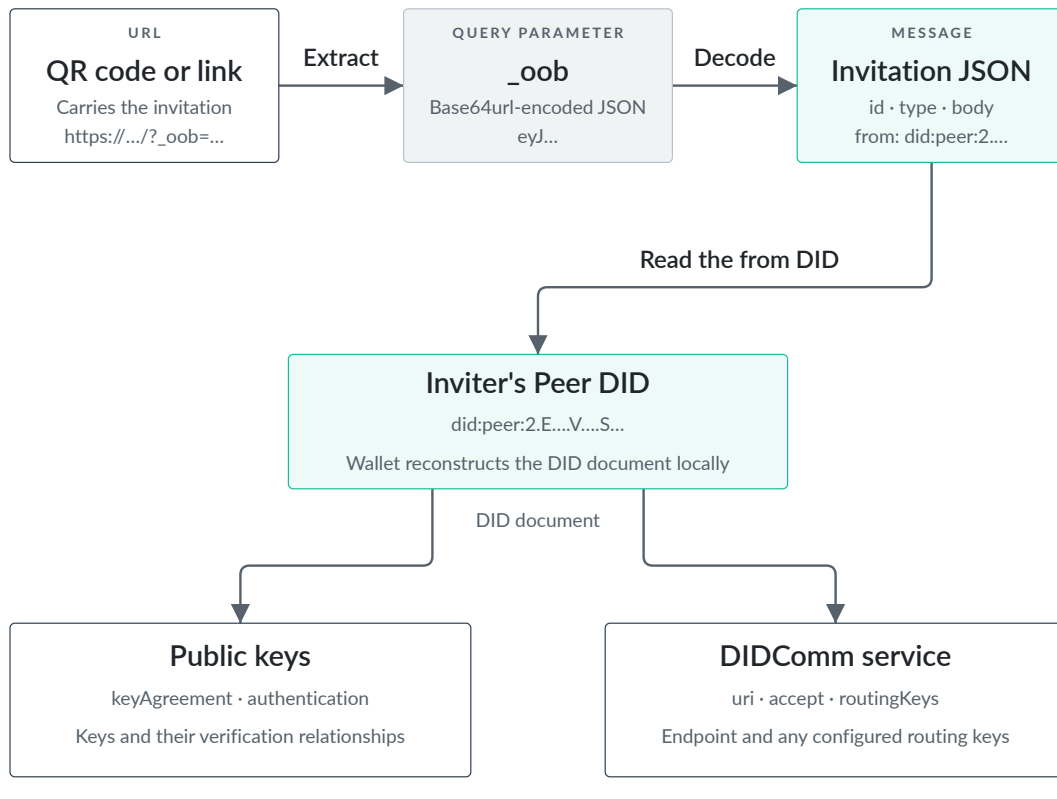
```
"body": {  
  "goal_code": "request-mediate",  
  "goal": "RequestMediate",  
  "accept": [  
    "didcomm/v2"  
  ]  
}
```

As you can see, an Out of Band invite is really just a way to package a PeerDID and signaling that it can be used for a particular interaction. In this case, for a **RequestMediate** goal over DIDComm.

As a refresher from what we covered, a PeerDID is a way to package a set of keys and optional service endpoints, and so, *because this an OOB invite from a mediator*, this invite has everything you need (a PeerDID and set of service endpoints) to establish this service as your mediator.

## From invitation to keys and endpoint

The invitee wallet reads an OOB invitation containing a Peer DID



The wallet uses these public keys and routing details in the next protocol step.

Figure 1: This example uses `did:peer:2` with embedded service information. The wallet decodes the invitation, resolves its from DID, and reads the public keys and DIDComm service. Ellipses abbreviate the encoded values.

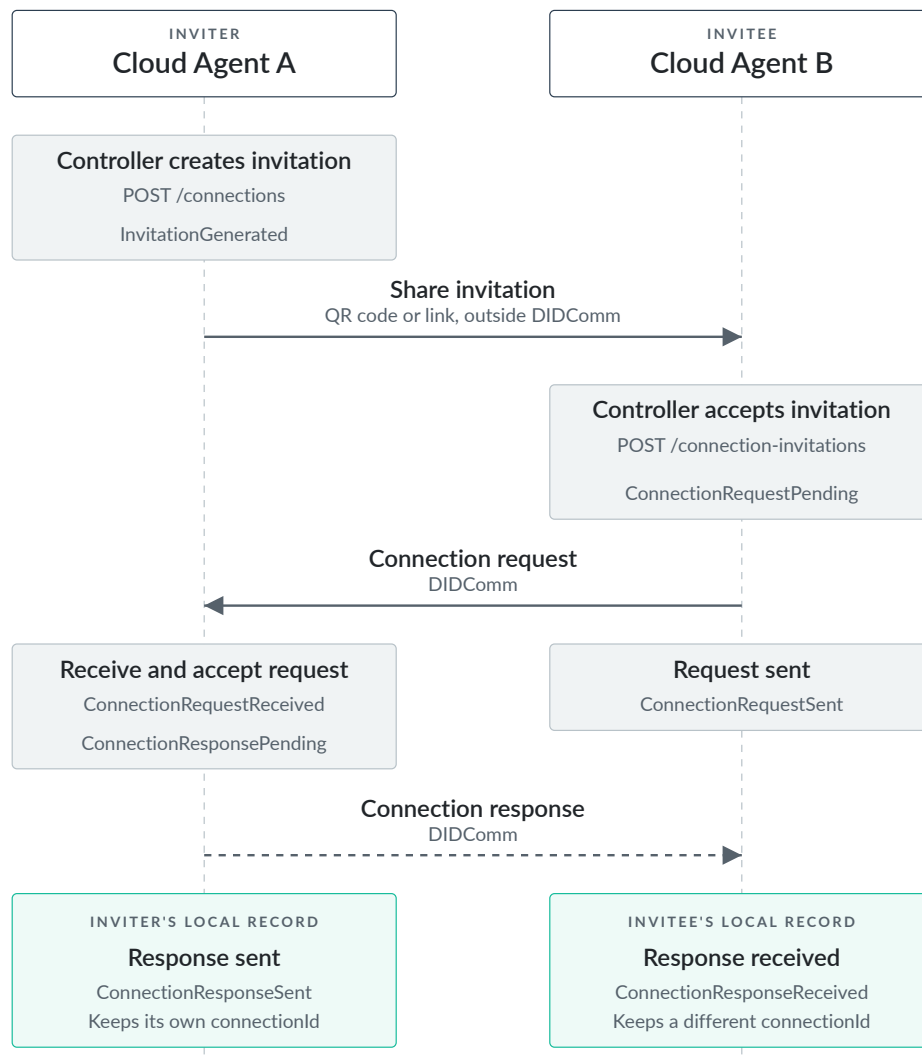
## Connecting two peers

Now, let's issue another kind of Out of Band invite, one from the cloud agent in order to connect.

The Cloud Agent can generate Out of Band invites, this invite then can be parsed by another peer (say another Cloud Agent or Edge Client) and use it to establish a connection, the end result should be a DID Peer on both sides that allow them to send messages to each other over DIDComm.

## Establishing a connection between two agents

Two Cloud Agents; selected API calls and record states



Boxes show local actions and record states. Arrows show invitation and protocol exchanges.

Figure 2: Each controller uses its own Cloud Agent's connectionId to read or continue the connection. The agents advance their records as they send and receive messages. The diagram shows selected states on the successful path.

So, our first step is to generate the invite:

```
curl --location 'http://127.0.0.1:8080/cloud-agent/connections' \
--header 'Content-Type: application/json' \
--header 'Accept: application/json' \
--data '{"label": "test"}'
```

**i** Note

The only parameter we can change when generating an invite is the `label`, this is optional and it is a simple string that you can use to identify the connection later, a good idea would be to use a `uuid` that you generate and manage on your systems, or could be an alias or the reason for the connection, this is all contextual to the interaction and use case so in our case we will go with “test”.

The Cloud Agent will respond with a payload that should look like this:

```
{
  "connectionId": "fb36eddd-d51e-42cf-a6fe-e76d2e638b70",
  "thid": "fb36eddd-d51e-42cf-a6fe-e76d2e638b70",
  "label": "test",
  "role": "Inviter",
  "state": "InvitationGenerated",
  "invitation": {
    "id": "fb36eddd-d51e-42cf-a6fe-e76d2e638b70",
    "type": "https://didcomm.org/out-of-band/2.0/invitation",
    "from": "did:peer:2.Ez6LSgY6Y67mJ75YCFZfZYxYEPQJZs3vaEg2Cc91vppoTA7cpj.Vz6MkpX7H7SNA",
    "invitationUrl": "https://my.domain.com/path?_oob=eyJpZCI6ImZiMzZlZGRkLWQ1MWUtNDJjZ"
  },
  "createdAt": "2025-01-04T12:37:37.059649293Z",
  "metaRetries": 5,
  "self": "fb36eddd-d51e-42cf-a6fe-e76d2e638b70",
  "kind": "Connection"
}
```

Once the connection invite is created you can fetch it's details by a `GET` request passing the `connectionId`:

```
curl --location 'http://127.0.0.1:8080/cloud-agent/connections/fb36eddd-d51e-42cf-a6fe-e76d2e638b70' \
--header 'Accept: application/json' \
```

You should get back the same payload as when it was created unless something changed, like the `state`:

```
{
  "connectionId": "fb36eddd-d51e-42cf-a6fe-e76d2e638b70",
  "thid": "fb36eddd-d51e-42cf-a6fe-e76d2e638b70",
  "label": "test",
  "role": "Inviter",
  "state": "InvitationGenerated",
  "invitation": {
    "id": "fb36eddd-d51e-42cf-a6fe-e76d2e638b70",
```

```

    "type": "https://didcomm.org/out-of-band/2.0/invitation",
    "from": "did:peer:2.Ez6LSgY6Y67mJ75YCFZYxYEPQJZs3vaEg2Cc91vppoTA7cpj.Vz6MkpX7H7SNA",
    "invitationUrl": "https://my.domain.com/path?_oob=eyJpZCI6ImZiMzZlZGRkLWQ1MWUtNDJjZ",
  },
  "createdAt": "2025-01-04T12:37:37.059649Z",
  "metaRetries": 5,
  "self": "fb36eddd-d51e-42cf-a6fe-e76d2e638b70",
  "kind": "Connection"
}

```

Lets dig a bit deeper on what this payload represents.

This invite payload contains some important metadata:

- **connectionId**: The unique identifier of the connection resource, used to fetch the connection details.
- **thid**: The unique identifier of the *thread* this connection record belongs to. The value will be identical on both sides of the connection (inviter and invitee).
- **label**: A human readable alias for the connection.
- **role**: The Cloud Agent role on this connection, either *Inviter* or *Invitee*.
- **state**: The current status of this connection, note this is contextual to the Cloud Agent role, so as *Inviter* the states could be: *InvitationGenerated*, *ConnectionRequestReceived*, *ConnectionResponsePending*, *ConnectionResponseSent*. But is also possible for the Cloud Agent to parse someone else's invitation, in that case the Cloud Agent will generate a connection with the *Invitee* role and the possible states for that role are: *InvitationReceived*, *ConnectionRequestPending*, *ConnectionRequestSent*, *ConnectionResponseReceived*.
- **invitation**: The DIDComm invitation details.
- **createdAt**: Date and time when this connection was created or received.
- **metaRetries**: The maximum background processing attempts remaining for this record.
- **self**: The reference to the connection resource.
- **kind**: The type of object returned. In this case a *Connection*.

Now lets unpack the *invitation* details.

- **id**: The unique identifier of the invitation. It should be used as parent thread ID (pthid) for the Connection Request message that follows.
- **type**: The DIDComm Message Type URI (MTURI) the invitation message complies with.
- **from**: The DID representing the sender to be used by recipients for future interactions.
- **invitationUrl**: The invitation message encoded as a URL.

Lets resolve the *from* DID:

```
curl https://dev.uniresolver.io/1.0/identifiers/did:peer:2.Ez6LSgY6Y67mJ75YCFZYxYEPQJZs3va
```

```

{
  "@context": "https://w3id.org/did-resolution/v1",
  "didDocument": {
    "@context": [
      "https://www.w3.org/ns/did/v1",
      "https://w3id.org/security/multikey/v1",
      {
        "@base": "did:peer:2.Ez6LSgY6Y67mJ75YCFZYxYEPQJZs3vaEg2Cc91vppoTA7cpj.Vz6MkpX7H7SNA6ooG5snn2MzgyoRadEZtsjNSL1x7HiiLkqyV"
      }
    ],
    "id": "did:peer:2.Ez6LSgY6Y67mJ75YCFZYxYEPQJZs3vaEg2Cc91vppoTA7cpj.Vz6MkpX7H7SNA6ooG5snn2MzgyoRadEZtsjNSL1x7HiiLkqyV",
    "verificationMethod": [
      {
        "id": "#key-2",
        "type": "Multikey",
        "controller": "did:peer:2.Ez6LSgY6Y67mJ75YCFZYxYEPQJZs3vaEg2Cc91vppoTA7cpj.Vz6MkpX7H7SNA6ooG5snn2MzgyoRadEZtsjNSL1x7HiiLkqyV",
        "publicKeyMultibase": "z6MkpX7H7SNA6ooG5snn2MzgyoRadEZtsjNSL1x7HiiLkqyV"
      },
      {
        "id": "#key-1",
        "type": "Multikey",
        "controller": "did:peer:2.Ez6LSgY6Y67mJ75YCFZYxYEPQJZs3vaEg2Cc91vppoTA7cpj.Vz6MkpX7H7SNA6ooG5snn2MzgyoRadEZtsjNSL1x7HiiLkqyV",
        "publicKeyMultibase": "z6LSgY6Y67mJ75YCFZYxYEPQJZs3vaEg2Cc91vppoTA7cpj.Vz6MkpX7H7SNA6ooG5snn2MzgyoRadEZtsjNSL1x7HiiLkqyV"
      }
    ],
    "keyAgreement": [
      "#key-1"
    ],
    "authentication": [
      "#key-2"
    ],
    "assertionMethod": [
      "#key-2"
    ],
    "service": [
      {
        "serviceEndpoint": {
          "uri": "http://host.docker.internal:8080/didcomm",
          "routingKeys": [],
          "accept": [
            "didcomm/v2"
          ]
        },
        "type": "DIDCommMessaging",
        "id": "#service"
      }
    ]
  }
}

```

```

    ]
  },
  "didResolutionMetadata": {
    "contentType": "application/did+ld+json",
    "pattern": "^(did:peer:.+)$",
    "driverUrl": "http://uni-resolver-driver-did-uport:8081/1.0/identifiers/",
    "duration": 3,
    "driverDuration": 3,
    "did": {
      "didString": "did:peer:2.Ez6LSgY6Y67mJ75YcZfZYxYEPQJZs3vaEg2Cc91vppoTA7cpj.Vz6MkpX7H7SN",
      "methodSpecificId": "2.Ez6LSgY6Y67mJ75YcZfZYxYEPQJZs3vaEg2Cc91vppoTA7cpj.Vz6MkpX7H7SN",
      "method": "peer"
    }
  },
  "didDocumentMetadata": {}
}

```

Now this looks familiar, we have the usual set of keys and it looks similar to the mediator DID but in this case we see a `serviceEndpoint` that contains accepts `didcomm/v2` and it's intended to be used for `DIDCommMessaging`. What all this means is the Cloud Agent DID is essentially advertising how it will receive `DIDComm` messages. In other words this could be translated as: “Here is an invite to connect to me, on it you will find a DID that has my public keys and a service endpoint where I receive `DIDComm` messages”.

The final piece to unpack is the `invitationUrl`, this looks a little odd at first:

```
"https://my.domain.com/path?_oob=eyJpZCI6ImZiMzZlZGRkLWQ1MWUtNDJjZi1hNmZlLWU3NmQyZTYzOGI3MCIsInR5cGUiOiJodHRwczovL2RpbZ"
```

The first thing that looks wrong is the domain, where does `my.domain.com` comes from? well, it comes from the Cloud Agent and it's hardcoded, you can't customize it but it really doesn't matter, what matters is the payload of the `_oob` field. The URL is not important as what we really need is inside the `base64` encoded field, lets unpack it.

```
echo 'eyJpZCI6ImZiMzZlZGRkLWQ1MWUtNDJjZi1hNmZlLWU3NmQyZTYzOGI3MCIsInR5cGUiOiJodHRwczovL2RpbZ'
```

```

{
  "id": "fb36eddd-d51e-42cf-a6fe-e76d2e638b70",
  "type": "https://didcomm.org/out-of-band/2.0/invitation",
  "from": "did:peer:2.Ez6LSgY6Y67mJ75YcZfZYxYEPQJZs3vaEg2Cc91vppoTA7cpj.Vz6MkpX7H7SNA6ooG5s",
  "body": {
    "accept": []
  }
}

```

And there it is, the `_oob` encoded payload contains the bare minimum to tell you it's a `DIDComm` invitation from a DID Peer.

## Connectionless Credential Presentations and Issuance

In the realm of digital identity, establishing trust and exchanging verifiable credentials typically involves a series of interactions between an issuer or verifier and a holder. While many protocols need an existing connection or relationship, a connectionless flow offers a more streamlined approach for specific scenarios. This method is particularly useful when a prior relationship between the issuer or verifier and the holder has not yet been established or is not necessary for a particular interaction.

The fundamental distinction of connectionless issuance and presentation lies in its initiation. Unlike traditional flows that might require a formal connection setup (e.g., exchanging DIDs and establishing a DIDComm channel) *before* a credential offer can be made, the connectionless flow leverages an Out-of-Band (OOB) invitation to kickstart the process directly.

When an issuer or verifier intends to offer or request proof this way, they generate an OOB invitation. This invitation is essentially a self-contained message or a reference (like a URL or QR code) that the holder can receive through various means (QR code, email, a website, etc). Upon parsing this OOB invitation, the holder's agent can immediately understand the intent to offer or proof a credential.

The key here is that the OOB invitation itself contains enough information, or points to it, for the holder's agent to proceed with requesting the credential offer from the issuer or presenting proof to a verifier. This bypasses the need for a separate, preliminary connection handshake. The issuer or verifier, upon receiving a request derived from this OOB invitation, can then proceed to send the actual credential offer or proof request.

From the holder's acceptance of the offer onwards, the subsequent steps closely mirror those in a standard issuance and proof request protocols. The primary efficiency and distinction of the connectionless approach are concentrated at the beginning of the interaction, enabling a quicker, more direct path when a persistent connection is not a prerequisite. This makes it ideal for scenarios like anonymous attestations, one-time verifications, or public credential offerings where the overhead of establishing and managing connections for every holder is impractical.

# Verifiable Credentials

## Overview

Think of a Verifiable Credential (VC) as a signed statement that can move with the person or organization it describes. An airline can issue a boarding pass to a traveler. A university can issue a degree credential to a graduate. A government agency can issue a permit to a company. In each case, the holder keeps the credential and later presents it to a verifier that needs proof of a claim.

The W3C Verifiable Credentials Data Model 2.0 defines the main roles as issuer, holder, verifier, and subject. The issuer creates the credential. The holder stores it and presents it. The verifier checks the presentation. The subject is the person, organization, thing, or account that the claims describe. The holder and subject sometimes match. In other cases, a parent may hold a child credential, or a company administrator may hold credentials about the company.

A VC contains four kinds of information:

- Claims, such as name, ticket number, membership level, age range, or license category.
- Issuer information, so a verifier can decide who made the statement.
- Proof material, so a verifier can check integrity and authorship.
- Metadata, such as issuance date, expiration date, schema, credential type, and status.

The proof lets a verifier detect tampering. It does not decide whether the verifier should accept the credential for a given business purpose. That decision depends on policy. A boarding gate may accept only credentials issued by the airline for the current flight. A verifier may reject an otherwise valid credential if the issuer is not trusted, the credential has expired, the schema is not accepted, or the credential has been revoked.

The Identus Cloud Agent README describes Cloud Agent as a W3C and Aries-based agent that can issue, hold, and verify credentials over DIDComm v2. Identus supports multiple credential formats through a REST API and webhook-driven agent workflows.

## Formats

VCs share a common purpose, but they do not all use the same envelope, proof format, privacy model, or verification procedure. Identus Cloud Agent documents three credential formats for issuance through its APIs: JWT-VC, SD-JWT-VC, and AnonCreds. In Cloud Agent payloads these appear as `credentialFormat` values such as `JWT`, `SDJWT`, and `AnonCreds`.

## **JWT Verifiable Credentials**

JWT-VC packages credential claims in a JSON Web Token. Teams often choose it when their verifiers already rely on JOSE tooling and DID-based issuer verification. The verifier decodes the JWT, validates the signature against the issuer's public key resolved from the issuer DID, and reads the claims.

JWT-VC has a privacy tradeoff. The holder usually presents the credential as a whole, so the verifier sees all claims in the credential. That is fine for a boarding gate that needs the full ticket details. It is a poor fit when the holder should reveal only one or two fields.

The Identus DIDComm issuance guide uses `jwtVcPropertiesV1` for JWT credential offers and notes that this payload shape is aligned with the W3C VC Data Model 1.1 profile used by the agent.

## **SD-JWT Verifiable Credentials**

SD-JWT-VC builds on Selective Disclosure JWT. It lets a holder disclose selected claims from a credential instead of revealing the whole claim set. A traveler proving lounge access may need to disclose membership tier and expiration date, but not date of birth or full customer profile.

The IETF SD-JWT VC draft defines data formats and processing rules for JSON credentials with selective disclosure. At a high level, the issuer signs a structure that commits to the claim values. The holder later presents only the disclosures needed for the verifier's request, and the verifier checks those disclosures against the signed commitments.

Identus uses `sdJwtVcPropertiesV1` for this format and requires Ed25519 issuer and holder keys for SD-JWT issuance. Identus Present Proof documentation calls out one presentation detail: if the SD-JWT credential has no `cnf` key, the holder cannot create and sign a presentation bound to the verifier's challenge and domain. With `cnf`, the holder can prove control of the bound key during presentation.

## **AnonCreds**

AnonCreds is a zero-knowledge proof credential format. It comes from the Hyperledger Indy ecosystem and is now maintained under Hyperledger AnonCreds. Holders use it for privacy-preserving proofs, such as proving predicates over attributes without disclosing raw values.

AnonCreds requires a credential definition. That artifact references a schema and contains issuer cryptographic material used for proof generation. In Identus, AnonCreds claims use a flat string-to-string shape, and the issuer references the credential definition with `credentialDefinitionId` inside `anoncredsVcPropertiesV1`.

## OID4VCI

OpenID for Verifiable Credential Issuance (OpenID4VCI) is an issuance protocol, not a credential format. It extends OAuth 2.0-style flows so a wallet can obtain credentials from an issuer through a Credential Endpoint. The OpenID Foundation approved OpenID4VCI 1.0 as a Final Specification on 16 September 2025, and the specification defines the issuer metadata, credential configurations, authorization flow, and credential request flow.

The Identus OID4VCI guide describes Cloud Agent acting as a Credential Issuer server and integrating with an Authorization Server that follows the expected contract. Identus provides an example flow with Keycloak and authorization code issuance.

## W3C VC 2.0 context

Early VC 1.1 deployments no longer describe the full standards picture. W3C announced the Verifiable Credentials 2.0 family as Recommendations on 15 May 2025. The VC JOSE and COSE Recommendation defines ways to secure VC Data Model 2.0 credentials and presentations with JOSE, SD-JWT, and COSE.

Identus documentation still names the concrete formats and payloads supported by Cloud Agent, so implementation work should follow the Cloud Agent docs first and treat the W3C VC 2.0 documents as the direction of the wider standards family.

## Schemas

A credential schema describes the shape of credential claims. It answers questions such as: Which fields are expected? Which fields are required? What data type should each field use? A schema does not decide whether a claim is true. It gives issuers, holders, and verifiers a shared structure for reading the credential.

## Schema specifications

Identus uses two schema families across its credential formats.

JWT and SD-JWT credentials use JSON Schema. The official Identus schema guide requires the schema body to set `$schema` to `https://json-schema.org/draft/2020-12/schema`, which matches the current draft described by the JSON Schema project.

AnonCreds credentials use AnonCreds schemas paired with credential definitions. The credential definition references a schema by ID and must exist before the issuer can create an AnonCreds credential offer.

## Example schema

An airline ticket credential might use a JSON Schema like this:

```
{
  "$id": "https://example.com/schemas/boarding-pass-1.0",
  "$schema": "https://json-schema.org/draft/2020-12/schema",
  "title": "Boarding pass",
  "type": "object",
  "properties": {
    "passengerName": { "type": "string" },
    "flightNumber": { "type": "string" },
    "departureAirport": { "type": "string" },
    "arrivalAirport": { "type": "string" },
    "departureDateTime": { "type": "string", "format": "date-time" },
    "seatNumber": { "type": "string" },
    "boardingGroup": { "type": "string" },
    "ticketClass": { "type": "string" }
  },
  "required": [
    "passengerName",
    "flightNumber",
    "departureAirport",
    "arrivalAirport",
    "departureDateTime",
    "seatNumber"
  ],
  "additionalProperties": false
}
```

## Creating schemas in Identus

Identus Cloud Agent has a schema registry for creating and resolving credential schemas. The official schema guide documents two creation endpoints:

```
POST /cloud-agent/schema-registry/schemas
POST /cloud-agent/schema-registry/schemas/did-url
```

Use the HTTP endpoint when verifiers should resolve the schema through an HTTP URL. Use the DID URL endpoint when verifiers should resolve the schema through a DID URL. These are separate resolution modes, so keep the expected verifier path in mind before issuing credentials against the schema.

Each schema record includes metadata around the schema definition. The **name** gives the schema a readable label, **version** identifies the version, **author** names the DID that created

it, and **tags** help filter schema records. The **schema** field contains the JSON Schema definition. Cloud Agent treats the combination of **author**, schema **id**, and **version** as unique.

The **author** field must be the short-form PRISM DID created by the same Cloud Agent. The DID does not need to be published before schema creation. During setup, an issuer can create a DID, create a schema, and publish the DID later when the credential flow needs public resolution.

### Versioning

Updating a schema means creating a new schema record with the changed JSON Schema and a higher version. Do not mutate the meaning of a schema version after credentials have been issued against it. Old credentials remain easier to verify when their original schema still resolves to the same structure.

For breaking changes, such as removing required fields or changing field types, use a new major version. For additive changes, such as adding an optional field, use a minor version. This keeps issuer and verifier policy readable when multiple credential versions exist at the same time.

### Issuing

Issuance turns an issuer's claim data into a credential held by a wallet or agent. In Identus, issuance can happen through a DIDComm connection, through a connectionless invitation, or through OpenID4VCI.

The Identus DID guides matter before issuance starts. The Cloud Agent registrar can create a PRISM DID offline. The DID document template supports verification methods for purposes such as **authentication** and **assertionMethod**. A long-form PRISM DID carries the create operation in the DID itself. A short-form PRISM DID needs publication before other parties can resolve it from the ledger. The Cloud Agent DID publication guide documents the publication flow and its status changes from **CREATED** to **PUBLICATION\_PENDING** to **PUBLISHED**.

### Prerequisites

For DIDComm issuance, the Identus Issue Credential Protocol 3.0 guide describes the format-specific prerequisites.

JWT issuance requires a connection between issuer and holder agents, a published issuer PRISM DID with **assertionMethod**, a credential schema, and a holder PRISM DID with **authentication**.

SD-JWT issuance has the same shape, but the issuer and holder PRISM DIDs must use Ed25519 keys for the relevant verification methods.

AnonCreds issuance requires a connection and an AnonCreds credential definition.

## **Credential states**

The issuer-side states are:

```
OfferPending -> OfferSent -> RequestReceived -> CredentialPending -> CredentialGenerated ->
```

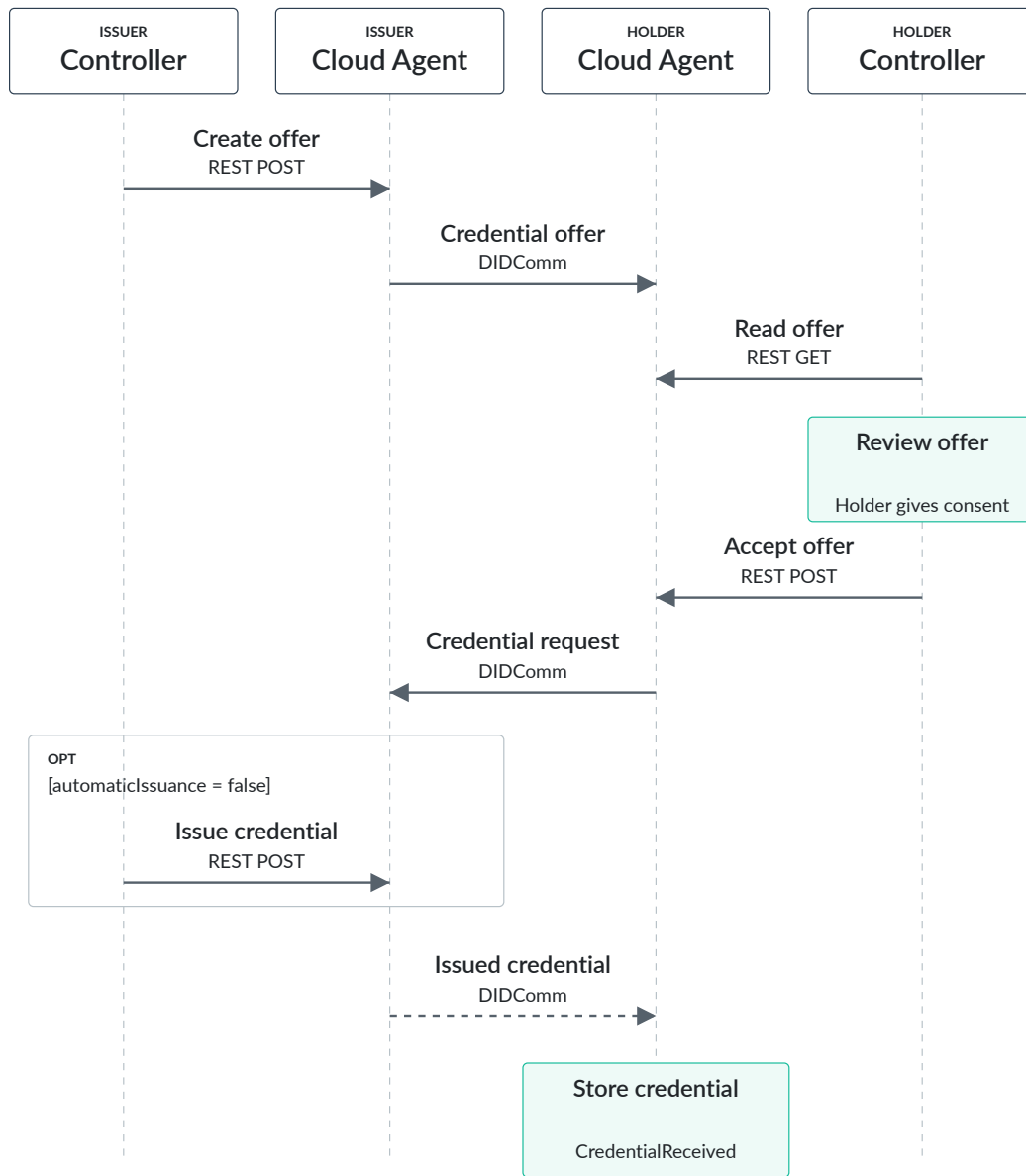
The holder-side states are:

```
OfferReceived -> RequestPending -> RequestSent -> CredentialReceived
```

These states are useful when a wallet or controller needs to resume a flow, show progress to a user, or decide whether a manual issuer action is still required.

## Issuing a credential over DIDComm

An existing connection links the issuer and holder agents



REST calls connect each controller to its agent. DIDComm connects the two agents.

Figure 1: The holder controller reads the offer and records holder consent before calling accept-offer. With automatic issuance enabled, the issuer agent processes the credential request without the optional controller call. Manual issuance uses issue-credential on the issuer's record. REST responses and intermediate states are omitted; each controller uses its own agent's record IDs.

## Issuer flow

An issuer starts by preparing four pieces of data: the issuer DID, the credential schema or credential definition, the claims, and the credential format.

For a boarding pass, the airline selects its issuer DID, chooses the boarding pass schema, and prepares claims such as passenger name, flight number, departure date, seat, and boarding group. The format choice depends on verifier needs. A gate scanner may only need a JWT-VC. Use SD-JWT-VC when the traveler should reveal only part of the credential. Use AnonCreds when the verifier needs zero-knowledge proofs or predicate proofs.

The issuer creates a credential offer through Cloud Agent:

```
POST /cloud-agent/issue-credentials/credential-offers
```

JWT offers use `jwtVcPropertiesV1`:

```
{
  "connectionId": "holder-connection-id",
  "credentialFormat": "JWT",
  "jwtVcPropertiesV1": {
    "claims": {
      "passengerName": "Alice Wonderland",
      "flightNumber": "ID123",
      "departureAirport": "SCL",
      "arrivalAirport": "EZE",
      "seatNumber": "12A"
    },
    "issuingDID": "did:prism:issuer",
    "credentialSchema": {
      "id": "http://localhost:8080/cloud-agent/schema-registry/schemas/...",
      "type": "JsonSchemaValidator2018"
    }
  }
}
```

SD-JWT offers use `sdJwtVcPropertiesV1`:

```
{
  "connectionId": "holder-connection-id",
  "credentialFormat": "SDJWT",
  "sdJwtVcPropertiesV1": {
    "claims": {
      "passengerName": "Alice Wonderland",
      "flightNumber": "ID123",
      "boardingGroup": "A",
    }
  }
}
```

```

    "exp": 1883000000
  },
  "issuingDID": "did:prism:issuer",
  "credentialSchema": {
    "id": "http://localhost:8080/cloud-agent/schema-registry/schemas/...",
    "type": "JsonSchemaValidator2018"
  }
}
}
}

```

AnonCreds offers use `anoncredsVcPropertiesV1` and a `credentialDefinitionId`:

```

{
  "connectionId": "holder-connection-id",
  "credentialFormat": "AnonCreds",
  "anoncredsVcPropertiesV1": {
    "claims": {
      "passengerName": "Alice Wonderland",
      "flightNumber": "ID123",
      "seatNumber": "12A"
    },
    "issuingDID": "did:prism:issuer",
    "credentialDefinitionId": "credential-definition-id"
  }
}

```

After creating the offer, the issuer watches the issue credential record state. If the holder accepts the offer and the issuer uses automatic issuance, Cloud Agent issues the credential when the holder's request arrives. If automatic issuance is disabled, the issuer sends the credential from the matching record:

```
POST /cloud-agent/issue-credentials/records/{recordId}/issue-credential
```

## Holder flow

The holder receives a credential offer, reviews it, and accepts it. In a user-facing wallet, that review step should show the issuer, credential type, requested format, claim preview, and any privacy-relevant details. The holder should know what they are accepting before the wallet stores it.

The holder can retrieve issue credential records:

```
GET /cloud-agent/issue-credentials/records
```

To accept a JWT or SD-JWT offer, the holder provides a PRISM DID as `subjectId`:

```
{  
  "subjectId": "did:prism:holder"  
}
```

For SD-JWT credentials with key binding, the holder can include `keyId`:

```
{  
  "subjectId": "did:prism:holder",  
  "keyId": "key-1"  
}
```

AnonCreds offers do not use `subjectId` in the same way. The holder accepts the offer with an empty body:

```
{}
```

After acceptance, the holder receives the issued credential over DIDComm. Identus documents holder states such as `OfferReceived`, `RequestPending`, `RequestSent`, and `CredentialReceived`. The wallet stores the credential and later uses it in a presentation flow.

## Connectionless issuance

Connectionless issuance helps when the issuer and holder do not already have a DIDComm connection. The Identus connectionless issuance guide documents an out-of-band invitation endpoint:

```
POST /cloud-agent/issue-credentials/credential-offers/invitation
```

The issuer creates an invitation and shares the returned invitation code, for example as a QR code or link. The holder accepts the invitation through a wallet or SDK. The issuer responds with a credential offer, and the normal holder acceptance and issuer issuance steps follow.

A conference check-in desk could display a QR code that starts issuance of an attendee credential. The attendee scans it with a wallet, accepts the offer, and receives the credential without first creating a standing relationship with the issuer.

## OpenID4VCI issuance

OID4VCI fits issuers that already use OAuth-based user journeys. DIDComm issuance fits wallets and issuers that already participate in agent-to-agent protocols. A production deployment may support both paths, with policy deciding which one applies to each credential type.

In the Identus OID4VCI model, Cloud Agent acts as the Credential Issuer server. The wallet follows the authorization flow, obtains an access token from the Authorization Server, and uses that token at the Credential Endpoint. The exact issuer policy lives in the issuer and authorization server configuration, not in the wallet.

## Presenting and verification

Issuance gives the holder a credential. Presentation is how the holder proves something with it.

In Identus, the Present Proof Protocol 3.0 guide describes verifier, holder, and prover flows over DIDComm. A verifier creates a proof request:

```
POST /cloud-agent/present-proof/presentations
```

The request can include a **domain** and **challenge**. These values bind the presentation to the verifier and session, which reduces replay risk. The holder reviews the request, selects credentials, and accepts it:

```
PATCH /cloud-agent/present-proof/presentations/{id}
```

The exact payload depends on the credential format. JWT presentations use a **proofId**. SD-JWT presentations disclose selected claims and use **credentialFormat: SDJWT**. AnonCreds presentations use an AnonCreds presentation request.

After verification, Identus can reach **PresentationVerified**. The verifier can then accept the presentation, which moves the record to **PresentationAccepted**. This split matters. Verification checks cryptographic validity and protocol rules. Acceptance records a business decision by the verifier.

In the airline example, a valid ticket credential may still fail business policy. A traveler can hold a legitimate ticket and still lack a required visa, arrive after the gate closes, or fail a security check. VC verification tells the verifier whether the credential is authentic, intact, and acceptable under protocol rules. The verifier still decides whether to accept it for the trip.

## Revoking

Revocation lets an issuer mark a credential as no longer valid before its natural expiration. An airline may revoke a boarding pass after a booking is canceled. A university may revoke a credential issued by mistake. A company may revoke an employee credential after employment ends.

The Identus revocation guide documents revocation for JWT credentials using Verifiable Credentials Status List v2021. A revocable credential contains a `credentialStatus` object with fields such as `type`, `statusPurpose`, `statusListIndex`, and `statusListCredential`.

### Revocation mechanism

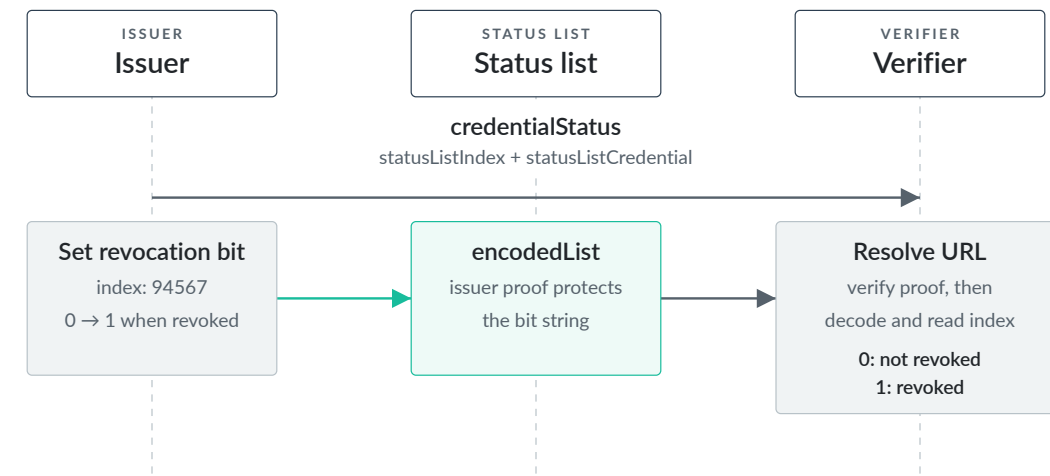
A revocable credential contains status data like this:

```
{
  "credentialStatus": {
    "id": "http://localhost:8080/cloud-agent/credential-status/[UUID]#[INDEX]",
    "type": "StatusList2021Entry",
    "statusPurpose": "revocation",
    "statusListIndex": "94567",
    "statusListCredential": "http://localhost:8080/cloud-agent/credential-status/[UUID]"
  }
}
```

The `statusListCredential` URL points to a Status List Credential. That credential contains an encoded bitstring where each bit position corresponds to a credential. The `statusListIndex` identifies the credential's position in that bitstring. When the issuer revokes a credential, the issuer flips the corresponding bit from 0 to 1.

## Credential revocation through a status list

The verifier checks one indexed bit in an issuer-signed list



The issuer controls revocation. The verifier trusts the result only after proof verification.

Figure 2: The credential points to `credentialStatus.statusListCredential` and supplies `statusListIndex`. The issuer changes the indexed bit, and the verifier resolves the list, verifies its proof, decodes `encodedList`, and reads that bit.

## Revoking a credential

Only the issuer of a credential can revoke it. Identus exposes the revocation operation as:

```
PATCH /cloud-agent/revoke-credential/{credential_id}
```

The issuer can find the credential ID by listing issued credential records, then calling the revocation endpoint for the target credential. Once revoked, a later Present Proof verification fails if the holder presents that credential. This keeps revocation in the verification path instead of relying on the holder to remove old credentials from storage.

## Checking revocation status

When a verifier receives a presentation containing a credential with `credentialStatus`, the verifier checks the status list before accepting the credential.

First, the verifier retrieves the Status List Credential from `credentialStatus.statusListCredential`. Then it verifies the proof embedded in that status credential. Identus documents two supported proof types for status list credentials: `DataIntegrityProof` with `eddsa-jcs-2022` for Ed25519 keys, and `EcdsaSecp256k1Signature2019` for secp256k1 keys.

After proof verification, the verifier decodes `credentialSubject.encodedList` and checks the bit at `statusListIndex`. If the bit is set to 1, the credential has been revoked. If the bit is 0, the status list has not revoked that credential.

This status-list model has a privacy benefit: the verifier retrieves the whole list instead of asking the issuer about a specific credential. The issuer does not learn which credential the verifier checked.

W3C published Bitstring Status List v1.0 as part of the VC 2.0 Recommendation family on 15 May 2025. The Identus documentation cited above still names Status List v2021 for JWT credential revocation, so implementers should follow the current Identus guide for Cloud Agent behavior and track future Identus releases for any status-list migration.

# Verification

## Presenting proof

Verification in Identus starts when a verifier asks a holder to present evidence from one or more credentials. For DIDComm flows, Identus Cloud Agent uses the Present Proof protocol. The verifier Cloud Agent sends a presentation request over an existing DIDComm connection, the holder Cloud Agent returns a presentation, and the verifier Cloud Agent checks the received proof material.

The Identus Present Proof guide describes the DIDComm API flow:

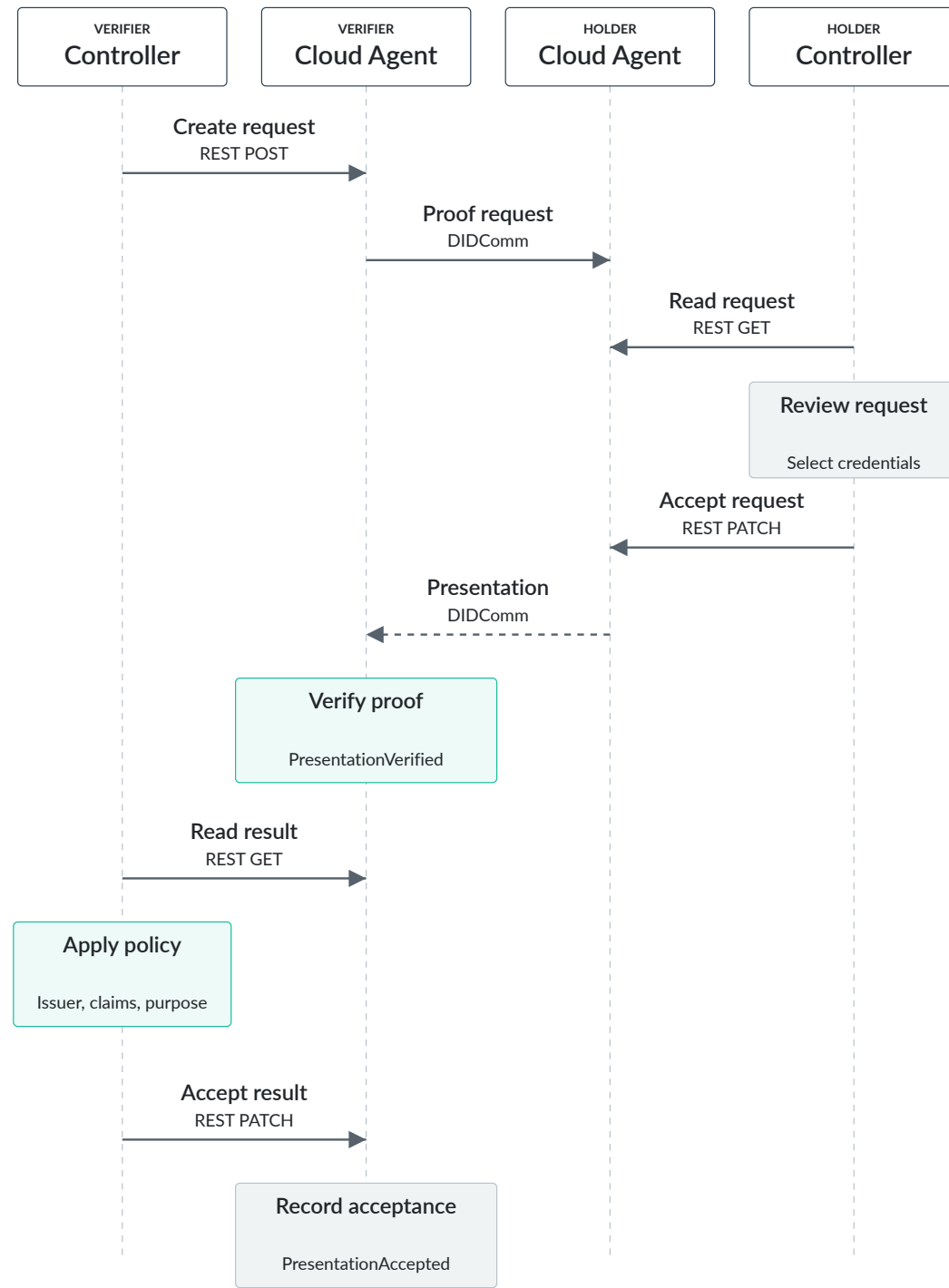
1. The verifier controller calls `POST /present-proof/presentations` on its Cloud Agent. The request identifies the DIDComm connection and describes the proof the verifier wants.
2. The holder controller reads pending presentation records from `GET /present-proof/presentations`.
3. The holder controller accepts a request with `PATCH /present-proof/presentations/{id}` using `action: "request-accept"`. For JWT and SD-JWT credentials it supplies credential record IDs through `proofId`. For AnonCreds it supplies the credential proof mapping under `anoncredPresentationRequest`.
4. The holder Cloud Agent generates the presentation and sends it to the verifier Cloud Agent.
5. The verifier Cloud Agent verifies the presentation. A successful verifier-side record moves through `PresentationReceived` and `PresentationVerified`.
6. The verifier controller accepts the verified presentation with `PATCH /present-proof/presentations/{id}` using `action: "presentation-accept"`, or rejects it in application logic.

The exact request shape depends on the credential format. JWT and SD-JWT presentation requests can include `options.challenge` and `options.domain` so the holder signs material bound to the verifier's request. AnonCreds presentation requests use an `anoncredPresentationRequest` object with a nonce, requested attributes, requested predicates, restrictions, and optional non-revocation intervals.

The DIDComm Present Proof 3.0 protocol is format-neutral. It carries a presentation request and a presentation, but the credential format decides which cryptographic checks run.

## Presenting proof and accepting the result

The verifier controller applies policy after the agent verifies the proof



REST calls connect each controller to its agent. DIDComm connects the two agents.

Figure 1: The verifier supplies request binding for the chosen format: challenge and domain for JWT or key-bound SD-JWT, or an AnonCreds nonce. The holder controller selects credentials and calls request-accept. After PresentationVerified, the verifier controller checks its policy and calls presentation-accept only if the checks pass. A policy rejection stops the application action. This diagram follows the successful path and omits REST responses.

## Verification and acceptance

Cryptographic verification and verifier acceptance are separate decisions.

The verifier Cloud Agent can check whether the presentation is well formed for its format, bound to the verifier request, and backed by the expected cryptographic material. For JWT-VC, the verifier checks JWT signatures and DID-resolved keys. For SD-JWT-VC, the verifier checks the issuer signature, disclosed claim digests, and holder key binding when the credential carries a **cnf** key. For AnonCreds, the verifier checks equality proofs, predicate proofs, aggregate proofs, and any non-revocation proofs requested by the verifier.

The verifier controller still decides whether the proof should be accepted for the business action. The W3C Verifiable Credentials Data Model 2.0 separates verification from validation: verification checks the securing mechanism, and validation applies business rules to a specific use of the credential.

After Cloud Agent reports a verified presentation, the verifier controller should check:

1. The verifier trusts the issuer DID for the credential type and schema.
2. The credential uses the schema or credential definition named in the verifier's request.
3. The disclosed claims satisfy the verifier's policy.
4. The credential validity period and any status or revocation data fit the verifier's time of interest.
5. The verifier accepts the holder or presenter as authorized for this use case.

A valid proof can still fail acceptance. A venue verifier can receive a cryptographically valid age credential, reject it if the issuer is outside its trusted issuer list, and reject it if the revealed claim does not meet the venue's age rule.

## Direct credential verification

Cloud Agent exposes a direct verification endpoint at `POST /verification/credential`. Use this endpoint when verifier software has an encoded JWT credential and needs explicit check results outside a DIDComm present-proof exchange.

The endpoint accepts a list of encoded credentials and verification checks. The current service implementation includes checks such as signature verification, algorithm verification, issuer identification, expiration, not-before, audience, schema validation, subject schema validation, and semantic parsing of claims.

The direct verification endpoint does not replace a presentation request. It verifies credential data supplied to the endpoint. It does not prove that the current holder controls the credential subject's key for a verifier challenge, and it does not decide whether an issuer or claim should be accepted by the application.

## Verification policies

Identus uses the term **verification policy** for stored verifier rules. The Cloud Agent source exposes `/verification/policies` endpoints to create, update, fetch, list, and delete those policies. The current policy model contains a **CredentialSchemaAndTrustedIssuersConstraint** with:

1. **schemaId**, the schema the verifier expects.
2. **trustedIssuers**, the issuer DIDs the verifier accepts for that schema.

The endpoint description in the Cloud Agent source says these policies apply to W3C Verifiable Credentials in JWT format and currently use **schemaId** and **trustedIssuers** constraints.

A verifier controller can use a verification policy before sending a presentation request, after receiving a verified presentation, or both. Before the request, the policy can help the verifier ask for the schema it accepts. After verification, the policy can help the verifier reject a credential from an untrusted issuer. The Cloud Agent's cryptographic verification result should feed into this policy decision; it should not be treated as the whole decision.

If a deployment uses an external trust registry, keep the registry lookup separate from proof verification. The verifier or its controller queries the registry, resolves the trusted issuer set for the requested schema, and passes that result into its policy decision.

## Selective disclosure

Selective disclosure lets a holder reveal only the claims needed for a verifier request. Identus supports selective-disclosure presentations through SD-JWT and AnonCreds, but the two formats use different mechanisms.

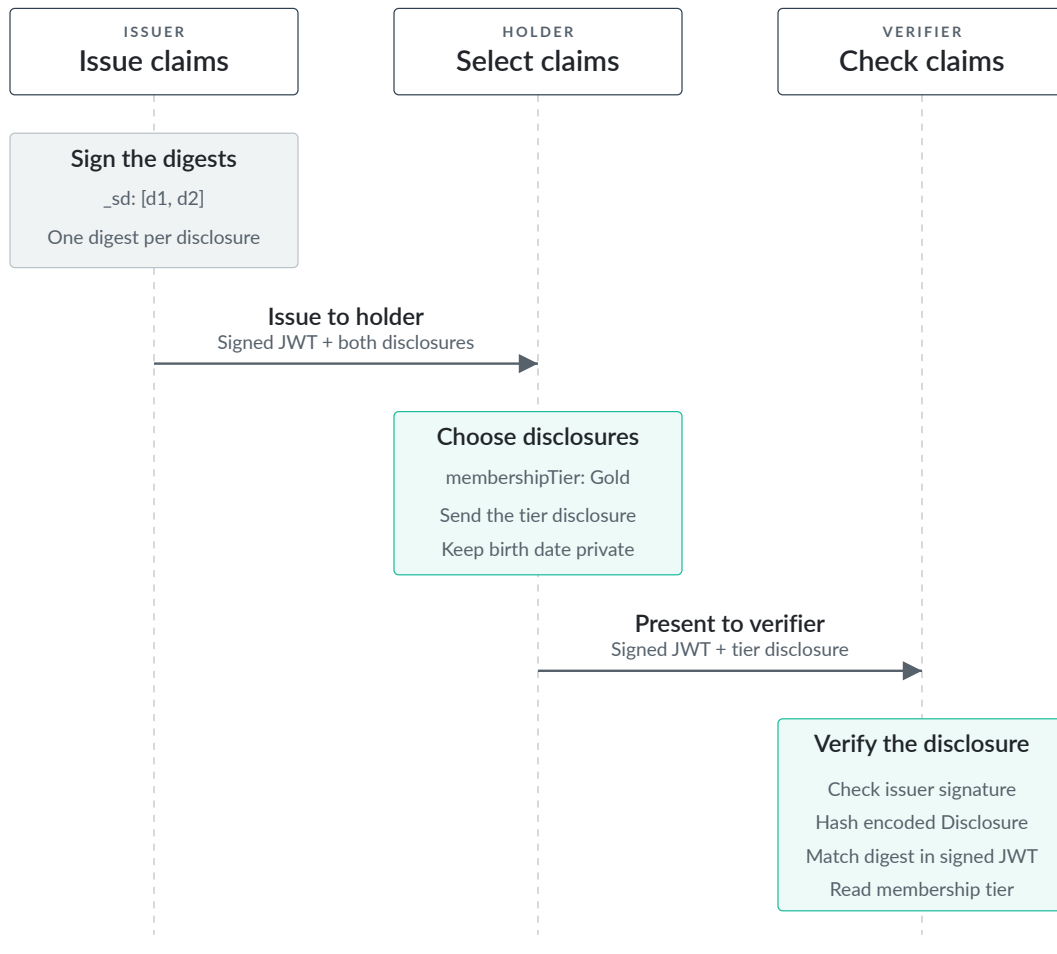
Plain JWT-VC presentation exposes the credential payload needed for verifier checks. The format works for use cases where the verifier needs the full credential, such as a boarding gate checking a complete boarding pass. It fits poorly when the verifier needs one attribute or one predicate.

SD-JWT uses salted hashes. The issuer signs a JWT payload that contains digests for selectively disclosable claims. During presentation, the holder sends the issuer-signed SD-JWT plus the disclosures selected for that verifier. The verifier hashes each disclosed value with its salt and checks that the digest appears in the signed payload. SD-JWT gives selective disclosure for JSON claims; it is not a zero-knowledge predicate proof system.

Identus adds one key-binding detail for SD-JWT presentations. If the holder accepts an SD-JWT credential offer with a **keyId**, the issued credential can include a **cnf** key binding. A later holder presentation can then sign the verifier's **challenge** and **domain**. If the SD-JWT credential has no **cnf** key, the Identus Present Proof guide says the holder cannot create a presentation that signs the verifier's **challenge** and **domain**.

## Selective disclosure with an SD-JWT

The holder selects which disclosures to send with the signed JWT



The verifier receives the selected value and its salt; the other disclosure stays with the holder.

Figure 2: This example uses two selectively disclosable object properties. Each Disclosure encodes [salt, name, value] as base64url. The verifier hashes that encoded string and compares the base64url digest with the issuer-signed payload, as specified in RFC 9901, Section 4.2.3. The labels d1 and d2 stand for full digests. A credential with cnf can support holder key binding to the verifier request.

AnonCreds uses zero-knowledge proofs. The verifier's presentation request can ask for revealed attributes, predicates such as `age >= 18`, restrictions such as `schema_id` or `cred_def_id`, and non-revocation intervals. The holder selects credentials that satisfy the request and creates a proof. The verifier resolves the required schemas, credential definitions, and revocation data, then verifies the presentation.

AnonCreds lets the holder prove a predicate without revealing the raw attribute. For age verification, a government issuer can issue a credential containing a date-derived age

## *Verification*

attribute. An age-restricted venue can request an AnonCreds predicate for `age >= 21`. The holder presents a proof that satisfies the predicate, and the verifier checks the proof, issuer restriction, credential definition, and revocation interval without receiving the holder's full date of birth.

Selective disclosure does not remove verifier policy. The verifier still checks issuer trust, schema fit, credential status, request binding, and local acceptance rules for the disclosed claims or predicates.

## **Section IV - Deploy**

# Installation - Production Environment

## Scope

Section 2 starts two local Cloud Agent instances with a development PRISM Node. This chapter keeps the same learning path and moves it toward a production-style **preprod** deployment. The goal is to show the service boundaries a developer must understand before a real issuer or verifier service depends on Identus.

The examples in this chapter are preprod scaffolding for operator learning. They show how to copy the local Docker configuration, pin current component versions, expose public Cloud Agent URLs, protect service ports, attach PRISM Node to Cardano services, and separate tutorial shortcuts from production requirements.

Run this chapter on Cardano **preprod** first. Move to **mainnet** after the deployment passes the health, wallet, DB Sync, DID publication, and backup checks at the end of the chapter.

## Version Selection

Use Identus platform release notes as the first compatibility source. At the time this chapter was checked on June 14, 2026, the latest Identus Platform release was **v2.16**. That release lists Cloud Agent 2.1.0, Mediator 1.2.0, NeoPRISM 0.6.2, and SDK-TS 7.0.0.

The Cloud Agent component repository has a newer component release, **v2.2.0**. That release adds VDR driver and NeoPRISM backend work. Treat it as a component release that requires compatibility testing against the platform pin. The Cloud Agent README warns that untested Cloud Agent and PRISM Node image pairs can fail compatibility checks.

This chapter uses these pins:

```
AGENT_VERSION=2.1.0
PRISM_NODE_VERSION=2.6.1
CARDANO_WALLET_TAG=v2026-05-11
CARDANO_DB_SYNC_VERSION=13.7.1.0
```

**AGENT\_VERSION** follows the latest platform release. **PRISM\_NODE\_VERSION** follows the latest PRISM Node release checked for this chapter, **v2.6.1**. If you change either Identus image, rerun the full check list at the end of the chapter.

The Cardano Wallet release **v2026-05-11** is paired by its release notes with **cardano-node 11.0.1**. The latest Cardano DB Sync release checked for this chapter was **13.7.1.0**.

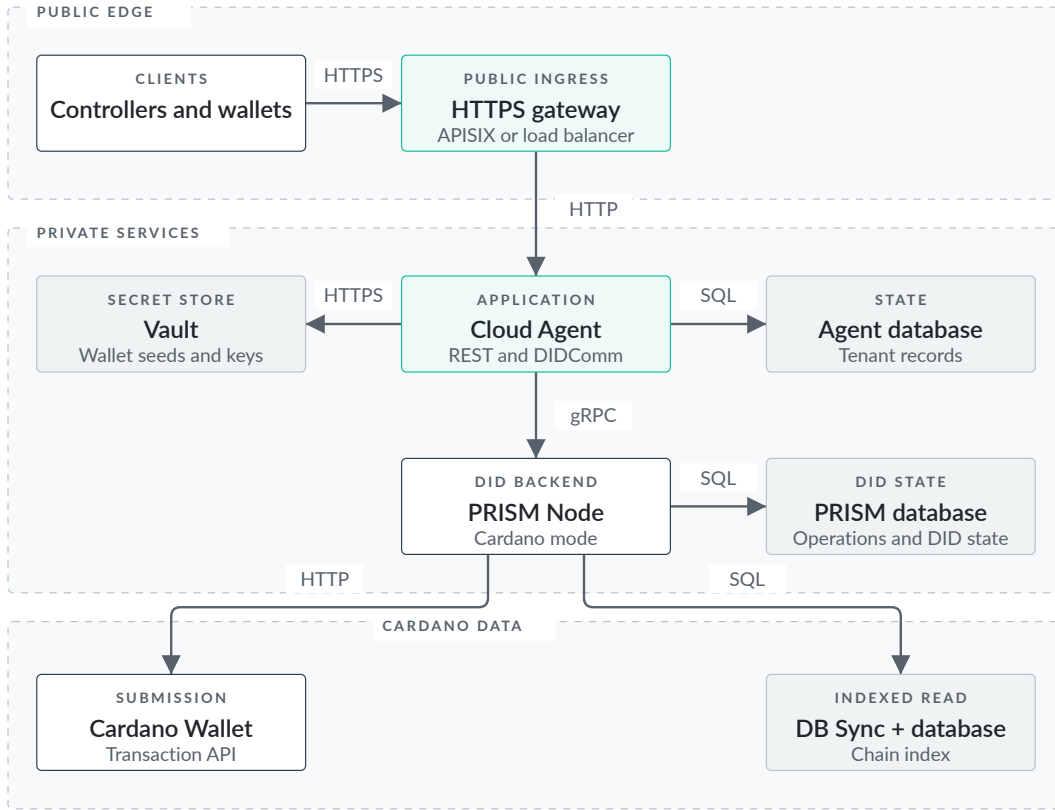
## Deployment Model

A production Identus deployment has several actors and services:

- The controller application calls the Cloud Agent REST API and receives webhooks.
- The Cloud Agent manages tenant state, wallets, DIDs, DIDComm V2 messages, credential issuance, credential verification, credential storage, and status list publication.
- PostgreSQL stores Cloud Agent state. PRISM Node and Cardano DB Sync need their own PostgreSQL databases.
- Vault stores wallet seeds and secret material when `SECRET_STORAGE_BACKEND=vault`.
- The DID node backend publishes and resolves `did:prism` operations. Current Cloud Agent configuration can use PRISM Node, NeoPRISM, or other VDR drivers depending on the selected driver flags.
- PRISM Node acts as a level-2 node over Cardano. With `NODE_LEDGER=cardano`, it uses Cardano Wallet to submit transactions and Cardano DB Sync to read blocks.
- Cardano Wallet connects to a Cardano node through the node socket and exposes an HTTP API to PRISM Node.
- Cardano DB Sync follows the same Cardano node and indexes blocks into PostgreSQL for PRISM Node.

## Production service and network boundaries

Configured example with one public ingress point



Only the gateway accepts public traffic in this configured example.

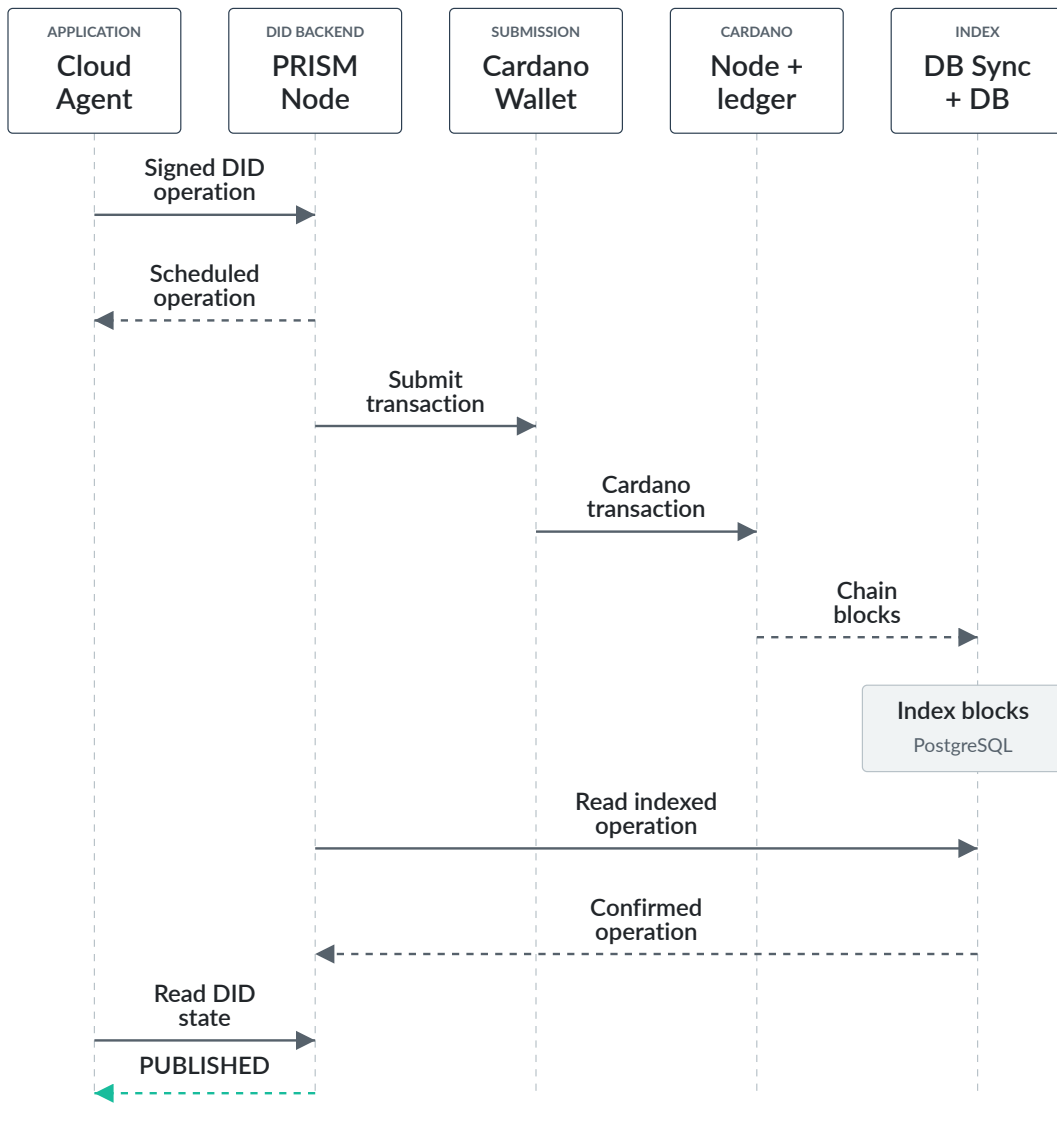
Figure 1: This configured example exposes only the HTTPS gateway. The Cloud Agent and each data, secret, and DID backend service stay on private networks.

For a `did:prism` publication path:

1. The issuer controller asks the Cloud Agent to create, update, or deactivate a `did:prism` DID.
2. The Cloud Agent uses the wallet seed and stored derivation path to reconstruct key material for the DID operation.
3. The Cloud Agent signs the operation and sends it to the configured DID node backend.
4. PRISM Node receives the signed operation, schedules it, uses Cardano Wallet to submit a Cardano transaction, and reads indexed blocks through Cardano DB Sync.
5. The Cloud Agent or resolver reads the DID state after the operation reaches the configured confirmation depth.

## DID publication and indexed readback

Asynchronous publication through PRISM Node on Cardano



PUBLISHED follows the configured confirmation path and indexed readback.

Figure 2: Publication is asynchronous. PRISM Node submits through Cardano Wallet and reads the confirmed operation from the DB Sync index before the Cloud Agent reports the DID as published.

Credential verification is a different decision path. Verifier software performs technical checks such as proof verification, DID resolution, key use, credential status, and presentation binding. The relying party then applies policy checks such as accepted issuer DIDs, schemas, credential types, trust registry entries, or business rules.

## Hardware and Data Requirements

Use live workload and Cardano service requirements for production sizing. The Cloud Agent itself is modest compared with the Cardano services. Production sizing depends on request rate, number of tenants, webhook volume, credential issuance volume, verification volume, database latency, and secret storage latency.

Cardano DB Sync is the largest resource consumer in this stack. The official DB Sync system requirements page listed these mainnet requirements when checked for this chapter:

- Linux host.
- At least 64 GB RAM.
- At least 4 CPU cores.
- SSD storage with 60k IOPS or better.
- At least 700 GB disk.

The same page listed current mainnet storage examples of about 203 GB for the Cardano node database, about 10 GB for DB Sync ledger state, and about 438 GB for the DB Sync PostgreSQL database. It listed mainnet memory examples of about 24 GB for `cardano-node` and about 21 GB RSS for `cardano-db-sync`.

`preprod` is much smaller. The DB Sync page listed about 12 GB for the Cardano node database, about 2 GB for DB Sync ledger state, about 16 GB for the DB Sync PostgreSQL database, about 5.5 GB RAM for `cardano-node`, and about 3.5 GB RSS for `cardano-db-sync`.

Run DB Sync and its PostgreSQL database close to each other. The DB Sync documentation recommends colocating them to reduce database traffic latency during synchronization. If you split services across machines, use a private network with low latency and monitor database IOPS.

## Prepare the Base Identus Configuration

Clone the current Cloud Agent repository and copy the local infrastructure directory into a `preprod` directory:

```
git clone https://github.com/hyperledger-identus/cloud-agent identus-cloud-agent
cd identus-cloud-agent

cp -R infrastructure/local infrastructure/preprod
cp infrastructure/shared/docker-compose.yml infrastructure/shared/docker-compose-preprod.yml
```

Edit `infrastructure/preprod/run.sh` so the `preprod` script uses the copied Compose file:

```
PORT=${PORT} NETWORK=${NETWORK} DOCKERHOST=${DOCKERHOST} docker compose \
  -p ${NAME} \
- -f ${SCRIPT_DIR}/../shared/docker-compose.yml \
+ -f ${SCRIPT_DIR}/../shared/docker-compose-preprod.yml \
  --env-file ${ENV_FILE} ${DEBUG} up ${BACKGROUND} ${WAIT}
```

If your checkout still references the old Cloud Agent registry, update the image name in `infrastructure/shared/docker-compose-preprod.yml`:

```
cloud-agent:
- image: ghcr.io/hyperledger/identus-cloud-agent:${AGENT_VERSION}
+ image: docker.io/hyperledgeridentus/identus-cloud-agent:${AGENT_VERSION:-latest}
```

Keep PostgreSQL off the host network. Add a private administration path when operators need direct database access:

```
db:
- ports:
-   - "127.0.0.1:${PG_PORT:-5432}:5432"
+ # Keep PostgreSQL inside the Docker network for this tutorial.
+ # Add a host binding for a private administration path.
+ # ports:
+ #   - "127.0.0.1:${PG_PORT:-5432}:5432"
```

Make the Cloud Agent environment explicit. The current Cloud Agent configuration supports `NODE_BACKEND`, PRISM Node connection settings, NeoPRISM connection settings, and VDR driver flags:

```
cloud-agent:
  environment:
    POLLUX_STATUS_LIST_REGISTRY_PUBLIC_URL: ${POLLUX_STATUS_LIST_REGISTRY_PUBLIC_URL}
    DIDCOMM_SERVICE_URL: ${DIDCOMM_SERVICE_URL}
    REST_SERVICE_URL: ${REST_SERVICE_URL}
    PRISM_NODE_HOST: ${PRISM_NODE_HOST:-prism-node}
    PRISM_NODE_PORT: ${PRISM_NODE_PORT:-50053}
+   PRISM_NODE_USE_PLAIN_TEXT: ${PRISM_NODE_USE_PLAIN_TEXT:-true}
+   NODE_BACKEND: ${NODE_BACKEND:-prism-node}
+   NEOPRISM_BASE_URL: ${NEOPRISM_BASE_URL}
    VAULT_ADDR: ${VAULT_ADDR:-http://vault-server:8200}
    VAULT_TOKEN: ${VAULT_TOKEN:-root}
-   SECRET_STORAGE_BACKEND: postgres
-   DEV_MODE: true
+   SECRET_STORAGE_BACKEND: ${SECRET_STORAGE_BACKEND:-postgres}
+   DEV_MODE: ${DEV_MODE:-true}
+   VDR_PRISM_NODE_DRIVER_ENABLED: ${VDR_PRISM_NODE_DRIVER_ENABLED:-false}
```

```
+ VDR_NEOPRISM_DRIVER_ENABLED: ${VDR_NEOPRISM_DRIVER_ENABLED:-false}
  ADMIN_TOKEN:
  API_KEY_SALT:
  API_KEY_ENABLED:
  API_KEY_AUTHENTICATE_AS_DEFAULT_USER:
  API_KEY_AUTO_PROVISIONING:
```

Use PRISM Node for this chapter:

```
NODE_BACKEND=prism-node
PRISM_NODE_HOST=prism-node
PRISM_NODE_PORT=50053
PRISM_NODE_USE_PLAIN_TEXT=true
```

New deployments should evaluate NeoPRISM before mainnet. The current Cloud Agent VDR documentation marks the NeoPRISM driver as recommended for production and the PRISM Node driver as a legacy production option. This chapter keeps PRISM Node so the tutorial can show the Cardano Wallet and DB Sync boundary in detail.

## Create the Preprod Environment File

Create `infrastructure/preprod/.env-preprod`:

```
cat > ./infrastructure/preprod/.env-preprod <<EOF
### Identus image pins
AGENT_VERSION=2.1.0
PRISM_NODE_VERSION=2.6.1

### Docker project and public URLs
PORT=8000
NETWORK=identus-preprod
DOCKERHOST=agent.example.test
REST_SERVICE_URL=https://agent.example.test/cloud-agent
DIDCOMM_SERVICE_URL=https://agent.example.test/didcomm
POLLUX_STATUS_LIST_REGISTRY_PUBLIC_URL=https://agent.example.test/cloud-agent

### Cloud Agent access control
API_KEY_ENABLED=true
API_KEY_AUTO_PROVISIONING=false
API_KEY_AUTHENTICATE_AS_DEFAULT_USER=false
ADMIN_TOKEN=replace-with-admin-token
API_KEY_SALT=replace-with-long-random-salt
DEFAULT_WALLET_ENABLED=false
```

```
### Secret storage
SECRET_STORAGE_BACKEND=postgres
VAULT_ADDR=http://vault-server:8200
VAULT_USE_SEMANTIC_PATH=true
VAULT_DEV_ROOT_TOKEN_ID=replace-for-lab
VAULT_TOKEN=replace-for-lab

### Databases
AGENT_DB_USER=postgres
AGENT_DB_PASSWORD=replace-with-agent-db-password
PGADMIN_DEFAULT_PASSWORD=replace-with-pgadmin-password

### DID node backend
NODE_BACKEND=prism-node
PRISM_NODE_HOST=prism-node
PRISM_NODE_PORT=50053
PRISM_NODE_USE_PLAIN_TEXT=true
VDR_PRISM_NODE_DRIVER_ENABLED=false
VDR_NEOPRISM_DRIVER_ENABLED=false

### PRISM Node Cardano mode
NODE_LEDGER=cardano
NODE_CARDANO_NETWORK=testnet
NODE_CARDANO_WALLET_ID=replace-after-wallet-create
NODE_CARDANO_WALLET_PASSPHRASE=replace-after-wallet-create
NODE_CARDANO_PAYMENT_ADDRESS=replace-after-wallet-create
NODE_CARDANO_WALLET_API_HOST=cardano-wallet
NODE_CARDANO_WALLET_API_PORT=8090
NODE_CARDANO_DB_SYNC_HOST=cardano-db-sync-postgres:5432
NODE_CARDANO_DB_SYNC_DATABASE=cexplorer
NODE_CARDANO_DB_SYNC_USERNAME=postgres
NODE_CARDANO_DB_SYNC_PASSWORD=replace-with-db-sync-password

### Cardano services
CARDANO_NETWORK=preprod
CARDANO_WALLET_TAG=v2026-05-11
CARDANO_DB_SYNC_VERSION=13.7.1.0
NODE_DB=$PWD/cardano/node-db
WALLET_DB=$PWD/cardano/wallet-db
NODE_CONFIGS=$PWD/cardano/configs
NODE_SOCKET_DIR=$PWD/cardano/ipc
NODE_SOCKET_NAME=node.socket
WALLET_PORT=127.0.0.1:8090

### Keycloak, disabled until the Keycloak section is completed
KEYCLOAK_ENABLED=false
```

```
KEYCLOAK_URL=https://iam.example.test
KEYCLOAK_REALM=identus
KEYCLOAK_CLIENT_ID=cloud-agent
KEYCLOAK_CLIENT_SECRET=replace-when-keycloak-enabled
KEYCLOAK_UMA_AUTO_UPGRADE_RPT=false
EOF
```

`SECRET_STORAGE_BACKEND=postgres` keeps the lab small. The Cloud Agent secret storage documentation states that PostgreSQL storage stores secrets in plaintext and is unsuitable for production. Before issuer traffic reaches this stack, set `SECRET_STORAGE_BACKEND=vault` and configure Vault with a production server, token policy, or AppRole.

## Production-Style Compose Example

The `infrastructure/shared/docker-compose-preprod.yml` example collects the earlier edits into one file. It preserves the full configuration view from the original tutorial and keeps the production boundaries visible.

This file is still a preprod lab scaffold. Replace the development Vault server, default database credentials, APISIX HTTP listener, and DB Sync service definition before mainnet. Keep the file under source control so developers can compare the local stack with the production-style stack.

```
---
version: "3.8"

services:
  db:
    image: postgres:13
    environment:
      POSTGRES_MULTIPLE_DATABASES: "pollux,connect,agent,node_db"
      POSTGRES_USER: ${AGENT_DB_USER:-postgres}
      POSTGRES_PASSWORD: ${AGENT_DB_PASSWORD}
    volumes:
      - pg_data_db:/var/lib/postgresql/data
      - ./postgres/init-script.sh:/docker-entrypoint-initdb.d/init-script.sh
      - ./postgres/max_conns.sql:/docker-entrypoint-initdb.d/max_conns.sql
    # Keep the database inside the Docker network.
    # ports:
    #   - "127.0.0.1:${PG_PORT:-5432}:5432"
    healthcheck:
      test: ["CMD", "pg_isready", "-U", "${AGENT_DB_USER:-postgres}", "-d", "agent"]
      interval: 10s
      timeout: 5s
      retries: 5
```

```
pgadmin:
  image: dpage/pgadmin4
  environment:
    PGADMIN_DEFAULT_EMAIL: ${PGADMIN_DEFAULT_EMAIL:-pgadmin4@pgadmin.org}
    PGADMIN_DEFAULT_PASSWORD: ${PGADMIN_DEFAULT_PASSWORD}
    PGADMIN_CONFIG_SERVER_MODE: "False"
  volumes:
    - pgadmin:/var/lib/pgadmin
  ports:
    - "127.0.0.1:${PGADMIN_PORT:-5050}:80"
  depends_on:
    db:
      condition: service_healthy
  profiles:
    - debug

vault-server:
  image: hashicorp/vault:1.15.6
  environment:
    VAULT_ADDR: "http://0.0.0.0:8200"
    VAULT_DEV_ROOT_TOKEN_ID: ${VAULT_DEV_ROOT_TOKEN_ID}
  command: server -dev -dev-root-token-id=${VAULT_DEV_ROOT_TOKEN_ID}
  cap_add:
    - IPC_LOCK
  healthcheck:
    test: ["CMD", "vault", "status"]
    interval: 10s
    timeout: 5s
    retries: 5

prism-node:
  image: ghcr.io/input-output-hk/prism-node:${PRISM_NODE_VERSION}
  environment:
    NODE_PSQL_HOST: db:5432
    NODE_PSQL_DATABASE: node_db
    NODE_PSQL_USERNAME: ${AGENT_DB_USER:-postgres}
    NODE_PSQL_PASSWORD: ${AGENT_DB_PASSWORD}
    NODE_LEDGER: ${NODE_LEDGER:-cardano}
    NODE_CARDANO_NETWORK: ${NODE_CARDANO_NETWORK:-testnet}
    NODE_CARDANO_WALLET_ID: ${NODE_CARDANO_WALLET_ID}
    NODE_CARDANO_WALLET_PASSPHRASE: ${NODE_CARDANO_WALLET_PASSPHRASE}
    NODE_CARDANO_PAYMENT_ADDRESS: ${NODE_CARDANO_PAYMENT_ADDRESS}
    NODE_CARDANO_WALLET_API_HOST: ${NODE_CARDANO_WALLET_API_HOST:-cardano-wallet}
    NODE_CARDANO_WALLET_API_PORT: ${NODE_CARDANO_WALLET_API_PORT:-8090}
    NODE_CARDANO_DB_SYNC_HOST: ${NODE_CARDANO_DB_SYNC_HOST}
```

```

    NODE_CARDANO_DB_SYNC_DATABASE: ${NODE_CARDANO_DB_SYNC_DATABASE:-cexplorer}
    NODE_CARDANO_DB_SYNC_USERNAME: ${NODE_CARDANO_DB_SYNC_USERNAME}
    NODE_CARDANO_DB_SYNC_PASSWORD: ${NODE_CARDANO_DB_SYNC_PASSWORD}
depends_on:
  db:
    condition: service_healthy
  cardano-wallet:
    condition: service_started
  cardano-db-sync-postgres:
    condition: service_started

cloud-agent:
  image: docker.io/hyperledgeridentus/identus-cloud-agent:${AGENT_VERSION:-latest}
  environment:
    POLLUX_DB_HOST: db
    POLLUX_DB_PORT: 5432
    POLLUX_DB_NAME: pollux
    POLLUX_DB_USER: ${AGENT_DB_USER:-postgres}
    POLLUX_DB_PASSWORD: ${AGENT_DB_PASSWORD}
    CONNECT_DB_HOST: db
    CONNECT_DB_PORT: 5432
    CONNECT_DB_NAME: connect
    CONNECT_DB_USER: ${AGENT_DB_USER:-postgres}
    CONNECT_DB_PASSWORD: ${AGENT_DB_PASSWORD}
    AGENT_DB_HOST: db
    AGENT_DB_PORT: 5432
    AGENT_DB_NAME: agent
    AGENT_DB_USER: ${AGENT_DB_USER:-postgres}
    AGENT_DB_PASSWORD: ${AGENT_DB_PASSWORD}
    POLLUX_STATUS_LIST_REGISTRY_PUBLIC_URL: ${POLLUX_STATUS_LIST_REGISTRY_PUBLIC_URL}
    DIDCOMM_SERVICE_URL: ${DIDCOMM_SERVICE_URL}
    REST_SERVICE_URL: ${REST_SERVICE_URL}
    PRISM_NODE_HOST: ${PRISM_NODE_HOST:-prism-node}
    PRISM_NODE_PORT: ${PRISM_NODE_PORT:-50053}
    PRISM_NODE_USE_PLAIN_TEXT: ${PRISM_NODE_USE_PLAIN_TEXT:-true}
    NODE_BACKEND: ${NODE_BACKEND:-prism-node}
    NEOPRISM_BASE_URL: ${NEOPRISM_BASE_URL}
    VAULT_ADDR: ${VAULT_ADDR:-http://vault-server:8200}
    VAULT_TOKEN: ${VAULT_TOKEN}
    VAULT_APPROLE_ROLE_ID: ${VAULT_APPROLE_ROLE_ID}
    VAULT_APPROLE_SECRET_ID: ${VAULT_APPROLE_SECRET_ID}
    VAULT_USE_SEMANTIC_PATH: ${VAULT_USE_SEMANTIC_PATH:-true}
    SECRET_STORAGE_BACKEND: ${SECRET_STORAGE_BACKEND:-postgres}
    DEV_MODE: ${DEV_MODE:-false}
    DEFAULT_WALLET_ENABLED: ${DEFAULT_WALLET_ENABLED:-false}
    DEFAULT_WALLET_SEED: ${DEFAULT_WALLET_SEED}
```

```
DEFAULT_WALLET_WEBHOOK_URL: ${DEFAULT_WALLET_WEBHOOK_URL}
DEFAULT_WALLET_WEBHOOK_API_KEY: ${DEFAULT_WALLET_WEBHOOK_API_KEY}
DEFAULT_WALLET_AUTH_API_KEY: ${DEFAULT_WALLET_AUTH_API_KEY}
GLOBAL_WEBHOOK_URL: ${GLOBAL_WEBHOOK_URL}
GLOBAL_WEBHOOK_API_KEY: ${GLOBAL_WEBHOOK_API_KEY}
WEBHOOK_PARALLELISM: ${WEBHOOK_PARALLELISM}
ADMIN_TOKEN: ${ADMIN_TOKEN}
API_KEY_SALT: ${API_KEY_SALT}
API_KEY_ENABLED: ${API_KEY_ENABLED:-true}
API_KEY_AUTHENTICATE_AS_DEFAULT_USER: ${API_KEY_AUTHENTICATE_AS_DEFAULT_USER:-false}
API_KEY_AUTO_PROVISIONING: ${API_KEY_AUTO_PROVISIONING:-false}
KEYCLOAK_ENABLED: ${KEYCLOAK_ENABLED:-false}
KEYCLOAK_URL: ${KEYCLOAK_URL}
KEYCLOAK_REALM: ${KEYCLOAK_REALM}
KEYCLOAK_CLIENT_ID: ${KEYCLOAK_CLIENT_ID}
KEYCLOAK_CLIENT_SECRET: ${KEYCLOAK_CLIENT_SECRET}
KEYCLOAK_UMA_AUTO_UPGRADE_RPT: ${KEYCLOAK_UMA_AUTO_UPGRADE_RPT:-false}
VDR_PRISM_NODE_DRIVER_ENABLED: ${VDR_PRISM_NODE_DRIVER_ENABLED:-false}
VDR_NEOPRISM_DRIVER_ENABLED: ${VDR_NEOPRISM_DRIVER_ENABLED:-false}
depends_on:
  db:
    condition: service_healthy
  prism-node:
    condition: service_started
  vault-server:
    condition: service_healthy
healthcheck:
  test: ["CMD", "curl", "-f", "http://cloud-agent:8085/_system/health"]
  interval: 30s
  timeout: 10s
  retries: 5
extra_hosts:
  - "host.docker.internal:host-gateway"

swagger-ui:
  image: swaggerapi/swagger-ui:v5.1.0
  environment:
    - 'URLS=[
      { name: "Cloud Agent", url: "/docs/cloud-agent/api/docs.yaml" }
    ]'
```

```
apisix:
  image: apache/apisix:2.15.0-alpine
  volumes:
    - ./apisix/conf/apisix.yaml:/usr/local/apisix/conf/apisix.yaml:ro
    - ./apisix/conf/config.yaml:/usr/local/apisix/conf/config.yaml:ro
```

```
ports:
  - "${PORT}:9080/tcp"
depends_on:
  - cloud-agent
  - swagger-ui

cardano-node:
  image: cardanofoundation/cardano-wallet:${CARDANO_WALLET_TAG}
  environment:
    CARDANO_NODE_SOCKET_PATH: /ipc/${NODE_SOCKET_NAME}
  volumes:
    - ${NODE_DB}:/data
    - ${NODE_SOCKET_DIR}:/ipc
    - ${NODE_CONFIGS}:/configs
  entrypoint: []
  command: >
    cardano-node run
      --topology /configs/cardano/${CARDANO_NETWORK}/topology.json
      --database-path /data
      --socket-path /ipc/${NODE_SOCKET_NAME}
      --config /configs/cardano/${CARDANO_NETWORK}/config.json
      +RTS -N -A16m -qg -qb -RTS
  restart: on-failure

cardano-wallet:
  image: cardanofoundation/cardano-wallet:${CARDANO_WALLET_TAG}
  volumes:
    - ${WALLET_DB}:/wallet-db
    - ${NODE_SOCKET_DIR}:/ipc
    - ${NODE_CONFIGS}:/configs
  ports:
    - "${WALLET_PORT}:8090"
  entrypoint: []
  command: >
    cardano-wallet serve
      --node-socket /ipc/${NODE_SOCKET_NAME}
      --database /wallet-db
      --listen-address 0.0.0.0
      --testnet /configs/cardano/${CARDANO_NETWORK}/byron-genesis.json
  depends_on:
    - cardano-node
  restart: on-failure

cardano-db-sync-postgres:
  image: postgres:14
  environment:
```

```
POSTGRES_USER: ${NODE_CARDANO_DB_SYNC_USERNAME:-postgres}
POSTGRES_PASSWORD: ${NODE_CARDANO_DB_SYNC_PASSWORD}
POSTGRES_DB: ${NODE_CARDANO_DB_SYNC_DATABASE:-cexplorer}
volumes:
  - cardano_db_sync_postgres:/var/lib/postgresql/data

cardano-db-sync:
  image: ghcr.io/intersectmbo/cardano-db-sync:${CARDANO_DB_SYNC_VERSION}
  depends_on:
    - cardano-node
    - cardano-db-sync-postgres
  volumes:
    - ${NODE_SOCKET_DIR}:/ipc
    - ${NODE_CONFIGS}:/configs
  environment:
    CARDANO_NODE_SOCKET_PATH: /ipc/${NODE_SOCKET_NAME}
    NETWORK: ${CARDANO_NETWORK}
    POSTGRES_HOST: cardano-db-sync-postgres
    POSTGRES_PORT: 5432
    POSTGRES_DB: ${NODE_CARDANO_DB_SYNC_DATABASE:-cexplorer}
    POSTGRES_USER: ${NODE_CARDANO_DB_SYNC_USERNAME:-postgres}
    POSTGRES_PASSWORD: ${NODE_CARDANO_DB_SYNC_PASSWORD}

volumes:
  pg_data_db:
  pgadmin:
  cardano_db_sync_postgres:
```

## Production Configuration and Security

Treat the preprod file as a working reference for placeholders and service boundaries. Commit the sample so developers can see every moving part. Load real values from your deployment system, CI secret store, Vault, or a sealed secret mechanism.

A production Cloud Agent configuration should make these decisions explicit:

- Image pins for Cloud Agent, PRISM Node or NeoPRISM, Cardano Wallet, Cardano node, and DB Sync.
- Public URLs for `REST_SERVICE_URL`, `DIDCOMM_SERVICE_URL`, and `POLLUX_STATUS_LIST_REGISTRY_PUBLIC`.
- Tenant model: default wallet disabled for multi-tenant deployments, API keys or Keycloak enabled, and a long random `ADMIN_TOKEN`.
- Secret backend: `SECRET_STORAGE_BACKEND=vault` for issuer and verifier deployments that keep wallet seeds.
- DID backend: PRISM Node for this tutorial path, or NeoPRISM after you validate the newer production driver in your target version.

- Cardano network wiring: `NODE_CARDANO_NETWORK=testnet` or `mainnet` for PRISM Node, and `CARDANO_NETWORK=preprod` or `mainnet` for Cardano node, Cardano Wallet, and DB Sync configuration.

The public URL values are part of protocol behavior. Holder wallets and mediator services use the DIDComm service endpoint to deliver DIDComm V2 messages. Verifier software or controller applications use the REST URL for API calls and status list access. If a load balancer rewrites the path or host, update the Cloud Agent URLs to match the externally reachable address.

Set `DEV_MODE=false` for deployments beyond the local tutorial. Rotate `ADMIN_TOKEN`, API keys, database passwords, Vault credentials, Keycloak client secrets, and wallet passphrases through the same process used for other production credentials. Store real wallet seeds, Cardano mnemonics, and Keycloak admin credentials in the production secret system.

## Docker and PostgreSQL Hardening

The Compose file keeps the original tutorial shape so a developer can inspect all services. Production operators should reduce the Docker surface area.

Keep PostgreSQL ports off public interfaces. The Cloud Agent database, PRISM Node database, and DB Sync database can share a managed PostgreSQL cluster. Each service should use a separate database, separate credentials, and a backup policy that matches its recovery needs. DB Sync stores chain index data that can be rebuilt or restored from snapshots. Cloud Agent and PRISM Node databases hold application state that should be backed up and restore-tested.

Replace default `postgres` passwords before the first non-local run. The tutorial uses `POSTGRES_MULTIPLE_DATABASES` for convenience; a production deployment should create databases and users through migrations, infrastructure code, or managed database provisioning.

Docker Compose secrets mount files under `/run/secrets/<name>` inside a container. Images such as PostgreSQL support the `_FILE` convention for some secret values. Use that pattern where the image supports it:

```
secrets:
  agent_db_password:
    file: ./config/secrets/agent_db_password

services:
  db:
    image: postgres:13
    secrets:
      - agent_db_password
    environment:
      POSTGRES_PASSWORD_FILE: /run/secrets/agent_db_password
```

The Cloud Agent reads its database, API, Vault, and Keycloak values from environment variables. Inject those values through the orchestrator or deployment platform. Compose secrets for Cloud Agent variables require an entrypoint wrapper that reads secret files and exports the expected variable names.

Set log rotation for long-running containers. Cardano node, Cardano Wallet, and DB Sync produce continuous logs during synchronization. The example later in this chapter sets `json-file` size limits for the Cardano services; carry the same policy to Cloud Agent, PRISM Node, APISIX, Vault, and PostgreSQL when Compose is used beyond a lab.

## SSL and Reverse Proxy

Expose the Cloud Agent through HTTPS. The example APISIX service listens on HTTP port 9080 so the lab remains simple. For production, terminate TLS at APISIX, a load balancer, or another reverse proxy, then forward to the internal Cloud Agent and DIDComm routes.

Use a public route plan before creating DIDs or issuing credentials:

```
https://agent.example.test/cloud-agent    -> Cloud Agent REST API
https://agent.example.test/didcomm        -> Cloud Agent DIDComm endpoint
https://agent.example.test/apidocs        -> Swagger UI, private or disabled
https://iam.example.test/realms/...       -> Keycloak OIDC and UMA endpoints
```

If APISIX terminates TLS, configure TLS 1.2 and TLS 1.3 at the gateway level or on each SNI-specific SSL resource:

```
apisix:
  ssl:
    ssl_protocols: TLSv1.2 TLSv1.3
```

Bind the APISIX admin API to a private network. If your deployment exposes Swagger UI, protect it with network controls or authentication. The OpenAPI route is useful for developer onboarding and gives attackers a complete API map.

Keycloak needs a separate proxy configuration. Keycloak production docs require HTTPS for sensitive authentication traffic and recommend a reverse proxy or load balancer.

Proxy the Keycloak application port, usually 8443 or 8080 when HTTP is enabled behind the proxy. Keep the management port 9000 internal.

Expose the public OIDC and static paths needed by clients, such as `/realms/`, `/resources/`, and `/.well-known/`. Keep `/admin/`, `/metrics`, and `/health` on an internal administration path. Configure `proxy-headers` and trusted proxy addresses so Keycloak accepts forwarded host and scheme values from trusted proxies.

## Key Management with HashiCorp Vault

The Cloud Agent creates, stores, and uses wallet seed material for DID operations. A tenant wallet seed lets the agent derive DID keys again after restart or redeploy. Losing it can make existing DIDs unusable for future updates, deactivation, or issuance flows that depend on the same keys.

Set the production backend to Vault:

```
SECRET_STORAGE_BACKEND=vault
VAULT_ADDR=https://vault.example.internal:8200
VAULT_USE_SEMANTIC_PATH=true
```

Reserve `VAULT_TOKEN` for a lab or break-glass workflow. For automated deployment, prefer `AppRole`:

```
VAULT_APPROLE_ROLE_ID=replace-with-role-id
VAULT_APPROLE_SECRET_ID=replace-with-secret-id
```

The Cloud Agent expects permissions under `/secret/*` for the tutorial mount and policy design. A minimal policy for that path is:

```
path "secret/*" {
  capabilities = ["create", "read", "update", "patch", "delete", "list"]
}
```

Vault stores Cloud Agent secrets under wallet-scoped paths such as `/secret/<wallet-id>/seed`, peer DID key paths, and generic secret paths. Back up Vault storage, test restore, and document the unseal or recovery-key procedure. A development Vault server started with `server -dev` is lab storage. HashiCorp's production hardening guidance calls out TLS, unprivileged runtime users, memory locking or encrypted swap decisions, storage separation, and restricted network paths.

## Multi-Tenant Operation

The Cloud Agent tenant model separates administrator actions from tenant actions. The administrator manages wallets, entities, API keys, and optional Keycloak permissions. The tenant uses the Cloud Agent for SSI actions inside the wallet assigned to that tenant.

Use these Cloud Agent variables for basic multi-tenancy:

```
ADMIN_TOKEN=replace-with-admin-token
API_KEY_ENABLED=true
API_KEY_AUTO_PROVISIONING=false
API_KEY_AUTHENTICATE_AS_DEFAULT_USER=false
DEFAULT_WALLET_ENABLED=false
```

## API key tenant provisioning

Manual onboarding when automatic provisioning is disabled

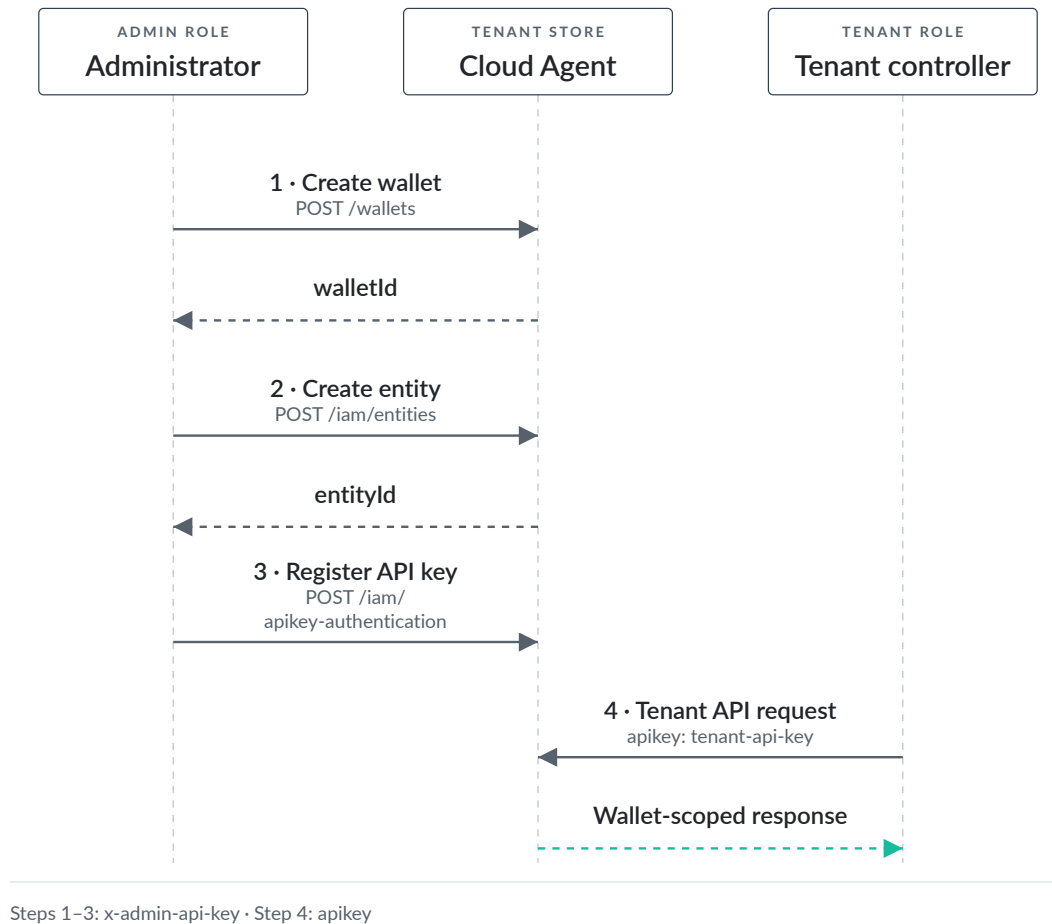


Figure 3: With `API_KEY_AUTO_PROVISIONING=false`, the administrator creates the wallet, entity, and API key. The tenant API key selects the entity's assigned wallet.

With those settings, the Cloud Agent starts with an empty tenant wallet set. The administrator creates a wallet, creates an entity tied to that wallet, and registers an API key for that entity:

```
curl -X POST "https://agent.example.test/cloud-agent/wallets" \
-H "x-admin-api-key: $ADMIN_TOKEN" \
-H "Content-Type: application/json" \
-d '{
  "name": "issuer-tenant-a"
}'
```

```
curl -X POST "https://agent.example.test/cloud-agent/iam/entities" \  
-H "x-admin-api-key: $ADMIN_TOKEN" \  
-H "Content-Type: application/json" \  
-d '{  
  "name": "tenant-a",  
  "walletId": "replace-with-wallet-id"  
'
```

```
curl -X POST "https://agent.example.test/cloud-agent/iam/apikey-authentication" \  
-H "x-admin-api-key: $ADMIN_TOKEN" \  
-H "Content-Type: application/json" \  
-d '{  
  "entityId": "replace-with-entity-id",  
  "apiKey": "replace-with-tenant-api-key"  
'
```

The tenant uses the assigned API key in the `apikey` header:

```
curl "https://agent.example.test/cloud-agent/did-registrar/dids" \  
-H "apikey: replace-with-tenant-api-key" \  
-H "Accept: application/json"
```

The response is scoped to the tenant wallet. A tenant that issues credentials from one wallet gains access to that tenant's DIDs, credentials, connections, and verification records.

## Keycloak External IAM

Use Keycloak when tenants should authenticate through OIDC and receive wallet permissions through UMA. This replaces static Cloud Agent API keys with Keycloak-issued tokens for tenant access. In this model, the Cloud Agent still owns wallet resources. Keycloak owns user authentication and authorization tokens.

Configure Keycloak with a dedicated client for the Cloud Agent and enable the authorization services required for UMA. Then switch the Cloud Agent to Keycloak:

```
KEYCLOAK_ENABLED=true  
KEYCLOAK_URL=https://iam.example.test  
KEYCLOAK_REALM=identus  
KEYCLOAK_CLIENT_ID=cloud-agent  
KEYCLOAK_CLIENT_SECRET=replace-with-client-secret  
KEYCLOAK_UMA_AUTO_UPGRADE_RPT=false
```

In the Keycloak flow, the administrator creates a wallet in the Cloud Agent, registers a user in Keycloak, and grants that Keycloak subject permission to the wallet:

```
curl -X POST "https://agent.example.test/cloud-agent/wallets/replace-with-wallet-id/uma-permission" \
  -H "x-admin-api-key: $ADMIN_TOKEN" \
  -H "Content-Type: application/json" \
  -d '{
    "subject": "replace-with-keycloak-user-id"
  }'
```

The tenant obtains an OIDC access token from Keycloak, requests an UMA requesting party token with `grant_type=urn:ietf:params:oauth:grant-type:uma-ticket`, and calls the Cloud Agent with:

```
Authorization: Bearer replace-with-rpt
```

If `KEYCLOAK_UMA_AUTO_UPGRADE_RPT=true`, the Cloud Agent can accept the tenant's access token and perform the RPT upgrade path described in the Cloud Agent external IAM guide. Keep `false` until the controller application owns the token exchange and error handling.

## Keycloak wallet authorization

Controller-managed OIDC to UMA exchange

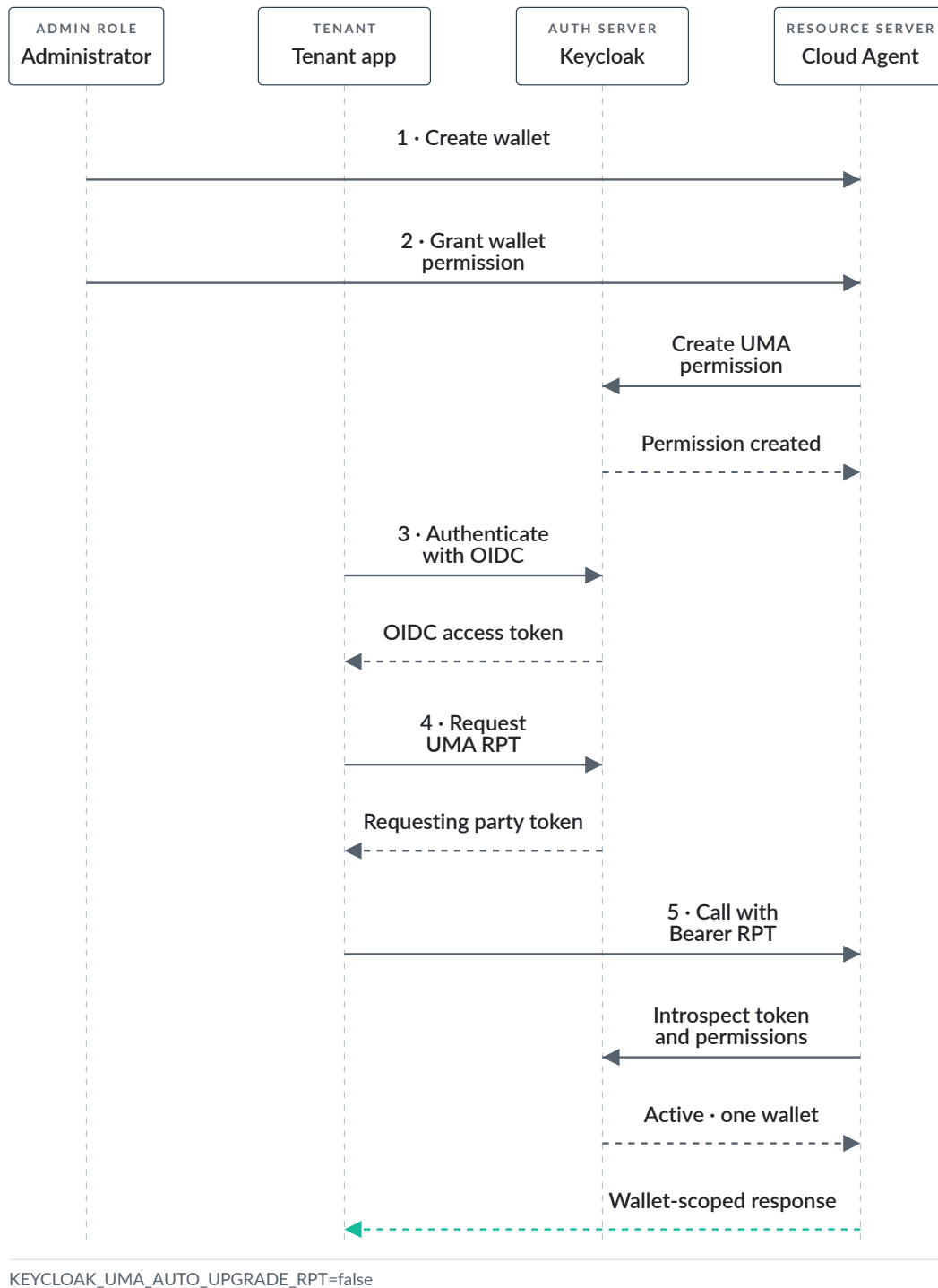


Figure 4: The administrator grants a Keycloak subject access to a Cloud Agent wallet. With automatic RPT upgrade disabled, the tenant controller obtains the RPT. The agent accepts one permitted wallet per tenant request.

## Cardano Wallet Operations

PRISM Node in Cardano mode has three external dependencies: its own PostgreSQL database, a Cardano Wallet backend, and Cardano DB Sync. The local Identus Compose file already creates the Node database through the shared PostgreSQL service. Add Cardano Wallet and a Cardano node to `infrastructure/shared/docker-compose-preprod.yml`.

Use separate variables for the PRISM Node network selector and the Cardano service configuration directory:

```
NODE_CARDANO_NETWORK=testnet
CARDANO_NETWORK=preprod
```

PRISM Node accepts `testnet` and `mainnet` for `NODE_CARDANO_NETWORK`. Cardano Wallet, Cardano node, and DB Sync use `preprod`, `preview`, or `mainnet` configuration names. This tutorial uses Cardano `preprod`, which is still a PRISM Node `testnet` deployment.

```
cardano-node:
  image: cardanofoundation/cardano-wallet:${CARDANO_WALLET_TAG}
  environment:
    CARDANO_NODE_SOCKET_PATH: /ipc/${NODE_SOCKET_NAME}
  volumes:
    - ${NODE_DB}:/data
    - ${NODE_SOCKET_DIR}:/ipc
    - ${NODE_CONFIGS}:/configs
  entrypoint: []
  command: >
    cardano-node run
      --topology /configs/cardano/${CARDANO_NETWORK}/topology.json
      --database-path /data
      --socket-path /ipc/${NODE_SOCKET_NAME}
      --config /configs/cardano/${CARDANO_NETWORK}/config.json
      +RTS -N -A16m -qg -qb -RTS
  restart: on-failure
  logging:
    driver: "json-file"
    options:
      compress: "true"
      max-file: "10"
      max-size: "50m"

cardano-wallet:
  image: cardanofoundation/cardano-wallet:${CARDANO_WALLET_TAG}
  volumes:
    - ${WALLET_DB}:/wallet-db
    - ${NODE_SOCKET_DIR}:/ipc
```

```
- ${NODE_CONFIGS}:/configs
ports:
- "${WALLET_PORT}:8090"
entrypoint: []
command: >
  cardano-wallet serve
  --node-socket /ipc/${NODE_SOCKET_NAME}
  --database /wallet-db
  --listen-address 0.0.0.0
  --testnet /configs/cardano/${CARDANO_NETWORK}/byron-genesis.json
depends_on:
- cardano-node
restart: on-failure
logging:
  driver: "json-file"
  options:
    compress: "true"
    max-file: "10"
    max-size: "50m"
```

For **mainnet**, set both production network variables and change the wallet command:

```
NODE_CARDANO_NETWORK=mainnet
CARDANO_NETWORK=mainnet
```

Change:

```
--testnet /configs/cardano/${CARDANO_NETWORK}/byron-genesis.json
```

to:

```
--mainnet
```

Bind the Cardano Wallet API to 127.0.0.1, a private administration network, or an internal service network.

Create or restore the wallet used by PRISM Node after Cardano Wallet reports a healthy network state:

```
curl http://127.0.0.1:8090/v2/network/information
```

Generate the mnemonic through your custody process or through the Cardano Wallet CLI on a secured operator machine:

```
cardano-wallet mnemonic generate --size 24
```

Restore the wallet through the local Cardano Wallet API. Replace every `word-*` placeholder before running the command:

```
curl -X POST "http://127.0.0.1:8090/v2/wallets" \
-H "Content-Type: application/json" \
-d '{
  "name": "prism-node-preprod",
  "mnemonic_sentence": [
    "word-01", "word-02", "word-03", "word-04", "word-05", "word-06",
    "word-07", "word-08", "word-09", "word-10", "word-11", "word-12",
    "word-13", "word-14", "word-15", "word-16", "word-17", "word-18",
    "word-19", "word-20", "word-21", "word-22", "word-23", "word-24"
  ],
  "passphrase": "replace-with-wallet-passphrase",
  "address_pool_gap": 20
}'
```

Record the returned wallet id as `NODE_CARDANO_WALLET_ID`. Store the wallet mnemonic and spending passphrase in the production secret system. Store the mnemonic away from `.env-preprod`, CI logs, shell history, and the repository.

Ask Cardano Wallet for an unused address and fund it:

```
curl "http://127.0.0.1:8090/v2/wallets/${NODE_CARDANO_WALLET_ID}/addresses?state=unused"
```

Set the first unused address as `NODE_CARDANO_PAYMENT_ADDRESS` after it is funded. On `preprod`, use the Cardano faucet. On `mainnet`, transfer real ADA from the treasury process assigned to the issuer or verifier operator. PRISM Node needs enough ADA for transaction fees and the 1 ADA output described by the PRISM Node deployment guide.

Add the documented PRISM Node Cardano variables to the existing `prism-node` service:

```
prism-node:
  image: ghcr.io/input-output-hk/prism-node:${PRISM_NODE_VERSION}
  environment:
    NODE_PSQL_HOST: db:5432
    NODE_PSQL_DATABASE: node_db
    NODE_PSQL_USERNAME: ${AGENT_DB_USER:-postgres}
    NODE_PSQL_PASSWORD: ${AGENT_DB_PASSWORD}
    NODE_LEDGER: ${NODE_LEDGER:-cardano}
    NODE_CARDANO_NETWORK: ${NODE_CARDANO_NETWORK:-testnet}
    NODE_CARDANO_WALLET_ID: ${NODE_CARDANO_WALLET_ID}
    NODE_CARDANO_WALLET_PASSPHRASE: ${NODE_CARDANO_WALLET_PASSPHRASE}
    NODE_CARDANO_PAYMENT_ADDRESS: ${NODE_CARDANO_PAYMENT_ADDRESS}
```

```
NODE_CARDANO_WALLET_API_HOST: ${NODE_CARDANO_WALLET_API_HOST:-cardano-wallet}  
NODE_CARDANO_WALLET_API_PORT: ${NODE_CARDANO_WALLET_API_PORT:-8090}  
NODE_CARDANO_DB_SYNC_HOST: ${NODE_CARDANO_DB_SYNC_HOST}  
NODE_CARDANO_DB_SYNC_DATABASE: ${NODE_CARDANO_DB_SYNC_DATABASE:-cexplorer}  
NODE_CARDANO_DB_SYNC_USERNAME: ${NODE_CARDANO_DB_SYNC_USERNAME}  
NODE_CARDANO_DB_SYNC_PASSWORD: ${NODE_CARDANO_DB_SYNC_PASSWORD}
```

The PRISM Node deployment guide states that `NODE_CARDANO_NETWORK` sets PRISM Node's network selector. Wallet and DB Sync use their own network configuration. Cardano node, Cardano Wallet, DB Sync, and PRISM Node must all point to the same Cardano network. A mixed setup can pass process startup and still fail to publish or resolve DID operations. In this tutorial, `NODE_CARDANO_NETWORK=testnet` plus `CARDANO_NETWORK=preprod` is consistent: PRISM Node runs in testnet mode, and the Cardano services use the pre-production testnet files.

## Cardano DB Sync Operations

DB Sync requires its own PostgreSQL database and a connection to the same Cardano node. Use the current DB Sync release package, its release notes, or your infrastructure module for the exact service definition. The service boundary must satisfy these PRISM Node variables:

```
NODE_CARDANO_DB_SYNC_HOST=cardano-db-sync-postgres:5432  
NODE_CARDANO_DB_SYNC_DATABASE=cexplorer  
NODE_CARDANO_DB_SYNC_USERNAME=postgres  
NODE_CARDANO_DB_SYNC_PASSWORD=replace-with-db-sync-password
```

A Compose-based lab normally contains:

```
cardano-db-sync-postgres:  
  image: postgres:14  
  environment:  
    POSTGRES_USER: postgres  
    POSTGRES_PASSWORD: ${NODE_CARDANO_DB_SYNC_PASSWORD}  
    POSTGRES_DB: ${NODE_CARDANO_DB_SYNC_DATABASE:-cexplorer}  
  volumes:  
    - cardano_db_sync_postgres:/var/lib/postgresql/data  
  
cardano-db-sync:  
  image: ghcr.io/intersectmbo/cardano-db-sync:${CARDANO_DB_SYNC_VERSION}  
  depends_on:  
    - cardano-node  
    - cardano-db-sync-postgres  
  volumes:
```

```
- ${NODE_SOCKET_DIR}:/ipc
- ${NODE_CONFIGS}:/configs
environment:
  CARDANO_NODE_SOCKET_PATH: /ipc/${NODE_SOCKET_NAME}
  NETWORK: ${CARDANO_NETWORK}
  POSTGRES_HOST: cardano-db-sync-postgres
  POSTGRES_PORT: 5432
  POSTGRES_DB: ${NODE_CARDANO_DB_SYNC_DATABASE:-cexplorer}
  POSTGRES_USER: ${NODE_CARDANO_DB_SYNC_USERNAME:-postgres}
  POSTGRES_PASSWORD: ${NODE_CARDANO_DB_SYNC_PASSWORD}
```

DB Sync command flags and snapshot restore steps change across releases. Pin the DB Sync image, read its release notes, and validate synchronization on **preprod** before switching to **mainnet**. For **mainnet**, restore from a trusted snapshot or plan for a long initial sync.

Add the volume used by the DB Sync database:

```
volumes:
  cardano_db_sync_postgres:
```

Run DB Sync against the same node socket used by Cardano Wallet. DB Sync publishes synchronization progress in logs and in the **cexplorer** database. Before testing **did:prism** publication, confirm DB Sync is close to chain tip, then create, update, and resolve a DID through the Cloud Agent.

For DB Sync upgrades, read the release notes before changing the image tag. The 13.7.1.0 release notes state that upgrading from 13.7.0.x runs an **epoch** table migration and that compatible 13.7 and 13.6 mainnet snapshots are published. Treat snapshot compatibility as release-specific.

## Preprod and Mainnet Network Selection

Use **preprod** for the first production-style deployment. Cardano documentation describes pre-production as the mature test network that resembles mainnet for release testing. It uses test ADA, so issuer and verifier teams can test DID publication, credential issuance, credential revocation, and verification before moving real funds.

For preprod:

```
NODE_CARDANO_NETWORK=testnet
CARDANO_NETWORK=preprod
```

For mainnet:

```
NODE_CARDANO_NETWORK=mainnet
CARDANO_NETWORK=mainnet
```

Mainnet changes the risk profile. The operator must fund the PRISM Node wallet with real ADA, protect the Cardano Wallet mnemonic and passphrase, monitor balance, and approve transaction fee spending. Run at least one complete issuer flow on preprod before mainnet: create an issuer `did:prism`, issue a credential to a holder wallet, revoke or suspend it if your use case uses status lists, present it to verifier software, and confirm the verifier separates cryptographic checks from issuer and trust-policy checks.

## Copy Cardano Network Configuration

The Cardano Wallet repository stores network configuration under `configs/cardano`. Copy those files into the project working directory used by the Compose volume:

```
mkdir -p ./cardano
git clone --depth 1 https://github.com/cardano-foundation/cardano-wallet ./cardano/cardano-
cp -R ./cardano/cardano-wallet/configs ./cardano/configs
```

Run the refresh script from the `configs/cardano` directory. The script enters each network directory and runs that directory's `download.sh`:

```
(
  cd ./cardano/configs/cardano
  ./refresh.sh
)
```

Confirm the `preprod` directory contains the network files required by `cardano-node` and `cardano-wallet`:

```
ls ./cardano/configs/cardano/preprod
```

Expected files include:

```
alonzo-genesis.json
byron-genesis.json
config.json
conway-genesis.json
download.sh
shelley-genesis.json
topology.json
```

Create the data directories used by the Compose file:

```
mkdir -p ./cardano/node-db ./cardano/wallet-db ./cardano/ipc
```

## Start Preprod

Validate the Compose configuration before starting services:

```
docker compose \
  -p identus-preprod \
  -f ./infrastructure/shared/docker-compose-preprod.yml \
  --env-file ./infrastructure/preprod/.env-preprod \
  config
```

Start the stack:

```
./infrastructure/preprod/run.sh \
  -n preprod \
  -b \
  -w \
  -e ./infrastructure/preprod/.env-preprod \
  -p 8000 \
  -d agent.example.test
```

Check the Cloud Agent health endpoint through the same public base URL configured in `REST_SERVICE_URL`:

```
curl https://agent.example.test/cloud-agent/_system/health
```

For a lab before TLS termination, use the APISIX host port:

```
curl http://localhost:8000/cloud-agent/_system/health
```

Check Cardano Wallet network status:

```
curl http://127.0.0.1:8090/v2/network/information
```

Create or restore the Cardano wallet used by PRISM Node, fund it on `preprod`, then update these values in `.env-preprod`:

```
NODE_CARDANO_WALLET_ID=replace-after-wallet-create
NODE_CARDANO_WALLET_PASSPHRASE=replace-after-wallet-create
NODE_CARDANO_PAYMENT_ADDRESS=replace-after-wallet-create
```

Restart PRISM Node after changing those values.

## Production Checks

Use these checks before an issuer, verifier, holder wallet, or controller application depends on this deployment:

- Cloud Agent health returns the expected version and the public `REST_SERVICE_URL` uses HTTPS.
- `DIDCOMM_SERVICE_URL` is reachable from holder wallets and mediator services.
- API key authentication is enabled. `ADMIN_TOKEN` and `API_KEY_SALT` are long random values stored in the production secret system.
- `DEFAULT_WALLET_ENABLED=false` for multi-tenant deployments.
- `SECRET_STORAGE_BACKEND=vault` for production. Vault runs with production configuration, and wallet seed backup has an operator procedure.
- PostgreSQL ports stay on private networks. Cloud Agent, PRISM Node, and DB Sync databases have backups and restore tests.
- PRISM Node uses `NODE_CARDANO_NETWORK=testnet` for `preprod` and `mainnet` for `mainnet`. Cardano node, Cardano Wallet, and DB Sync use the matching `CARDANO_NETWORK` value, `preprod` or `mainnet`.
- Cardano Wallet has enough ADA for PRISM Node transactions. On `preprod`, use a faucet. On `mainnet`, monitor balance and transaction fees.
- DB Sync is close to chain tip before PRISM Node publication tests.
- A `did:prism` create operation reaches confirmed state, then a resolver can resolve the short-form DID.
- Verifier software separates technical credential checks from issuer, schema, trust registry, and business policy decisions.

Keep the example Docker files under source control for developer learning and reproducible lab work. For `mainnet`, move secrets, persistent storage, networking, TLS, monitoring, backups, and rollout policy into the deployment system your team uses for production operations.

# Maintenance

Mastering Identus means maintaining your application once it is launched. The production deployment from Chapter is not a single process; it is a set of long-running services — Cloud Agent, PRISM Node (or NeoPRISM), HashiCorp Vault, PostgreSQL, and, in Cardano mode, a Cardano node, Cardano Wallet, and Cardano DB Sync — that each have their own lifecycle, storage, and failure modes. This chapter covers the day-two work of keeping that stack healthy: restarting it cleanly, observing it, upgrading it without breaking compatibility, and protecting the secrets and keys it depends on.

This chapter assumes the deployment described in the production installation chapter. Where a topic is well-grounded in that deployment, the guidance below is concrete. Where Identus operational practice is still immature or undocumented, the section is marked as a placeholder to expand in a later draft.

## Restarting and Cleanup

The services in a Cardano-mode deployment have a dependency order, and restarts should respect it. Cardano Wallet and Cardano DB Sync both connect to the Cardano node through its node socket, PRISM Node depends on Cardano Wallet and DB Sync, and the Cloud Agent depends on PRISM Node and PostgreSQL. A clean restart generally moves outward from the ledger toward the application:

1. Start (or confirm) PostgreSQL and unseal Vault. The Cloud Agent cannot read wallet seeds while Vault is sealed.
2. Start `cardano-node`, then `cardano-wallet` and `cardano-db-sync` once the node socket is available.
3. Wait for DB Sync to reach close to chain tip before relying on `did:prism` publication or resolution.
4. Start PRISM Node, then the Cloud Agent, then the controller application.

A restart does not re-anchor existing DIDs. The Cloud Agent reconstructs DID key material from the wallet seed and stored derivation path, so seed availability (Vault unsealed and reachable) is the precondition for issuance and DID-update flows after a restart.

Cleanup is mostly about disk and logs. The Cardano services produce continuous logs during synchronization; keep log rotation configured for every long-running container, not just the Cardano ones. DB Sync's PostgreSQL database grows continuously and is the largest consumer of disk in the stack. Unlike the Cloud Agent and PRISM Node databases, DB Sync data is derived chain state: it can be rebuilt by resyncing or restored from a trusted snapshot, so it is a candidate for pruning or rebuild rather than long-term backup.

TODO: Add concrete cleanup runbooks — pruning Docker images and volumes, reclaiming DB Sync disk, and the resync-vs-snapshot decision with timings on `preprod` and `mainnet`.

## Observability

Operating Identus well means watching both the application layer (Cloud Agent and controller) and the ledger layer (Cardano services), because a problem in either can stall credential issuance while leaving the Cloud Agent itself “up.”

### Health and Service Checks

The production check list in Chapter is the starting point for ongoing monitoring. The checks worth running continuously, not just at launch, include:

- Cloud Agent health returns the expected version, and the public `REST_SERVICE_URL` answers over HTTPS.
- `DIDCOMM_SERVICE_URL` is reachable from holder wallets and mediator services.
- Cardano DB Sync is close to chain tip. A DB Sync that falls behind silently delays DID publication and resolution.
- Cardano Wallet reports a healthy network state (`/v2/network/information`) and, on mainnet, the PRISM Node payment address holds enough ADA for transaction fees.
- An end-to-end probe: a `did:prism` create operation reaches confirmed state and then resolves in short form.

### Managing Nodes and Memory

Cardano DB Sync is the heaviest resource consumer in the stack, and its requirements dominate sizing. The production chapter records mainnet figures on the order of 64 GB RAM, 4+ CPU cores, SSD storage at 60k IOPS or better, and several hundred GB of disk that grows over time; `preprod` is far smaller. Run DB Sync and its PostgreSQL database close together (ideally colocated) to keep synchronization latency low, and monitor database IOPS if services are split across machines.

For ongoing operation, watch:

- DB Sync PostgreSQL disk growth and remaining headroom.
- `cardano-node` and `cardano-db-sync` memory against the host’s limits.
- Cloud Agent and PRISM Node database size and query latency, which affect issuance and verification throughput.

## Performance Testing

TODO: Placeholder. The book does not yet define a performance-testing methodology for Identus. Expand this section with a repeatable load test (issuance, verification, and DID-resolution throughput), the metrics to capture, target numbers, and how Cardano confirmation depth bounds end-to-end issuance latency.

## Analytics with BlockTrust Analytics

TODO: Placeholder. BlockTrust Analytics is a third-party analytics tool for Identus/PRISM. Expand this section with what it observes, how to connect it to a running deployment, and which operational questions it answers that the raw health checks do not.

## Upgrading Agents

### Version Selection and Compatibility

Treat the Identus platform release notes as the first compatibility source. A platform release pins a set of components that are known to work together — for example, a Cloud Agent version, a Mediator version, a NeoPRISM version, and an SDK version. Newer standalone component releases (a newer Cloud Agent or PRISM Node image) may exist, but they require compatibility testing against the platform pin: untested Cloud Agent and PRISM Node image pairs can fail compatibility checks.

In practice, upgrades change one or more of these pinned versions:

- `AGENT_VERSION` (Cloud Agent)
- `PRISM_NODE_VERSION` (PRISM Node) or the NeoPRISM backend version
- `CARDANO_WALLET_TAG` and its paired `cardano-node` version
- `CARDANO_DB_SYNC_VERSION`

Whenever you change any Identus image, rerun the full production check list before depending on the deployment.

### Upgrade Procedure and Compatibility Notes

Cardano DB Sync upgrades deserve special care: read the release notes before changing the image tag. DB Sync upgrades can run schema migrations (for example, an `epoch` table migration between point releases), and snapshot compatibility is release-specific. Validate a DB Sync upgrade on `preprod` before applying it to `mainnet`, and confirm the new version still reaches chain tip and that PRISM Node can publish and resolve a test DID afterward.

For Cloud Agent and PRISM Node, confirm the pair is a tested combination, then upgrade and run an end-to-end issuer flow (create issuer DID, issue, optionally revoke/suspend, present, verify) before cutting traffic over.

## Minimizing Downtime

TODO: Placeholder. Document a low-downtime upgrade strategy. Open questions to resolve before writing this with confidence: whether the Cloud Agent supports running old and new versions side by side against a shared database, how database migrations are applied across an upgrade, and how to drain in-flight DIDComm and issuance flows. Until then, plan for a maintenance window.

## HashiCorp Vault and Key Management

### Key Management

For production, the Cloud Agent stores wallet seed material in Vault (`SECRET_STORAGE_BACKEND=vault`), under wallet-scoped paths such as `/secret/<wallet-id>/seed`, along with peer DID key paths and other secrets. A tenant's wallet seed is what lets the agent re-derive DID keys after a restart or redeploy; losing it can make existing DIDs unusable for future updates, deactivation, or issuance. Vault is therefore the single most important thing to protect and back up in the deployment.

Operational essentials carried over from the production chapter:

- Use AppRole (`VAULT_APPROLE_ROLE_ID / VAULT_APPROLE_SECRET_ID`) for automated deployments. Reserve `VAULT_TOKEN` for lab or break-glass use.
- Run Vault with production hardening: TLS, an unprivileged runtime user, a deliberate memory-lock/encrypted-swap decision, storage separation, and restricted network paths. A `server -dev` Vault is lab storage only.
- Back up Vault storage, test the restore, and document the unseal or recovery-key procedure. After any Vault restart, the store must be unsealed before the Cloud Agent can read seeds.

### Backups and Restore

Back up by data type, because the services do not all need the same treatment:

- **Cloud Agent and PRISM Node databases** hold application state. Back them up and test restores.
- **Vault storage** holds wallet seeds and key material. Back it up, test restore, and protect the unseal/recovery keys.
- **Cardano Wallet mnemonic and spending passphrase**, and the PRISM Node payment address, belong in the production secret system — never in `.env` files, CI logs, shell history, or the repository.

- **Cardano DB Sync database** is derived chain state. It can be rebuilt by resyncing or restored from a trusted snapshot, so it is lower priority for backup than application state.

## Key and Credential Rotation

Rotation covers two different kinds of secret. Operational credentials — `ADMIN_TOKEN`, tenant API keys, database passwords, Vault credentials, Keycloak client secrets, and the Cardano Wallet passphrase — protect access to the services, and rotate through the same process used for the rest of your production secrets. DID keys are different: they are protocol-level material that verifiers depend on, and rotating them changes what the rest of the world can verify. The procedures below are based on Cloud Agent 2.1.0; check the release notes when you upgrade, because key-selection behavior is an area where the agent is still evolving.

**Operational credentials.** Most of these rotate with a restart, but a few have behavior worth knowing before you start:

| Credential                           | Procedure                                                                                                                                                                                                                                   | Impact                                                                                                                                                                    |
|--------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <code>ADMIN_TOKEN</code>             | Generate a new value, update the secret store, and restart the Cloud Agent.                                                                                                                                                                 | The agent accepts one admin token. Admin automation fails until it uses the new value; tenant API calls are not affected.                                                 |
| Tenant API keys                      | Register a new key with <code>POST /iam/apikey-authentication</code> , move the tenant's application to it, then unregister the old key with <code>DELETE /iam/apikey-authentication</code> and the same <code>entityId/apiKey</code> body. | None, if done in that order: an entity can hold several API keys at once.                                                                                                 |
| <code>API_KEY_SALT</code>            | Do not rotate as routine maintenance.                                                                                                                                                                                                       | The Cloud Agent stores API keys as salted hashes, so changing the salt invalidates every registered API key at once. Treat it as a re-provisioning event for all tenants. |
| Vault AppRole <code>secret_id</code> | See the runbook below.                                                                                                                                                                                                                      | None, if the old <code>secret_id</code> stays valid until every agent instance has restarted.                                                                             |

Always generate a new random value for a replacement API key. The Cloud Agent keeps unregistered keys on record and refuses to register the same value again, and if a key that is

already registered is submitted for a *different* entity, the agent treats it as compromised and disables it.

**Rotating the Vault AppRole `secret_id`.** The Cloud Agent logs in to Vault with `VAULT_APPROLE_ROLE_ID` and `VAULT_APPROLE_SECRET_ID` at startup, and logs in again with the same pair before each token lease expires. Revoking the old `secret_id` while an agent is still running on it does not fail immediately; it fails at the next re-login, when the agent can no longer read wallet seeds. Rotate in this order:

1. Generate a new `secret_id` for the role, and record its accessor:

```
vault write -f auth/approle/role/cloud-agent/secret-id
```

2. Update `VAULT_APPROLE_SECRET_ID` in the production secret store and restart or roll every Cloud Agent instance.
3. Confirm each instance is healthy and can reach wallet material, for example by listing a tenant's DIDs.
4. Destroy the old `secret_id` by its accessor:

```
vault write auth/approle/role/cloud-agent/secret-id-accessor/destroy \
  secret_id_accessor=replace-with-old-accessor
```

If the role sets `secret_id_ttl` or `secret_id_num_uses`, remember that the agent's periodic re-login consumes them. A `secret_id` that expires or runs out of uses while the agent is running has the same effect as revoking it.

**Rotating `did:prism` keys.** A `did:prism` controller rotates verification keys by publishing a signed DID **update** operation through PRISM Node, which changes the DID Document's verification methods and relationships on-chain (see Chapter ). In the Cloud Agent this is `POST /did-registrar/dids/{didRef}/updates`, with `ADD_KEY` and `REMOVE_KEY` actions. The agent derives the new key from the wallet seed and records its derivation path.

The important constraint is on the verifier side. When the Cloud Agent verifies a JWT credential, it resolves the issuer DID's *current* DID Document and checks the signature against the keys listed under `assertionMethod`. Removing a key therefore breaks verification of every credential that key signed, not just future ones. Rotate an issuing key with an overlap period:

1. **Add the new key.** Submit an update that adds a key with the same purpose and curve as the one being replaced:

```
curl -X POST "https://agent.example.test/cloud-agent/did-registrar/dids/$ISSUER_DID/updates" \
  -H "apikey: replace-with-tenant-api-key" \
  -H "Content-Type: application/json" \
  -d '{
    "actions": [
      {
        "actionType": "ADD_KEY",
        "addKey": { "id": "assertion-2", "purpose": "assertionMethod", "curve": "secp256k1" }
      }
    ]
  }
```

```

    }
  ]
}'

```

The agent accepts one pending update per DID. Wait until the operation is confirmed on-chain and the DID resolves with the new key before submitting another update.

2. **Name the signing key in every issuance request.** While the DID has two `assertionMethod` keys, the Cloud Agent refuses to pick one: when it signs a JWT credential for an offer that did not set an issuing key ID, the issuance fails. The key is looked up at signing time, so this also catches offers created before the new key was added that are still waiting for the holder's request. Set `issuingKid` in `jwtVcPropertiesV1` (for example `"issuingKid": "assertion-2"`) on every offer, update your issuer application *before* step 1 is confirmed, and let in-flight offers complete first. OID4VCI issuance in this release does not take a key ID, so it fails for as long as the DID has more than one `assertionMethod` key; schedule the overlap accordingly if you use it.
3. **Reissue credentials** that must remain verifiable after the old key is removed, signing with the new key. Credentials that will expire or be revoked before the cutover can be left alone.
4. **Remove the old key** with a `REMOVE_KEY` action (`"removeKey": { "id": "assertion-1" }`) once no credential you still need depends on it. After removal, confirm that a freshly issued credential verifies, and that your status list credential still verifies. The agent signs status list credentials with the first `assertionMethod` key it finds, so a status list last signed with the removed key may need an update (a revocation or suspension) to be re-signed.

The DID's `master0` key, which signs the update operations themselves, is reserved: the Cloud Agent rejects `ADD_KEY` and `REMOVE_KEY` actions that name it, so it cannot be rotated through the API.

**The wallet seed cannot be rotated.** A wallet's seed is fixed when the wallet is created; the Cloud Agent has no endpoint to replace it, and every PRISM key in the wallet, including `master0`, is derived from it. "Rotating" a seed means creating a new wallet (with a new seed), creating and publishing new DIDs in it, reissuing credentials from the new DIDs, and moving tenants and relying parties over to them. Plan it as a migration.

That also defines the blast radius of a seed compromise. Anyone holding the seed can derive `master0` and publish update or deactivation operations for every PRISM DID in that wallet, so the response is urgent: deactivate the affected DIDs, create a new wallet and new DIDs, and reissue. Deactivating a DID means verifiers can no longer resolve usable keys for it, so every credential it issued stops verifying — which is the intended outcome when the signing keys can no longer be trusted, but should be communicated to holders and relying parties before it happens where possible. This is why the seed, and the Vault storage that holds it, is the single most important thing in the deployment to protect and back up.

## **Section V - Addendum**

# Trust Registries

Throughout this book we have followed credentials as they move between three roles: an issuer that signs a credential, a holder that stores and presents it, and a verifier that checks it. The cryptography we covered in Chapter answers a precise question: *was this credential really signed by the key it claims, and has it been tampered with?* That is a powerful guarantee, but it is not the whole story. A valid signature only tells the verifier that some key signed the credential. It does not tell the verifier whether the entity behind that key should be believed.

Consider a verifier that receives a university degree credential. The signature checks out. But anyone can stand up an Identus Cloud Agent, mint a Published DID, and issue a credential that claims to be a degree from that same university. The cryptography on that forged credential is just as valid. What separates the real issuer from the impostor is not math, it is *authority*: the genuine university is recognized, within some community, as an entity that is allowed to issue degrees. A Trust Registry is the mechanism that captures and answers questions about that authority.

## What a Trust Registry is

A Trust Registry is an authoritative, machine-readable list that records which entities are trusted to perform which roles within a particular community, or *ecosystem*. In its simplest form it answers a question like:

Is DID `did:prism:abc...` authorized to issue a credential of type `UniversityDegree` under the rules of this ecosystem?

The registry does not replace cryptographic verification; it sits alongside it. Verification proves *who signed* a credential. The Trust Registry proves *whether that signer is recognized* as an authority for what the credential asserts. A verifier needs both answers before it can safely act on a credential.

It is worth being precise about what a Trust Registry is not. It is not a certificate authority, and it does not issue or hold credentials itself. It is not a blockchain or a Verifiable Data Registry, although it may publish its data to one. It is a governed list, maintained by, or on behalf of, the body that defines the rules of an ecosystem. In the language of Self-Sovereign Identity, that body is the *governance authority*, and the document describing its rules is the *governance framework*. The Trust Registry is the queryable, runtime expression of that framework.

A few concrete examples make the idea easier to hold onto:

- A national education ministry maintains a registry of accredited universities that may issue degree credentials. A verifier checking a diploma asks the registry whether the issuing DID belongs to an accredited institution.
- A pharmacy board maintains a registry of licensed pharmacists. A system dispensing controlled medication asks whether the presenting practitioner's DID is currently licensed.
- An aviation authority maintains a registry of approved maintenance organizations whose technicians may sign airworthiness credentials.

In each case the same pattern holds: a community with rules, a body that maintains the list, and verifiers that consult the list at the moment of decision.

### **i** Note

Trust Registries are still an emerging part of the SSI landscape. Many production systems today rely on simpler mechanisms, such as a hard-coded list of trusted issuer DIDs configured directly in the verifier. Identus itself reflects this stage: as we saw in Chapter , its verification policies carry a `trustedIssuers` list scoped to a schema. A Trust Registry generalizes that idea into a shared, governed, externally queryable service. Much of what follows is therefore architectural and forward-looking rather than a description of widely deployed software.

## Where a Trust Registry sits in the architecture

The cleanest way to understand a Trust Registry is to see where it fits among the components we have already built. A Trust Registry is an external service that the verifier consults, separately from the credential exchange itself. It is not part of the DIDComm connection between holder and verifier, and the holder typically never touches it.

The diagram below shows a production-quality SSI deployment. The issuer, holder, and verifier each run an Identus Cloud Agent. Credentials are exchanged over DIDComm, routed through mediators as needed. DIDs are resolved against a Verifiable Data Registry. The Trust Registry stands to one side, queried by the verifier when it needs to make a trust decision.

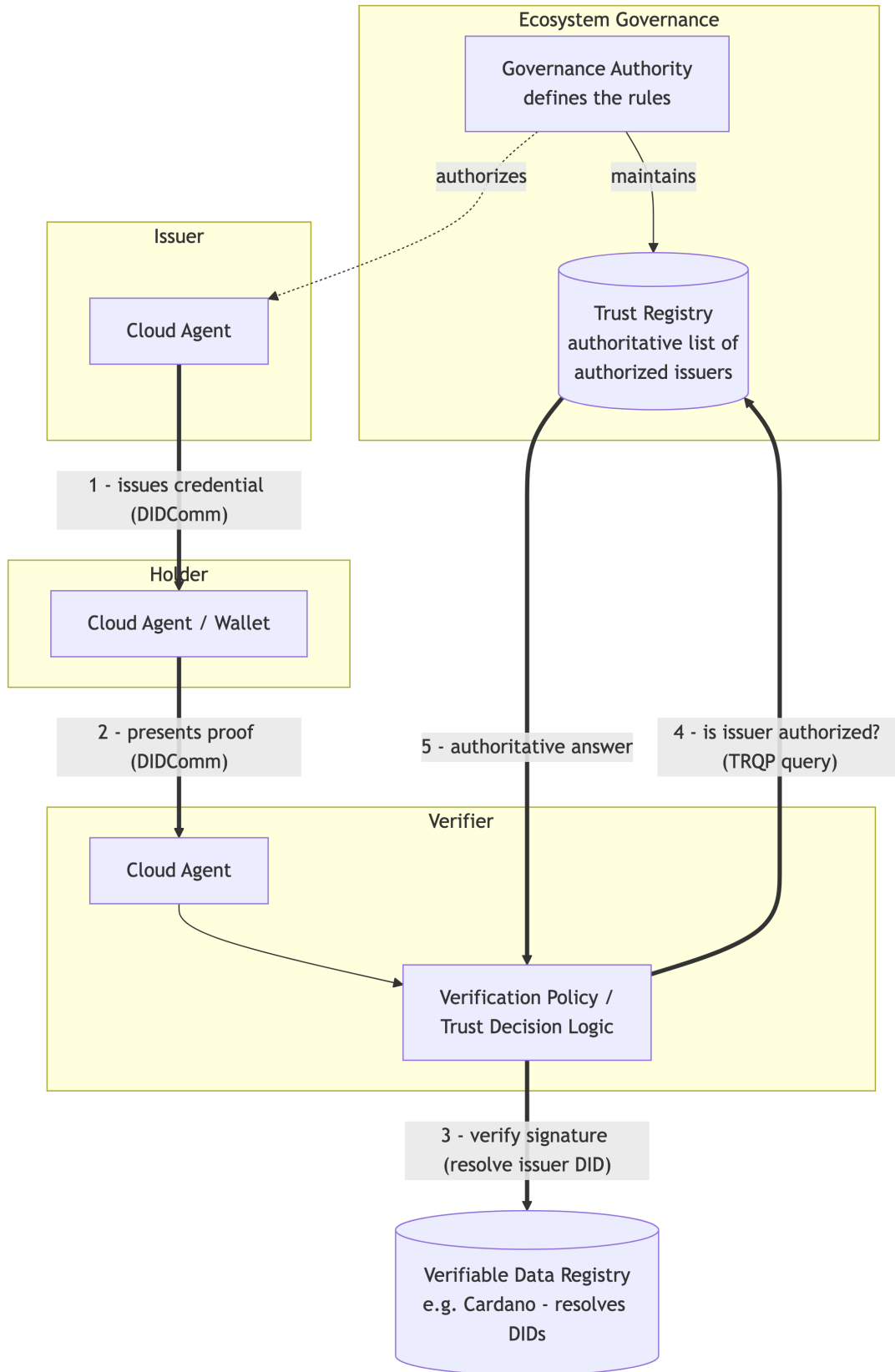


Figure 1: Where a Trust Registry sits in a production SSI architecture

Reading the flow from the verifier’s point of view:

1. The issuer issues a credential to the holder over DIDComm, exactly as described in Chapter .
2. Later, the holder presents a proof to the verifier over an existing DIDComm connection.
3. The verifier cryptographically verifies the presentation, resolving the issuer’s DID against the Verifiable Data Registry to check the signature.
4. The verifier asks the Trust Registry whether the issuer’s DID is authorized to issue this credential type under the relevant governance framework.
5. The Trust Registry returns an authoritative answer, which the verifier feeds into its final accept-or-reject decision.

Two properties of this layout matter. First, the Trust Registry query is *out of band* with respect to the credential exchange. It happens between the verifier and the registry; the holder is not involved and need not even know which registry the verifier consults. Second, trust verification and signature verification are deliberately separate steps. As noted in Chapter , a deployment using an external trust registry should keep the registry lookup separate from proof verification: the verifier resolves the trusted issuer set for the requested schema, then passes that result into its policy decision. A credential can be cryptographically perfect and still be rejected because its issuer is not in the registry.

## The ToIP Trust Registry Query Protocol (TRQP) 2.0

If every ecosystem invented its own way of exposing a Trust Registry, verifiers would need bespoke integration code for each community they interact with. The Trust Over IP Foundation (ToIP), which we introduce further in Chapter , addresses this with the **Trust Registry Query Protocol (TRQP)**. Its 2.0 specification defines a standard, read-only way to ask a Trust Registry whether an entity holds a given authorization within a given ecosystem.

A useful analogy from the specification is that TRQP is to trust registries what DNS is to name servers: a lightweight, universal query layer that lets any participant look up authoritative answers without knowing the internal implementation of the registry being queried. The protocol centers on two kinds of question:

- **Authorization queries** — *Does entity X hold authorization Y under the governance framework of ecosystem Z?* This is the question our verifier asks: is this issuer allowed to issue this credential type?
- **Recognition queries** — *Does this ecosystem recognize that other ecosystem (or registry) as authoritative?* This lets distinct communities acknowledge one another, so that trust can chain across organizational boundaries rather than stopping at the edge of a single registry.

Because the protocol is standardized and intentionally minimal, it is what allows different SSI applications and organizations to interoperate. A verifier built on Identus and a Trust Registry maintained by an unrelated organization can interact as long as both speak TRQP, without either side adopting the other’s stack. The specification separates the core protocol

from its transport bindings; the initial binding defines TRQP over HTTPS using an OpenAPI definition, with room for future bindings such as DIDComm. Crucially, TRQP is read-only: it queries trust data but never creates or modifies what lives inside a registry. How a registry's contents are populated and governed remains the responsibility of the ecosystem's governance authority.

For the full details, including the data model and the API definition, see the approved specification: [ToIP Trust Registry Query Protocol \(TRQP\) v2.0](#).

## Trust Registries and Identus today

Identus does not ship a built-in Trust Registry, and at the time of writing very few Trust Registries are running in production anywhere. What Identus gives you are the pieces a Trust Registry decision plugs into. As covered in Chapter , a verifier's **verification policy** already expresses a **trustedIssuers** set scoped to a **schemaId**. You can think of an external Trust Registry as the place that set should ultimately come from in a mature ecosystem: instead of hard-coding trusted issuer DIDs in each verifier, the verifier's controller queries a registry over TRQP, resolves the current authorized issuers for the credential type, and applies that result in its policy decision.

This keeps the architecture clean and future-proof. Your verifier's cryptographic checks stay where they are. The trust decision becomes a separate, swappable lookup, one that can start life as a static list during development and grow into a governed, TRQP-speaking registry as the ecosystem around your application matures.

### Note

Because Trust Registries are early in their adoption curve, treat this chapter as a map of where the ecosystem is heading. If you are building today, the practical advice is to keep your trust decision logic isolated from your verification logic, so that swapping a static issuer list for a real Trust Registry later is a localized change rather than a rewrite.

# Continuing on Your Journey

Information about becoming a Contributor to Identus

- How to contribute to the source code or documentation

Information about how to get involved in the SSI community outside of Identus

## **Trust over IP (ToIP)**

Trust Over IP (ToIP) comprises over 300 organizations from diverse industries collaborating to advance Decentralized Identity through ideas and software. According to ToIP, “We develop tools and specifications to help communities of any size use digital networks to build and strengthen trust between participants.”

The ToIP Stack, published in 2019, describes how the four layers (DIDs, DIDComm Protocol, Data Exchange Protocols, and Application Ecosystems) form a secure, scalable, and interoperable digital trust framework. Introduction to ToIP, Version 2.0, released in 2021, is an excellent resource for anyone catching up on the Digital Identity problem and solution. Membership options include free Contributor accounts and paid memberships, providing access to ToIP’s resources and Slack channels for collaboration.

To join Trust Over IP, you need to create a free Linux Foundation account and then complete your ToIP application [here](#).

All members agree to open, non-competitive participation, so please have your legal team review all associated documents during the onboarding process.

For further details, refer to The ToIP Stack and Overview.

## **Decentralized Identity Foundation (DIF)**

# Appendices

# Errata

Errata goes here

We will list any bugs that may have been “printed” in certain editions of the book.

# Glossary

This glossary collects the Self-Sovereign Identity (SSI), decentralized-identity, and Identus-specific terms used throughout the book. Definitions are written for the working developer: enough to follow the surrounding chapters, with pointers to the standards where a term is formally defined. Terms are listed alphabetically.

**ADA** The native cryptocurrency of the Cardano blockchain. PRISM Node spends ADA on transaction fees when it anchors `did:prism` operations on-chain — test ADA on test networks such as `preprod`, real ADA on `mainnet`.

**AnonCreds (Anonymous Credentials)** A privacy-preserving Verifiable Credential format originating in the Hyperledger Indy ecosystem. It uses zero-knowledge proofs and predicate proofs so a holder can prove facts (for example, “age over 21”) without revealing the underlying attribute values. Supported by the Identus Cloud Agent.

**API key** A per-tenant credential (sent in an `apikey` header) that scopes Cloud Agent API calls to a specific tenant’s wallet. Privileged administrative operations instead use an admin token.

**Apollo** The Identus building block that provides cryptographic primitives — hashing, digital signatures, encryption, and key generation — used across the platform to ensure data integrity, authenticity, and confidentiality.

**AppRole** A HashiCorp Vault authentication method (a role ID plus a secret ID) preferred over a static root token for automated, production Cloud Agent deployments.

**Aries (Hyperledger Aries)** A family of Hyperledger interoperability protocols (RFCs) for SSI agents — covering DID exchange, out-of-band invitations, issue-credential, and present-proof flows. The Identus Cloud Agent is built to be W3C- and Aries-compatible.

**assertionMethod** A verification relationship in a DID Document listing the keys approved for making assertions, including signing (issuing) Verifiable Credentials. A verifier checks that the credential’s signing key appears here.

**authentication** A verification relationship in a DID Document listing the keys approved for proving control of the DID through challenge-response authentication.

**Building Blocks** The set of focused, modular Identus libraries that each handle one area of SSI functionality: Apollo (cryptography), Castor (DIDs), Pollux (credentials), Mercury (DIDComm), and Pluto (storage). Both the Cloud Agent and the Edge Agent SDKs implement the same building blocks.

- Cardano** The public blockchain Identus uses as its production Verifiable Data Registry, anchoring `did:prism` operations so that anyone can resolve a published PRISM DID. Anchoring requires ADA to pay transaction fees.
- Cardano DB Sync** A Cardano component that follows the chain and indexes blocks into a PostgreSQL database so that PRISM Node can read ledger data efficiently. Typically the heaviest resource consumer in a self-hosted Cardano stack.
- Cardano Wallet** The Cardano-ecosystem service PRISM Node uses to manage funds and submit Cardano transactions when publishing DID operations. Distinct from an SSI wallet.
- Castor** The Identus building block that creates, manages, and resolves Decentralized Identifiers, currently supporting the `did:prism` and `did:peer` methods.
- Certificate Authority (CA)** The traditional centralized model of digital trust, in which a central authority vouches for identities. Contrasted in this book with a Trust Registry, which records authority within a governed ecosystem but does not itself issue or hold credentials.
- Claim** A single statement or attribute about a subject within a credential — for example a name, a date of birth, or a license category. A Verifiable Credential is a set of claims made by an issuer.
- Cloud Agent** The server-side Identus agent (written in Scala) that manages wallets, DIDs, and DIDComm messaging, and that can issue, hold, and verify Verifiable Credentials. It is driven by a controller application through its REST API and is expected to be online at all times.
- cnf (confirmation key)** A key-binding element embedded in an SD-JWT credential. It binds the credential to a holder key so the holder can later prove control by signing the verifier’s challenge and domain.
- Confirmation depth** The number of blocks that must be added after a DID transaction before its state is treated as final and safe to resolve. A tuning knob when anchoring DIDs on a ledger.
- Connection** An established, secure, ongoing DIDComm relationship between two agents, typically underpinned by Peer DIDs and tracked as a connection record in each party’s wallet.
- Controller (application)** The application that drives a Cloud Agent through its REST API and webhook callbacks. The controller holds the business logic; the agent handles the SSI standards work. (Not to be confused with a DID controller.)
- Coordinate Mediation** The DIDComm protocol (`coordinate-mediation/2.0`) a wallet uses to request mediation from a mediator and register the recipient keys for which the mediator should accept messages.
- Correlation** The linking of a person’s or organization’s activity across different contexts by means of a shared identifier or reused key. Public DIDs and reused DID Document material create correlation risk; pairwise DIDs reduce it.

**COSE** The CBOR-based family of cryptographic standards for signing and encryption — the binary counterpart to JOSE — referenced by the W3C VC “Securing with JOSE/COSE” recommendation.

**Credential offer** A message from an issuer proposing to issue a specific credential to a holder, which begins the credential issuance flow.

**Credential issuance** The protocol flow by which an issuer creates, signs, and delivers a Verifiable Credential into a holder’s wallet. In Identus this follows the Issue Credential protocol over DIDComm, or OpenID4VCI.

**Credential schema** A registered, shared definition of a credential type’s structure — its fields, types, and required attributes. Issuers issue against it, and verifiers and verification policies are scoped to it. Identus supports JSON Schema (for JWT/SD-JWT) and AnonCreds schemas.

**credentialStatus** The property inside a revocable credential that points to its status list entry, allowing a verifier to discover whether the credential has been revoked or suspended. Defined by the W3C VC Data Model.

**Decentralized Identifier (DID)** A globally unique identifier that an entity controls without a central registrar. Defined by the W3C DID Core specification, a DID is a URI with three parts — the `did:` scheme, a method name, and a method-specific identifier — and it resolves to a DID Document.

**Derivation path** The deterministic path used together with a wallet seed to regenerate a specific DID’s keys (hierarchical-deterministic key derivation). The Cloud Agent stores the path rather than the derived keys.

**DID controller** The entity authorized, under a DID method’s rules, to change a DID Document (rotate keys, add services, deactivate). The controller may be the same as the DID subject or a different entity acting on its behalf.

**DID Document** The document a DID resolves to. It publishes the public material needed to interact with the DID subject — verification methods, verification relationships, and service endpoints. It should never contain private keys, secrets, or a personal profile.

**DID method** The scheme (the part after `did:`, such as `prism` or `peer`) that defines how a particular class of DID is created, resolved, updated, and deactivated. The W3C defines the shared data model; each method specification defines its own registry, operations, and lifecycle.

**did:peer** See Peer DID.

**did:prism** See PRISM DID.

**DID resolution** The process of looking up a DID and returning its DID Document plus resolution metadata. Performed by a resolver that understands the relevant DID method.

- DIDComm (DIDComm Messaging V2)** A secure, encrypted, transport-agnostic messaging protocol for communication between DID-identified agents. DIDComm V2 (the version Identus uses) hides message content from everyone except authorized recipients, proves the sender in authenticated mode, and works over any transport (HTTP, WebSockets, Bluetooth, and so on).
- DIDPair** The cryptographic pairing of a sender DID and a recipient DID that together identify a DIDComm channel. A mediator maintains a message queue per DIDPair.
- DIF (Decentralized Identity Foundation)** An industry organization that develops decentralized-identity standards, including DIDComm and Presentation Exchange.
- DIF Presentation Exchange** A DIF specification for expressing what proof a verifier requires and how a holder's wallet responds. The Identus Cloud Agent implements it for credential requests and submissions.
- Disclosure (SD-JWT)** In an SD-JWT credential, the salted claim value a holder reveals at presentation time so the verifier can hash it and match it against the signed digest in the credential. Undisclosed claims stay hidden.
- Edge Agent** An Identus agent that runs inside a user-facing application (web, mobile, desktop), implemented as an SDK. Unlike a Cloud Agent, an Edge Agent cannot be assumed to be online and relies on a mediator to send and receive messages. Edge Agents typically act as the user's wallet.
- Edge SDK** The Identus client libraries — available in TypeScript, Swift, and Kotlin Multiplatform — that embed Edge Agent capabilities into an application. They implement the same building blocks as the Cloud Agent.
- Ecosystem** A community of participants operating under a shared governance framework within which trust relationships and authorizations are defined. A Trust Registry answers questions about authority within a specific ecosystem.
- Ed25519** A widely used elliptic-curve digital-signature algorithm and key type, used for authentication and credential signing (for example, required for SD-JWT issuer and holder keys in Identus).
- Entity** In the Cloud Agent, the administrative object that represents a tenant and is bound to a wallet. Authentication (an API key or Keycloak permission) is attached to an entity. In single-tenant mode a default entity (ID all-zeros) is used automatically.
- forward message** A DIDComm routing message (from the `routing/2.0` protocol) that wraps an already-encrypted message for a final recipient inside an outer envelope addressed to a mediator, so the mediator can route it without reading the inner content.
- Governance authority** The body that defines an ecosystem's rules and maintains, or oversees, its Trust Registry.

- Governance framework** The set of rules, published by a governance authority, describing who may do what within an ecosystem. A Trust Registry is its runtime, queryable expression. Authority comes from the governance framework, not from the registry technology itself.
- HashiCorp Vault** A secrets-management service that the Cloud Agent can use as its production secret storage backend for wallet seeds and key material, with per-wallet paths in multi-tenant deployments.
- Holder** The role that receives Verifiable Credentials, stores them (usually in a wallet), and creates presentations from them in response to verifier requests. The holder is often, but not always, the subject of the credential.
- Holder binding** Cryptographic evidence that the party presenting a credential actually controls the key associated with the credential's subject. See also key binding.
- Hyperledger Indy** A Hyperledger blockchain/SSI ecosystem from which the AnonCreds credential format originated.
- Identus (Hyperledger Identus)** The open-source decentralized-identity platform this book is about, hosted under the Linux Foundation's decentralized-trust umbrella. It provides the Cloud Agent, PRISM Node, Edge SDKs, and Mediator for issuing, holding, and verifying credentials.
- Issue Credential protocol** The DIDComm protocol (Issue Credential 3.0 in Identus) that governs the credential offer, request, and issuance message exchange between issuer and holder.
- Issuer** The role that makes claims about a subject, packages them as a Verifiable Credential, and cryptographically signs it. The issuer's authority comes from the surrounding context — law, accreditation, contract, or governance.
- Issuer DID** A DID controlled by an issuer and used to sign the credentials it issues, so verifiers can resolve the issuer's keys and check authorship. Issuer DIDs are typically public (PRISM DIDs).
- JOSE** The JSON-based family of cryptographic standards (JSON Web Signature, JSON Web Encryption, JSON Web Key, JSON Web Token) commonly used to secure credentials. See also COSE.
- JSON Web Key (JWK)** A JSON format for representing a cryptographic key. DID Documents and DIDComm key material are often expressed as JWKs.
- JWT-VC** A Verifiable Credential format that packages claims inside a signed JSON Web Token (JWT). A JWT-VC is generally presented whole, so all of its claims are revealed (no selective disclosure).
- keyAgreement** A verification relationship in a DID Document listing keys approved for key agreement — for example, establishing the encryption used by DIDComm. Typically backed by an X25519 key.
- Key binding** Cryptographically tying a credential to a holder's key so the holder can prove control of that key when presenting the credential. See also holder binding and *cnf*.

- Keycloak** An identity and access-management server that Identus can integrate so that tenants authenticate via OIDC and receive wallet permissions via UMA, replacing static API keys.
- Ledger anchoring** Recording DID operations as transactions on a blockchain (such as Cardano) so they become tamper-evident and publicly resolvable.
- Link secret** A holder-controlled secret used by AnonCreds to bind issued credentials to the holder and to enable zero-knowledge proofs across multiple credentials.
- Long-form / Short-form PRISM DID** Two encodings of a PRISM DID. The long form embeds the DID's full initial state in the identifier and is resolvable before the DID is published. The short form is the compact identifier used once the DID has been published to the ledger.
- Mediation** The arrangement a holder's wallet establishes with a mediator so the mediator will receive and relay DIDComm messages on its behalf. It produces routing information the wallet then advertises in its DID Document.
- Mediator** A DIDComm V2 service that acts as a stable, always-online relay for agents — such as mobile wallets — that are not continuously reachable. It queues encrypted messages per DIDPair and delivers them when the recipient polls or connects, without being able to read the encrypted content. It is *not* a VDR.
- Mercury** The Identus building block that provides the DIDComm V2 interface for secure agent-to-agent messaging, independent of the underlying transport.
- Message Pickup** The DIDComm protocol (`messagepickup/3.0`) a wallet uses to poll a mediator for queued messages, request their delivery, and confirm receipt.
- Multi-tenancy** A Cloud Agent mode in which a single agent instance hosts many isolated tenants, each with its own wallet, DIDs, credentials, and connections. The opposite is single-tenant mode, which serves one default wallet.
- NeoPRISM** A newer DID-node backend for Identus, recommended for production, that can replace the legacy PRISM Node as the way `did:prism` operations are published and resolved.
- OpenID4VCI (OID4VCI)** OpenID for Verifiable Credential Issuance — an OAuth 2.0-based protocol for a wallet to obtain credentials from an issuer's credential endpoint. An alternative issuance path to DIDComm.
- OpenID4VP** OpenID for Verifiable Presentations — an OAuth 2.0-based protocol for requesting and presenting credentials. An alternative presentation path to DIDComm.
- OIDC (OpenID Connect)** A standard authentication protocol layered on OAuth 2.0, used (via Keycloak) to authenticate tenants and issue access tokens.
- Out-of-Band (OOB) invitation** A self-contained DIDComm invitation — often delivered as a URL or QR code (carried in an `_oob` query parameter) — that lets a new party start a connection, mediation, or a connectionless issuance/presentation without a pre-existing channel.

- Pairwise DID** A DID created uniquely for a single relationship, so that each relationship uses a different pseudonymous identifier. Pairwise (relationship-specific) DIDs reduce correlation across contexts; Peer DIDs are typically used this way.
- Peer DID** A DID (method `did:peer`) shared privately between the parties to a relationship and not published to any public ledger. Identus uses Peer DIDs for DIDComm connections and mediation, where relationship-specific identifiers reduce correlation.
- Pluto** The Identus building block that defines the storage interface for identity data (DIDs, keys, credentials, connection state). The application supplies the concrete storage implementation.
- Pollux** The Identus building block (and Cloud Agent subsystem) responsible for Verifiable Credential operations — issuance, verification, selective disclosure, and credential status.
- Predicate proof** A proof that an attribute satisfies a condition (for example, `age >= 21`) without disclosing the underlying value. A core feature of AnonCreds and zero-knowledge proofs.
- Presentation request** A message (also called a proof request) in which a verifier specifies exactly what proof it needs from a holder. Carried by the Present Proof protocol.
- Present Proof protocol** The DIDComm, format-neutral protocol (Present Proof 3.0 in Identus) that carries a presentation request from a verifier and a presentation back from a holder.
- PRISM DID** A DID using Identus’s `did:prism` method, whose create, update, and deactivate operations are anchored to the Cardano ledger via PRISM Node. PRISM DIDs suit public issuer and verifier identities that need ledger-backed resolution. See also long-form / short-form.
- PRISM Node** The Identus component that implements the `did:prism` method, acting as a second-layer node over the ledger. It publishes and resolves PRISM DIDs, maintaining an indexed internal state synchronized with the underlying blockchain. It serves as the VDR for PRISM DIDs and is expected to be online at all times.
- Published DID** A DID whose operations have been anchored to the ledger so that any party can resolve it. Contrasted with an unpublished DID — for example, a holder usually does not need to publish their DID, whereas an issuer typically must.
- Recipient keys** The keys a wallet registers with a mediator so the mediator knows which incoming messages to queue for that recipient.
- Relying party** The party that consumes a verification result and applies business and trust policy — accepted issuers, schemas, and credential types — to decide whether to act. Often the same actor as the verifier.
- Resolver** Software that performs DID resolution: given a DID, it returns the DID Document. A Universal Resolver routes many methods to method-specific drivers. Resolver choice is itself a trust decision.

- Revocation / Suspension** Invalidating a previously issued credential — permanently (revocation) or temporarily (suspension) — before its natural expiry. The change is reflected through a status list that verifiers check via `credentialStatus`.
- SD-JWT / SD-JWT-VC** Selective Disclosure JWT — a JWT variant that uses salted hashes (digests) so a holder can reveal only selected claims while the verifier checks each disclosed value against the signed digest. SD-JWT-VC is the Verifiable Credential format built on it. Supported by Identus. See `disclosure` and `cnf`.
- secp256k1** An elliptic-curve key and signature algorithm (also used by Bitcoin and Cardano) supported by Identus for certain credential and status-list proofs.
- Secret storage** The Cloud Agent’s configurable store for wallet seeds and private keys. A `postgres` backend stores secrets in plaintext (lab use only); a HashiCorp Vault backend is recommended for production.
- Selective disclosure** A holder’s ability to reveal only the specific claims a verifier needs, rather than an entire credential — for example, proving “over 21” without revealing a full birth date. It depends on the credential format (SD-JWT and AnonCreds support it; plain JWT-VC does not) and supports the practice of data minimization.
- Self-Sovereign Identity (SSI)** A model of digital identity built around user-held credentials and cryptographic proofs rather than a central identity provider. A subject receives a credential from an issuer, stores it as a holder, and presents proof to a verifier who checks it against its own policy. SSI changes the custody and exchange of identity data; governance, law, and reputation still shape trust.
- Service endpoint** An entry in a DID Document advertising where and how to interact with the DID subject — for example, a `DIDCommMessaging` endpoint that names the URL, accepted DIDComm profile, and routing keys.
- Status list** A published, space-efficient revocation mechanism (such as a Bitstring Status List / `StatusList2021`) in which each bit represents the revocation or suspension status of one credential. A verifier reads the bit referenced by a credential’s `credentialStatus`. In Identus this is provided by Pollux.
- Subject** The person, organization, device, account, or thing that a credential’s claims describe. The subject is often the holder but need not be — a parent may hold a credential about a child, or a fleet manager about a device.
- Tenant** A logical user or organization served by a Cloud Agent, represented by an entity and backed by an isolated wallet. See `multi-tenancy`.
- ToIP (Trust over IP Foundation)** A Linux Foundation body developing standards for decentralized digital trust, including the ToIP Stack (a layered model of DIDs, DIDComm, data-exchange protocols, and application ecosystems) and the Trust Registry Query Protocol.
- Triangle of Trust** A common way of describing the three SSI roles — issuer, holder, and verifier — and the credential/presentation flows between them. The roles are interaction-specific: the same entity can issue one credential, hold another, and verify a third.

- TRQP (Trust Registry Query Protocol)** A ToIP read-only protocol for asking a Trust Registry whether an entity holds a given authorization under a given ecosystem’s governance — in plain terms, “Does entity X hold authorization Y under governance framework Z?” Sometimes described as “DNS for trust registries.”
- Trust Registry** An authoritative, governed, machine-readable record of which entities are authorized to play which roles in an ecosystem. A verifier queries it to confirm an issuer’s *authority* — a separate question from the cryptographic *validity* of a credential. A Trust Registry is not a Certificate Authority and is not a VDR.
- Trusted issuers** The set of issuer DIDs, usually scoped to a credential schema, that a verifier accepts as authoritative. In Identus this is configured today in a verification policy and is the concept a Trust Registry generalizes.
- UMA (User-Managed Access)** An OAuth 2.0-based authorization standard that Keycloak uses to grant a subject permission to a specific Cloud Agent wallet resource, issuing a Requesting Party Token (RPT) the tenant presents to the agent.
- Universal Resolver** A public resolver service able to resolve many different DID methods by routing each to a method-specific driver.
- Validation** The verifier’s business-rule check on whether a credential is *appropriate* for a particular decision — for example, whether the issuer is acceptable under a hiring policy. Distinct from verification: a credential can be cryptographically valid yet fail validation.
- Verifiable Credential (VC)** A set of claims made by an issuer, secured with a cryptographic mechanism so that software can detect tampering and confirm authorship. Defined by the W3C Verifiable Credentials Data Model. The data model is separate from the credential format (see JWT-VC, SD-JWT-VC, AnonCreds).
- Verifiable Data Registry (VDR)** A system — often a blockchain, but potentially a database, distributed network, or in-memory store — against which DIDs and related data are published and resolved, so that independent parties can verify authenticity and integrity without a central authority. Identus accesses VDRs through pluggable drivers (for example, the PRISM Node and NeoPRISM drivers). A mediator is not a VDR.
- Verifiable Presentation (VP)** Data derived from one or more Verifiable Credentials and shared with a specific verifier in response to a request. Depending on the credential format, a presentation can include a whole credential, parts of one (see selective disclosure), or data from several.
- Verification** The technical check that a credential or presentation is cryptographically sound: valid signatures, correctly resolved issuer keys, proper key usage (verification relationships), current status, and holder binding. Distinct from validation, which applies business policy.
- Verification method** An entry in a DID Document that specifies a public key (for example as a JWK), its type, and its controller. Verification methods are referenced by verification relationships for specific purposes.

- Verification policy** The verifier-side configuration in Identus expressing which credential schemas and trusted issuers are accepted. Applied after cryptographic checks, it is the practical form of acceptance policy / validation.
- Verification relationship** The association in a DID Document between a verification method and a permitted purpose — `authentication`, `assertionMethod`, `keyAgreement`, `capabilityInvocation`, or `capabilityDelegation`. These relationships prevent a key from being reused across proof purposes.
- Verifier** The role that requests a presentation from a holder and decides whether to accept it, performing both verification (cryptographic checks) and validation (business policy). See also relying party.
- Wallet** In SSI, software that stores and protects a party’s DIDs, keys, connections, and credentials, and that creates presentations. In the Identus Cloud Agent, a wallet is also the unit of tenant isolation. A holder’s wallet is usually an Edge Agent; a server-side wallet runs in a Cloud Agent. Distinct from a Cardano Wallet.
- Wallet seed** The secret root key material from which a wallet deterministically derives its DID keys, via a stored derivation path. It is a high-value secret: losing it can permanently break the ability to use or update existing DIDs.
- Webhook** The HTTP callback mechanism by which the Cloud Agent notifies a controller of state changes — a received connection, a credential issued or received, a presentation verified, and so on.
- X25519** An elliptic-curve key type used for Diffie-Hellman key agreement to set up the encryption used by DIDComm. Appears in DID Documents under the `keyAgreement` relationship.
- Zero-knowledge proof (ZKP)** A cryptographic technique that proves a statement is true without revealing the underlying data. The basis of AnonCreds predicate proofs such as “over 21” without disclosing a birth date.